

Implementação

COBIT® 5

AN ISACA® FRAMEWORK

Personal Copy of: Mr. Jorge Diab Maluf Filho

ISACA®

Com 95.000 membros em 160 países, a ISACA (www.isaca.org) é líder global no fornecimento de informações, certificações, padrões, apoio e experiência para a garantia e segurança relacionadas a sistemas de informação (SI), governança corporativa e gestão da Tecnologia da Informação (TI), além de conformidade e riscos a ela relacionados.

Fundada em 1969, sem fins lucrativos, a ISACA acolhe conferências internacionais independentes, publica o ISACA® Journal e desenvolve padrões internacionais para auditoria e controle de SI que ajudam seus membros a garantir a confiança e o valor dos sistemas de informação. Também promove e certifica os seguintes conhecimentos e habilidades de ponta a ponta em TI que são mundialmente respeitadas Certified Information Systems Auditor® (CISA®), Certified Information Security Manager® (CISM®), Certified in the Governance of Enterprise IT® (CGEIT®) e Certified in Risk and Information Systems Control™ (CRISC™). A ISACA atualiza continuamente o COBIT®, o que ajuda os profissionais de TI e os líderes organizacionais a cumprirem suas responsabilidades de gestão e governança de TI, especialmente nas áreas de garantia, segurança, risco e controle, e entrega de valor para o negócio.

Declaração de Qualidade

Esta obra foi traduzida da versão em Inglês do COBIT® 5 Implementation para o Português Brasileiro com a colaboração dos capítulos de Brasília e Rio de Janeiro sob coordenação do ISACA Capítulo São Paulo detentor da permissão legal outorgada pela ISACA. O ISACA Capítulo São Paulo assume total responsabilidade pela precisão e fidelidade da tradução.

Quality Statement

This Work is translated into Brazilian Portuguese from the English language version of COBIT® 5 Implementation by the ISACA® Sao Paulo Chapter with the permission of ISACA®. The ISACA® Sao Paulo Chapter assumes sole responsibility for the accuracy and faithfulness of the translation.

Aviso Legal

A ISACA desenvolveu esta publicação, o COBIT® 5 Implementation (a 'Obra'), essencialmente como um recurso educacional para profissionais de Governança Corporativa de TI (GEIT), garantia, risco e segurança. A ISACA não afirma que o uso de qualquer parte da Obra garantirá um resultado bem-sucedido. A Obra não deve ser considerada como contendo todas as informações, procedimentos e testes adequados ou exclusiva de outras informações, procedimentos e testes que sejam voltados à obtenção dos mesmos resultados. Ao determinar a adequação de qualquer informação, procedimento ou teste específico, os leitores deverão aplicar seu próprio julgamento profissional às circunstâncias específicas de GEIT, garantia, risco e segurança apresentados pelos sistemas ou ambientes de tecnologia da informação particulares.

Disclaimer

ISACA has designed this publication, COBIT®5 Implementation (the 'Work'), primarily as an educational resource for governance of enterprise IT (GEIT), assurance, risk and security professionals. ISACA makes no claim that use of any of the Work will assure a successful outcome. The Work should not be considered inclusive of all proper information, procedures and tests or exclusive of other information, procedures and tests that are reasonably directed to obtaining the same results. In determining the propriety of any specific information, procedure or test, readers should apply their own professional judgement to the specific GEIT, assurance, risk and security circumstances presented by the particular systems or information technology environment.

Direitos de Uso

© 2012 ISACA. Todos os direitos reservados. Para orientações de uso, vide www.isaca.org/COBITuse.

Copyright

© 2012 ISACA. All rights reserved. For usage guidelines, see www.isaca.org/COBITuse.

ISACA

3701 Algonquin Road, Suite 1010
Rolling Meadows, IL 60008 EUA
Tel: +1.847.253.1545
Fax: +1.847.253.1443
E-mail: info@isaca.org
Websit e: www.isaca.org

Personal Copy of: Mr. Jorge Diab Maluf Filho

Feedback: www.isaca.org/cobit
Participe do ISACA Knowledge Center: www.isaca.org/knowledge-center
Siga a ISACA no Twitter: https://twitter.com/ISACANews
Junte-se à discussão do COBIT no Twitter: #COBIT
Junte-se à ISACA no LinkedIn: ISACA (Oficial), http://linkd.in/ISACAOfficial
Curta a ISACA no Facebook: www.facebook.com/ISACAHQ

COBIT® 5 Implementation
ISBN 978-1-60420-292-2

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página intencionalmente deixada em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

RECONHECIMENTOS

A ISACA gostaria de reconhecer:

Força Tarefa COBIT 5 (2009–2011)

John W. Lainhart, IV, CISA, CISM, CGEIT, IBM Global Business Services, EUA, Co-presidente
Derek J. Oliver, Ph.D., DBA, CISA, CISM, CRISC, CITP, FBCS, FISM, MInstISP, Ravenswood Consultants Ltd., Reino Unido, Co-presidente
Pippa G. Andrews, CISA, ACA, CIA, KPMG, Austrália
Elisabeth Judit Antonsson, CISM, Nordea Bank, Suécia
Steven A. Babb, CGEIT, CRISC, Betfair, Reino Unido
Steven De Haes, Ph.D., University of Antwerp Management School, Bélgica
Peter Harrison, CGEIT, FCPA, IBM Australia Ltd., Austrália
Jimmy Heschl, CISA, CISM, CGEIT, ITIL Expert, bwin.party digital entertainment plc, Áustria
Robert D. Johnson, CISA, CISM, CGEIT, CRISC, CISSP, Bank of America, EUA
Erik H.J.M. Pols, CISA, CISM, Shell International-ITCI, Holanda
Vernon Richard Poole, CISM, CGEIT, Sapphire, Reino Unido
Abdul Rafeq, CISA, CGEIT, CIA, FCA, A. Rafeq and Associates, Índia

Equipe de Desenvolvimento

Gert du Preez, CGEIT, PwC, Canadá
Gary Hardy, CGEIT, IT Winners, África do Sul
Dirk Steuperaert, CISA, CGEIT, CRISC, IT In Balance BVBA, Bélgica

Revisores Especialistas

Brian Barnier, CGEIT, CRISC, ValueBridge Advisors, EUA
Dirk Bruyndonckx, CISA, CISM, CGEIT, CRISC, MCA, KPMG Advisory, Bélgica
Christophe Burtin, CISA, ITIL LA 27001, Strategy and Governance, Luxemburgo
Ben Farhangui, Atos Worldline, Bélgica
James Golden, CISM, CGEIT, CRISC, CISSP, IBM, EUA
Jorge Hidalgo, CISA, CISM, CGEIT, ATC, Lic. Sistemas, Argentina
John Manzini, ITIL, Denel Aviation, África do Sul
Lucio Augusto Molina Focazzio, CISA, CISM, CRISC, ITIL, Independent Consultant, Colômbia
Robert Payne, CGEIT, MBL, MCSSA, PrM, Lode Star Strategy Consulting, África do Sul
Martin Rosenberg, Ph.D., Cloud Governance Ltd., Reino Unido
Claus Rosenquist, CISA, CISSP, Nets Holding, Dinamarca
Michael Shortt, CISA, CGEIT, Governance Realm IT, África do Sul
Ant Smith, Ph.D., JD Group, África do Sul
Greet Volders, CGEIT, Voquals N.V., Bélgica
Charl Weitz, CISA, Metropolitan, África do Sul
Tichaona Zororo, CISA, CISM, CGEIT, Standard Bank, África do Sul

Conselho de Administração da ISACA

Kenneth L. Vander Wal, CISA, CPA, Ernst & Young LLP (aposentado), EUA, Presidente Internacional
Christos K. Dimitriadis, Ph.D., CISA, CISM, CRISC, INTRALOT S.A., Grécia, Vice-Presidente
Gregory T. Grocholski, CISA, The Dow Chemical Co., EUA, Vice-Presidente
Tony Hayes, CGEIT, AFCHSE, CHE, FACS, FCPA, FIIA, Queensland Government, Austrália, Vice-Presidente
Niraj Kapasi, CISA, Kapasi Bangad Tech Consulting Pvt. Ltd., Índia, Vice-Presidente
Jeff Spivey, CRISC, CPP, PSP, Security Risk Management, Inc., EUA, Vice-Presidente
Jo Stewart-Rattray, CISA, CISM, CGEIT, CRISC, CSEPS, RSM Bird Cameron, Austrália, Vice-Presidente
Emil D'Angelo, CISA, CISM, Bank of Tokyo-Mitsubishi UFJ Ltd. (aposentado), EUA, Ex-Presidente Internacional
Lynn C. Lawton, CISA, CRISC, FBCS CITP, FCA, FIIA, KPMG Ltd., Rússia, Ex-Presidente Internacional
Allan Neville Boardman, CISA, CISM, CGEIT, CRISC, CA (SA), CISSP, Morgan Stanley, Reino Unido, Diretor
Marc Vael, Ph.D., CISA, CISM, CGEIT, CISSP, Valuendo, Bélgica, Diretor

Personal Copy of: Mr. Jorge Diab Maluf Filho

Reconhecimentos (Cont)

Conselho de Conhecimento

Marc Vael, Ph.D., CISA, CISM, CGEIT, CISSP, Valuendo, Bélgica, Presidente
Michael A. Berardi Jr., CISA, CGEIT, Bank of America, EUA
John Ho Chi, CISA, CISM, CRISC, CBCP, CFE, Ernst & Young LLP, Cingapura
Phillip J. Lageschulte, CGEIT, CPA, KPMG LLP, EUA
Jon Singleton, CISA, FCA, Auditor General of Manitoba (aposentado), Canadá
Patrick Stachtchenko, CISA, CGEIT, Stachtchenko & Associates SAS, França

Comitê do Modelo (2009-2012)

Patrick Stachtchenko, CISA, CGEIT, Stachtchenko & Associates SAS, França, Presidente
Georges Ataya, CISA, CISM, CGEIT, CRISC, CISSP, Solvay Brussels School of Economics and Management, Bélgica, Ex-Vice-Presidente
Steven A. Babb, CGEIT, CRISC, Betfair, Reino Unido
Sushil Chatterji, CGEIT, Edutech Enterprises, Cingapura
Sergio Fleginsky, CISA, Akzo Nobel, Uruguai
John W. Lainhart, IV, CISA, CISM, CGEIT, CRISC, IBM Global Business Services, EUA
Mario C. Micallef, CGEIT, CPAA, FIA, Malta
Anthony P. Noble, CISA, CCP, Viacom, EUA
Derek J. Oliver, Ph.D., DBA, CISA, CISM, CRISC, CITP, FBCS, FISM, MInstIS, Ravenswood Consultants Ltd., Reino Unido
Robert G. Parker, CISA, CA, CMC, FCA, Deloitte & Touche LLP (aposentado), Canadá
Rolf M. von Roessing, CISA, CISM, CGEIT, CISSP, FBCI, Forfa AG, Suíça
Jo Stewart-Rattray, CISA, CISM, CGEIT, CRISC, CSEPS, RSM Bird Cameron, Austrália
Robert E. Stroud, CGEIT, CA Inc., EUA

Afiliados e Patrocinadores da ISACA e do IT Governance Institute® (ITGI®)

American Institute of Certified Public Accountants
Commonwealth Association for Corporate Governance Inc.
FIDA Inform
Information Security Forum
Institute of Management Accountants Inc.
Capítulos da ISACA
. ITGI França
. ITGI Japão
Norwich University
Solvay Brussels School of Economics and Management
Strategic Technology Management Institute (STMI) of the National University of Singapore
University of Antwerp Management School
Enterprise GRC Solutions Inc.
Hewlett-Packard
IBM
Symantec Corp.

Reconhecimento da tradução para a língua portuguesa

Coordenação
Jose Luis Diniz, CGEIT, ITIL Expert, DNZ Consultoria - Capítulo São Paulo
Edson Kowask, CRISC, Rede Nacional de Ensino e Pesquisa (RNP) – Capitulo Brasília

Voluntários
Alessandro Manotti, CISM, CISA, Itaú Unibanco
Alexandre Rodrigues da Silva, CISA, Ford Motor Company
Bruno Domingos Rodrigues, ITIL Expert, PMP, ISO 20000, COBIT 5, Val IT Treinamento e Consultoria Empresarial
Bruno Henrique Montenegro Ferreira, COBIT 5 Foundation & Implementation, Ministério Público de Pernambuco
Eberson de Almeida Campos, MBA, CGEIT, COBIT, ITIL, Bradesco S/A
Edson Kowask, CRISC, Rede Nacional de Ensino e Pesquisa (RNP)
Eduardo Filho, COBIT 4.1, ISO 27000 LA, ITIL V3, Sonda IT

Personal Copy of: Mr. Jorge Diab Maluf Filho

Eduardo Massaru Kono, CISA, COBIT, MBA, Volkswagen Serviços Financeiros
Fabio Justo Hildebrand, CISA, CISSP, CISM, CGEIT, Ace Group
Jose Alex Belarmino, COBIT, ITIL, SOA/PPO/RCV/OSA, OCEB, Hewlett-Packard, FAESA
Juliano Augusto Martins de Oliveira, CISA, CISM, COBIT Fundation e ITIL Fundation, Serasa Experian
Julio Graziano Pontes, CISM, CISSP, CCSK, QSA, ISO 27000 LA, FireMon LLC
Leandro Pfeifer Macedo, CRISC, ITSM, MCSO, Lpfeifer Ltda.
Marcelo Silva Cunha, MSc, Prodasen
Marcus Garcia de Almeira, Mestre em Ciência, Gestão e TI; Pós Graduação em Gestão do Conhecimento; Doutorado em Educação, PROFISSIONAIS.COM, Lume Tecnologia, Futuro Eventos
Monica Keiko Kosaka, Segurança da Informação, Tokio Marine Seguradora S/A
Nathália Galhego, COBIT 4.1,ISO 27001 LA, Teleperformance
Nestor N. de Albuquerque, MsC, Processware
Paulo Keglevich, MSc, CSM, PMP, PBA ITILv3, CGEIT, COBIT5, MSP, P3O e PRINCE2, KSC Projetos & Soluções
Rosvelt S. Santos, CGEIT, TOTVS

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página deixada intencionalmente em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

ÍNDICE

Capítulo 1 Introdução 13
Objetivos e Escopo do Guia 14
Capítulo 2 Posicionando a GEIT 17
Entendimento do Contexto 17
O que é a GEIT? 17
Por que a GEIT é tão importante? 17
O que a GEIT Deve Proporcionar? 18
Potencialização do COBIT 5 e Integração de Modelos, Padrões e Boas Práticas 19
Princípios e Habilitadores 19
capítulo 3 Primeiros Passos em Direção à GEIT 21
Criação do Ambiente Adequado 21
Aplicação da Abordagem de Ciclo de Vida de Melhoria Contínua 22
1ª Fase - Quais São os Direcionadores? 24
2ª Fase - Onde Estamos Agora? 24
3ª Fase - Onde Queremos Chegar? 24
4ª Fase - O Que Deve Ser Feito? 24
5ª Fase - Como Chegamos Lá? 24
6ª Fase - Já Chegamos Lá? 24
7ª Fase - Como Mantemos Essa Dinâmica? 24
Primeiros Passos - Identificar a Necessidade de Agir: Reconhecer Dificuldades e Eventos Desencadeadores 25
Dificuldades Mais Comuns 25
Eventos Desencadeadores nos Ambientes Internos e Externos 26
Envolvimento das partes interessadas 27
Reconhecimento dos Papéis e Requisitos das Partes Interessadas 28
Partes Interessadas Internas 28
Partes Interessadas Externas 30
Avaliação Independente e o Papel dos Auditores 30
Capítulo 4 Identificação dos Desafios e Fatores de Sucesso da Implementação 31
Criação do Ambiente Adequado 31
1ª Fase - Quais São os Direcionadores? 31
2ª Fase - Onde Estamos Agora? e 3ª Fase - Onde Queremos Chegar? 32
4ª Fase - O Que Deve Ser Feito? 34
5ª Fase - Como Chegamos Lá? 35
6ª Fase - Já Chegamos Lá? e 7ª Fase - Como Mantemos Essa Dinâmica? 37
Capítulo 5 Habilitando a Mudança 39
A Necessidade de Habilitação para a Mudança 39
Habilitação da Mudança da Implementação da GEIT 40
As Fases do Ciclo de Vida de Habilitação da Mudança Criam o Ambiente Adequado 40
1ª Fase - Estabelecendo o Desejo de Mudança 41
2ª Fase - Formar uma Equipe de Implementação Efetiva 41
3ª Fase - Comunicar a Visão Desejada 41
4ª Fase - Capacitar Especialistas e Identificar Resultados Rápidos 41
5ª Fase - Facilitar a Operação e o Uso 42
6ª Fase - Incorporar Novas Abordagens 42
7ª Fase - Manter 42
Capítulo 6 Atividades, papéis e responsabilidades do clico de vida da implementação 43
Introdução 43
1ª Fase - Quais São os Direcionadores? 43
2ª Fase - Onde Estamos Agora? 46
3ª Fase - Onde Queremos Chegar? 49
4ª Fase - O Que Necessita Ser Feito? 52
5ª Fase - Como Chegamos lá? 55
6ª Fase -Já Chegamos Lá? 58
7ª Fase - Como Mantemos a Dinâmica? 60
Capítulo 7 Uso os Componentes do Cobit 5 63

Personal Copy of: Mr. Jorge Diab Maluf Filho

Considerações sobre Transição para Usuários do COBIT 4.1, Val IT e Risk IT 63
Planejamento e Escopo 65
Controle de Desempenho 66
Práticas e Atividades de Governança e Gestão 66
Papéis e Responsabilidades 66
Apêndice A Mapeamento de Dificuldades (Pain Points) em Processos do Cobit 5 67
Apêndice B Exemplo de Matriz de Decisão 69
Apêndice C Mapeamento de Exemplos de Cenários de Risco em Processos do Cobit 5 73
Apêndice D Exemplo de Caso de negócio 79
Sumário Executivo 79
Referência (Ver Capítulo 2. Posicionamento GEIT) 80
Desafios de Negócio (Ver Capítulo 3. Primeiros Passos - Identificar a Necessidade de Agir: Reconhecer Pontos Fracos e Eventos Desencadeadores) 80
Análise de Lacunas (Gap) e Objetivos 81
Alternativas Consideradas 81
Solução Proposta 81
1ª Fase. Pré-planejamento (Ver Capítulo 3. Primeiros Passos em Direção a GEIT) 81
2ª Fase. Implementação do Programa (Ver Capítulo 3. Aplicação da Abordagem do Ciclo de Vida de Melhoria Contínua) 82
Escopo do Programa 82
Metodologia e Alinhamento do Programa (Ver Capítulo 6. Tarefas, papéis e Responsabilidades do Ciclo de Vida da Implementação) 82
Entregáveis do Programa (Ver Capítulo 6. Tarefas, Papéis e Responsabilidades do Ciclo de Vida da Implementação) 82
Riscos do Programa (Ver Capítulo 5. Capacitação da Mudança) 83
Participantes (Ver Capítulo 3. Reconhecimento das Papéis e Responsabilidades dos Participantes) 83
Análise de Custo-Benefício 83
Desafios e Fatores de Sucesso (Ver Capítulo 4. Identificação dos Desafios e Fatores de Sucesso da Implementação) 84
Apêndice E Tabela de Atributos de Maturidade do COBIT 4 87

Personal Copy of: Mr. Jorge Diab Maluf Filho

LISTA DE FIGURAS

Figura 1 - Família de Produtos COBIT 5 13
Figura 2- Princípios do COBIT 5 19
Figura 3 - Papéis na Criação do Ambiente Adequado 22
Figura 4 - Tabela RACI de Criação do Ambiente Adequado 22
Figura 5 - Componentes do Ciclo de Vida 23
Figura 6 - 7 Fases de Implementação do Ciclo de Vida 23
Figura 7 - Visão Geral das Partes Interessadas Internas de GEIT 28
Figura 8 - Exemplos de Participantes Externos GEIT 30
Figura 9 - 1ª Fase - Quais São os Direcionadores? 31
Figura 10 - 2ª Fase - Onde Estamos Agora? e 3ª Fase - Onde Queremos Chegar? 33
Figura 11 - 4ª Fase - O Que Deve Ser Feito? 34
Figura 12 - 5ª Fase - Como Chegamos Lá? 35
Figura 13 - 6ª Fase - Já Chegamos Lá? e 7ª Fase - Como Mantemos Essa Dinâmica? 37
Figura 14 - 7 Fases do Ciclo de Vida da Implementação 40
Figura 15 - Fase 1 do da Melhoria Continua do Ciclo de Vida 43
Figura 16 - Papéis na 1ª Fase 44
Figura 17 - Descrição da 1ª Fase 44
Figura 18 - Tabela RACI da 1ª Fase 45
Figura 19 - 2ª Fase do Ciclo de Vida de Melhoria Contínua 46
Figura 20 - Papéis na 2ª Fase 46
Figura 21 - Descrição da 2ª Fase 46
Figura 22 - Tabela RACI da 2ª Fase 49
Figura 23 - 3ª Fase do Ciclo de Vida de Melhoria Contínua 49
Figura 24 - Papéis na 3ª Fase 49
Figura 25 - Descrição da 3ª Fase 50
Figura 26 - Tabela RACI da Fase 3 52
Figura 27 - 4ª Fase do Ciclo de Vida 52
Figura 28 - Papéis na 1ª Fase 53
Figura 29 - Descrição da 4ª Fase 53
Figura 30 - Tabela RACI da 4ª Fase 55
Figura 31 - 5ª Fase do Ciclo de Vida de Melhoria Contínua 55
Figura 32 – Papéis da Fase 5ª 56
Figura 33 - Descrição da 5ª Fase 56
Figura 34 - Tabela RACI da 5ª Fase 57
Figura 35 - 6ª Fase do Ciclo de Vida de Melhoria Contínua 58
Figura 36 - Papéis na 6ª Fase 58
Figura 37 - Descrição da 5ª Fase 59
Figura 38 - Tabela RACI da 6ª Fase 60
Figura 39 - 7ª Fase do Ciclo de Vida de Melhoria Contínua 60
Figura 40 – Papéis da Fase 7ª 61
Figura 41 - Descrição da 7ª Fase 61
Figura 42 – Tabela RACI da 7ª Fase 62
Figura 43 - Princípios do COBIT 5 63
Figura 44 - Modelo de Referência de Processo do COBIT 5 67
Figura 45 – Mapeamento de Dificuldades em Processos do COBIT 5 68
Figura 46 - Exemplo de Matriz de Decisão 69
Figura 47 - Cenários de Risco e Capacidades de Processo do COBIT 5 73
Figura 48 – Desafios e Ações Planejadas da Acme Corporation 84
Figura 49 – Tabela de Maturidade do COBIT 4.1 87

Personal Copy of: Mr. Jorge Diab Maluf Filho

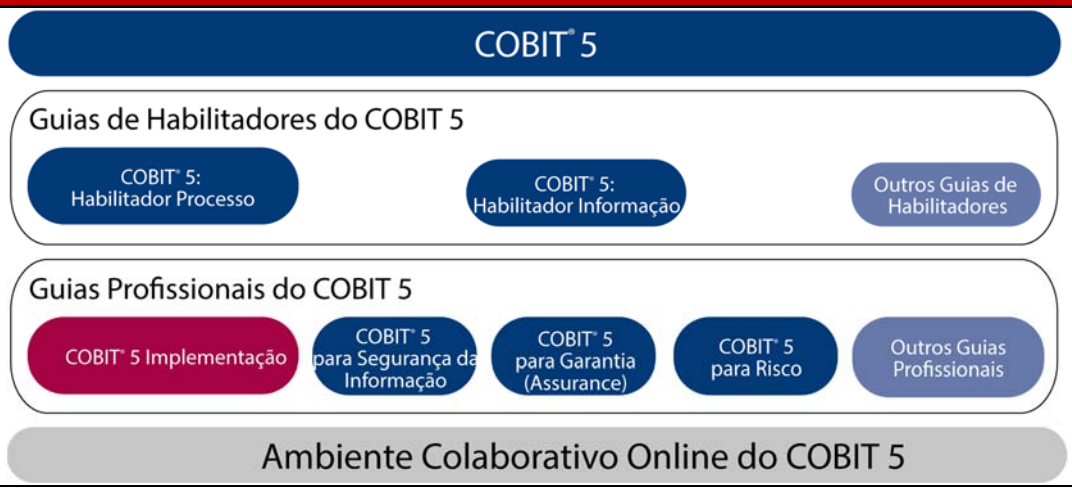
Página deixada intencionalmente em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

CAPÍTULO 1
INTRODUÇÃO

O COBIT 5 Implementação complementa o COBIT 5 (**figura 1**). O objetivo deste guia de referência é fornecer uma abordagem de boas práticas para implementação da Governança Corporativa de TI (Governance of Enterprise IT - GEIT) com base em um ciclo de vida de melhoria contínua que deve ser adaptado para atender às necessidades específicas da organização.

Figura 1 - Família de Produtos COBIT 5



O modelo do COBIT 5 baseia-se em cinco princípios básicos, que são cobertos em detalhe, e inclui ampla orientação sobre os habilitadores para a Governança e Gestão Corporativa de TI.

A família de produtos COBIT 5 inclui os seguintes produtos:

- COBIT 5 (o modelo)
- Guias habilitadores do COBIT 5, onde os habilitadores de governança e gestão são discutidos em detalhe. Estes incluem:
  - COBIT 5: Habilitando Processos
  - COBIT 5: Habilitando Informações
  - Outros guias habilitadores (vide www.isaca.org/cobit)
- Guias profissionais do COBIT 5, que incluem:
  - COBIT 5 Implementação
  - COBIT 5 para Segurança da Informação
  - COBIT 5 para Garantia (Assurance)
  - COBIT 5 para Risco
  - Outros guias profissionais (vide www.isaca.org/cobit)
- Um ambiente colaborativo on-line, que estará disponível para apoiar o uso do COBIT 5

Esta publicação é estruturada da seguinte forma:

- O Capítulo 2 explica o posicionamento da GEIT dentro de uma organização
- O Capítulo 3 discute os primeiros passos para melhorar a GEIT
- O Capítulo 4 explica os desafios da implementação e fatores de sucesso
- O Capítulo 5 discute a habilitação da mudança comportamental e organizacional relacionada à GEIT
- O Capítulo 6 detalha a implementação da melhoria contínua, incluindo a habilitação para a mudança e a gestão do programa
- O Capítulo 7 discute o uso do COBIT 5 e de seus componentes
- Diversos apêndices também foram incluídos:
  - O Apêndice A apresenta os processos do COBIT 5 e mapeia dificuldades para os processos
  - O Apêndice B apresenta um exemplo de matriz de decisão
  - O Apêndice C mapeia exemplos de cenários de risco em processos do COBIT 5
  - O Apêndice D apresenta um exemplo de caso de negócio
  - O Apêndice E contém a tabela de atributos de maturidade do COBIT 4.1

A melhoria da GEIT é amplamente reconhecida pela alta administração como uma parte essencial da Governança Corporativa. Em um momento em que a importância da informação e a difusão da tecnologia da informação (TI) são uma

Personal Copy of: Mr. Jorge Diab Maluf Filho

parte cada vez maior de cada aspecto do negócio e da vida pública, a necessidade de gerar maior valor a partir dos investimentos em TI e gerenciar a crescente variedade de riscos de TI nunca foi tão grande. O aumento da regulação também está gerando uma maior conscientização entre os conselhos de administração em relação à importância de um ambiente de TI bem controlado e a necessidade de cumprimento das obrigações legais, regulamentares e contratuais

A governança corporativa da TI efetiva resultará em melhor desempenho da organização, bem como o cumprimento das exigências externas, mas o sucesso da implementação ainda permanece ilusório para muitas organizações. A governança corporativa da TI efetiva exige uma série de habilitadores com papéis, responsabilidades e obrigações que se encaixem no estilo e nas normas operacionais da organização. Isto inclui cultura e comportamento apropriados, princípios de orientação e políticas, estruturas organizacionais, processos de governança e gestão bem definidos e administrados, e informação necessária para apoiar a tomada de decisão, soluções e serviços de apoio além das habilidades apropriadas de governança e gestão.

A melhoria da Governança Corporativa de TI (GEIT) é amplamente reconhecida pela alta administração como uma parte essencial da governança corporativa.

A ISACA pesquisou durante muitos anos esta importante área da governança corporativa para aprimorar o pensamento internacional e fornecer orientações para a avaliação, direcionamento e monitoramento do uso corporativo de TI.

A ISACA desenvolveu o modelo COBIT 5 para ajudar as organizações a implementar sólidos habilitadores de governança; de fato, a implementação de uma boa GEIT é praticamente impossível sem o envolvimento de um modelo de governança eficaz. Boas práticas e padrões também estão disponíveis para sustentar o COBIT 5.

Modelos, boas práticas e padrões são úteis somente se forem adotadas e adaptadas de forma eficaz. Há desafios que devem ser superados e problemas que devem ser tratados para implementação com sucesso da governança corporativa da TI. O Conselho de Administração e os gerentes precisam aceitar maior responsabilidade pela TI, prover princípios para orientação e modelos, e incutir uma mentalidade e cultura diferentes para entregar o valor de TI.

Objetivos e Escopo do Guia

No COBIT 5 Implementação, a ênfase é sobre a visão de toda a organização em relação à governança de TI. Este guia e o COBIT 5 reconhecem que a informação e as tecnologias da informação são pervasivas nas organizações e que não é possível e nem seria uma boa prática separar os negócios das atividades relacionadas à TI. A governança e gestão corporativa de TI devem, portanto, ser executadas como parte integrante da governança corporativa, cobrindo o negócio de ponta a ponta, bem como as áreas funcionais sob responsabilidade da TI.

Este guia também é apoiado por um kit de ferramentas de implementação que contém uma variedade de recursos que serão continuamente aprimorados e disponibilizados como download para os membros da ISACA em: www.isaca.org/cobit. Seu conteúdo inclui:

- Ferramentas de autoavaliação, medição e diagnóstico
- Apresentações
- Artigos relacionados e explicações adicionais

Um dos motivos mais comuns pelo qual algumas implementações GEIT falham é que elas não são iniciadas e gerenciadas adequadamente como programas que garantam a realização dos benefícios. Programas GEIT devem ser patrocinados pela gerência executiva, adequadamente delimitados e com objetivos atingíveis definidos de modo que a organização possa absorver o ritmo da mudança conforme planejado. A gestão do programa é, então, considerada parte integrante do ciclo de vida da implementação.

Implementações GEIT devem ser gerenciadas como programas patrocinados pela gerência executiva, adequadamente delimitados e com objetivos atingíveis definidos.

Supõe-se também que, enquanto uma abordagem ao programa e ao projeto seja recomendada para conduzir eficientemente as iniciativas de melhoria, o objetivo também é estabelecer uma 'prática comum do negócio' e uma abordagem sustentável para governança e gestão corporativa de TI como qualquer outro aspecto de governança corporativa. Por estes motivos, a abordagem à implementação baseia-se no empoderamento do negócio e partes interessadas de TI para que possam assumir a responsabilidade pelas decisões e atividades relativas à governança e gestão de TI, facilitando e habilitando a mudança. O programa de implementação será encerrado quando o processo de concentração nas prioridades de TI e melhorias da governança estiverem gerando um benefício mensurável e tiver sido incorporado nas atividades rotineiras do negócio.

Este guia não pretende ser uma abordagem prescritiva, nem uma solução completa, mas sim um guia para evitar as armadilhas, difundir as boas práticas mais recentes e auxiliar na criação de resultados de sucesso de governança e gestão ao

Personal Copy of: Mr. Jorge Diab Maluf Filho

longo do tempo. Cada organização aplicará seu próprio plano ou guia de implementação específico, dependendo, obviamente, de fatores tais como seu setor e ambiente de negócios bem como de sua cultura e objetivos. Igualmente importante será o atual ponto de partida. Poucas organizações não terão modelos de GEIT ou processos em seu ambiente, ainda que não sejam atualmente reconhecidas dessa forma. Assim, a ênfase deve basear-se naquilo que a organização já adotou, especialmente aproveitando as atuais abordagens de sucesso em nível corporativo que possam ser adotadas e, se necessário, adaptadas para TI em vez de reinventar algo diferente. Além disso, as melhorias anteriores obtidas com o uso do COBIT 4.1 ou outros padrões e boas práticas não precisam ser reformuladas, mas podem, e devem basear-se no uso do COBIT 5 e neste guia atualizado como parte permanente da melhoria contínua.

Será benéfico para os usuários deste guia a familiarização com a GEIT como um tema e para a equipe de implementação obter o conhecimento especializado necessário para implementar GEIT com sucesso usando o COBIT 5. A realização de programas educacionais relacionados permitirá o entendimento adequado dos conceitos do COBIT 5, como utilizar seus componentes e como aplicar este método de implementação, bem como outras orientações correlatas fornecidas pela ISACA, inclusive avaliação da capacidade do processo e atividades de garantia baseadas no COBIT 5. O programa de Certificação em Governança Corporativa de TI (Certified in the Governance of Enterprise IT - CGEIT) da ISACA também apoia o desenvolvimento e o reconhecimento das habilidades e competência de governança de TI.

O COBIT 5 pode ser obtido livremente a partir do website: www.isaca.org/cobit. Um link para os produtos ISACA disponíveis para apoiar a implementação também foi disponibilizado nesta página.

Este guia reflete o melhor entendimento e experiências práticas das implementações GEIT, lições aprendidas ao aplicar e usar versões anteriores, bem como as atualizações feitas na orientação de GEIT da ISACA. Visto que TI é um tema em constante transformação, os usuários deste guia também devem se manter informados sobre as publicações profissionais da ISACA bem como os padrões e melhores práticas de outras organizações que possam ser lançados periodicamente para abordar os novos temas emergentes.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página intencionalmente deixada em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

CAPÍTULO 2
POSICIONANDO A GEIT

Entendimento do Contexto

A Governança Corporativa de TI (GEIT) não ocorre no vácuo. A implementação ocorre em diferentes condições e circunstâncias que são determinadas por diversos fatores nos ambientes interno e externo, tais como:

- A ética e cultura da comunidade
- Leis, políticas e regulamentos em vigor
- Padrões internacionais
- Práticas do setor
- O ambiente competitivo
- Os seguintes componentes da organização:
  - Missão, visão, objetivos e valores
  - Políticas e práticas de governança
  - Cultura e estilo de gestão
  - Modelos de papéis e responsabilidades
  - Planos de negócios e intenções estratégicas
  - Modelo operacional e nível de maturidade

A implementação da GEIT em cada organização será, portanto, diferente e o contexto precisa ser entendido e considerado no projeto do ambiente GEIT ideal, seja novo ou aperfeiçoado.

O que é a GEIT?

Os termos 'governança', 'governança corporativa' e 'GEIT' podem ter significados diferentes para muitas pessoas e organizações dependendo (entre outras coisas) do contexto organizacional, por exemplo, maturidade, setor e ambiente regulatório ou o contexto individual, por exemplo, cargo, formação e experiência. Para fornecer uma base para o resto deste guia, forneceremos explicações nesta seção, mas deve-se reconhecer que haverá pontos de vista diferentes. A melhor abordagem é basear-se em e aprimorar as atuais abordagens de modo a incluir TI em vez de desenvolver uma nova abordagem apenas para TI.

'Governança' é derivada do verbo grego kubernáo que significa 'orientar'. Um sistema de governança permite que diversos participantes de uma organização tenham uma opinião organizada na avaliação das condições e opções, definição da orientação e controle do desempenho em comparação com os objetivos corporativos. Definir e manter a abordagem adequada de governança é uma responsabilidade do conselho de administração ou órgão equivalente.

O COBIT 5 define a governança como:

A governança garante que as necessidades, condições e opções das partes interessadas sejam avaliadas a fim de determinar os objetivos corporativos equilibrados e consensuais a serem alcançados; define a orientação e a tomada de decisão; e monitora o desempenho e a conformidade em relação aos objetivos definidos.

GEIT não é uma disciplina isolada, mas parte integrante da governança corporativa. Embora a necessidade de governança em um nível organizacional seja orientada principalmente pela criação de valor para a parte interessada e demanda transparência e gestão eficaz do risco da organização, as oportunidades significativas, custos e riscos associados à TI requerem um dedicado, porém integrado, foco em GEIT. GEIT permite que a organização tire o máximo proveito de TI, maximize os benefícios, capitalize as oportunidades e obtenha vantagem competitiva.

Por que a GEIT é tão importante?

No mundo todo, as organizações - sejam públicas ou privadas, grandes ou pequenas - cada vez mais entendem que a informação é um recurso essencial e que TI é um ativo estratégico e importante contribuinte para o sucesso.

TI pode ser um recurso importante para ajudar as organizações a atingir seus objetivos mais importantes. Para exemplificar, TI pode representar o principal fator de redução de custos para grandes operações tais como fusões, aquisições e alienações. TI pode permitir a automação dos principais processos, tais como a cadeia de abastecimento, e pode ser o alicerce para novas estratégias de negócios ou modelos de negócios, aumentando assim a competitividade e permitindo a inovação, como, por exemplo, a entrega digital de produtos (ex: música vendida e entregue on-line). TI pode permitir maior familiaridade do cliente, por exemplo, por coleta e mineração de dados em diversos sistemas e fornecendo uma visão dos clientes em 360 graus. TI constitui a base da economia em rede atingindo quaisquer localizações geográficas e silos organizacionais para fornecer maneiras novas e inovadoras de criação de valor. A maioria das organizações reconhece a informação e o uso de TI como ativos críticos que devem ser gerenciados adequadamente.

Embora TI tenha potencial para a transformação do negócio, ela, frequentemente, representa um investimento bastante significativo. Em muitos casos, o real custo de TI não é transparente e os orçamentos são espalhados pelas unidades de negócios, funções e áreas geográficas sem supervisão geral. A maior parte das despesas é geralmente dedicada para

Personal Copy of: Mr. Jorge Diab Maluf Filho

iniciativas de 'manutenção das operações' (custos operacionais e de manutenção pós-implementação) ao contrário das iniciativas para a inovação ou transformação. Quando os recursos são gastos em iniciativas estratégicas, eles geralmente não produzem os resultados esperados. Muitas organizações ainda não conseguem demonstrar de forma concreta e palpável o valor gerado para o negócio através de investimentos relacionados a TI e estão se concentrando em GEIT como um mecanismo para tratar esta situação.

A última pesquisa sobre GEIT revelou uma série de resultados positivos de TI e de negócios decorrentes das práticas de GEIT.

Além disso, a economia em rede apresenta um espectro de risco de TI, como a indisponibilidade de sistemas de negócios voltados para o cliente, divulgação de dados de clientes ou dados confidenciais perdidos devido a uma arquitetura de TI inflexível. A necessidade de gerenciar esses e outros tipos de riscos relacionados à TI é outro direcionador para a melhoria da GEIT.

A importância da GEIT também pode ser atribuída ao complexo ambiente regulatório enfrentado pelas organizações em muitas indústrias e territórios atualmente, muitas vezes se estendendo diretamente para TI. A atenção fornecida aos relatórios financeiros tem impulsionado um importante foco correspondente sobre a importância dos controles relacionados à TI. O uso de boas práticas tais como o COBIT tem sido obrigatória em alguns países e indústrias como, por exemplo, a Banking Regulation and Supervision Agency (BRSA) da Turquia, que determinou que todos os bancos em operação na Turquia devem adotar as melhores práticas do COBIT ao gerenciar os processos de TI. O relatório sobre Governança Corporativa na África do Sul - King III - inclui, pela primeira vez em um código nacional de governança, um princípio para implementar a GEIT e recomenda a adoção de modelos tais como o COBIT. Um modelo de governança de TI pode permitir que requisitos de conformidade complexos sejam atingidos com maior eficiência e eficácia.

A última pesquisa[1] sobre GEIT realizada pela ISACA e PwC examinou as principais iniciativas de TI planejadas pelos entrevistados nos próximos 12 meses:

- 46% dos entrevistados estavam planejando grandes implementações ou atualizações dos sistemas de TI
- 45% estavam planejando iniciativas relacionadas a dados ou informações

Esses são exemplos de iniciativas que geralmente têm complexos ambientes de partes interessadas (diversas partes interessadas de diferentes unidades de negócios e TI) que reforça a necessidade de habilitadores adequados de GEIT.

Além disso, a pesquisa sobre GEIT revelou uma série de resultados positivos de TI e de negócios decorrentes das práticas de GEIT.

- 38% dos entrevistados mencionaram custos de TI mais baixos
- 27% tiveram um retorno maior sobre os investimentos em TI
- 42% dos entrevistados relataram uma melhor gestão do risco de TI
- 28% mencionaram o aumento da competitividade do negócio

A pesquisa também demonstrou que:

- Aproximadamente 47% dos entrevistados ainda pode aumentar significativamente a maturidade de sua GEIT.
- Embora apenas cerca de 5% dos entrevistados tenham indicado que não consideram a GEIT importante, 23% responderam que estão apenas começando a avaliar o que deve ser feito.
- 29% adotaram apenas algumas medidas específicas.

O que a GEIT Deve Proporcionar?

Fundamentalmente, GEIT diz respeito à criação de valor de TI para o negócio e à mitigação do risco de TI. Isso é alcançado pela disponibilidade e gestão adequada de recursos e pela medição do desempenho para monitoramento do progresso em relação aos objetivos estabelecidos.

A GEIT tem como foco os seguintes objetivos:

- **Realização dos benefícios** - Criar mais valor para a organização por meio de TI, manter e aumentar o valor derivado dos atuais investimentos em TI, e eliminar ativos e iniciativas de TI que não estão criando o valor esperado pela organização. Os princípios básicos de valor de TI são a prestação de serviços e soluções adequadas a finalidades específicas, dentro do prazo e do orçamento, e a geração de benefícios financeiros e não financeiros que foram previstos. O valor criado por TI deve estar diretamente alinhado aos valores em que o negócio estiver concentrado e medido de tal forma a mostrar com transparência os impactos e a contribuição dos investimentos habilitados por TI no processo de criação de valor da organização.
- **Otimização de riscos** -Avaliar o risco do negócio associado ao uso, responsabilidade, operação, envolvimento, influência e adoção de TI na organização. O risco do negócio relacionado à TI inclui eventos de TI que poderiam afetar o negócio.

[1] ITGI, Global Status Report on the Governance of Enterprise IT (GEIT), EUA, 2011

Personal Copy of: Mr. Jorge Diab Maluf Filho

Enquanto a entrega de valor concentra-se na criação de valor, a gestão de risco concentra-se na preservação do valor. A gestão do risco de TI deve ser integrada à abordagem de gestão de risco da organização para garantir um foco em TI pela organização e ser medida de tal forma a demonstrar com transparência os impactos e a contribuição da otimização do risco do negócio relacionado à TI na preservação do valor.

- **Otimização de recursos** - Garantir que as capacidades adequadas sejam adotadas para execução do plano estratégico e que os recursos suficientes, apropriados e eficientes sejam fornecidos. A otimização de recursos garante que uma infraestrutura de TI integrada e econômica seja fornecida, nova tecnologia seja introduzida conforme exigido pelo negócio e os sistemas obsoletos sejam atualizados ou substituídos. Também reconhece a importância das pessoas, além do hardware e software, e, portanto, concentra-se em fornecer treinamento, promovendo a retenção e garantindo a competência das pessoas chaves da TI.

Alinhamento estratégico e medição do desempenho também são importantes e aplicáveis de modo geral a todas as atividades para assegurar que os objetivos de TI estejam alinhados aos objetivos corporativos.

Potencialização do COBIT 5 e Integração de Modelos, Padrões e Boas Práticas

O Conselho de Administração deve impor a adoção e adaptação de um modelo GEIT tal como o COBIT 5 como parte integrante da governança corporativa. O modelo define a abordagem geral e posteriormente a orientação fornecida por normas específicas e boas práticas podem ser utilizadas na elaboração de políticas específicas, processos, práticas e procedimentos. Ao trabalhar dentro de uma modelo e alavancar boas práticas, os processos de governança adequados e demais habilitadores podem ser desenvolvidos e otimizados de modo que a GEIT opere eficientemente como parte da prática normal das atividades estabelecendo uma cultura de apoio demonstrada pela alta administração. O alinhamento com o COBIT deve resultar também em auditorias externas mais rápidas e eficientes visto que o COBIT é amplamente aceito como base para os procedimentos de auditoria de TI.

O Conselho de Administração deve impor a adoção de um modelo GEIT como parte integrante da governança corporativa.

O modelo e os habilitadores resultantes devem estar alinhados e em harmonia com (entre outros):

- As políticas, estratégias, planos de negócios e de governança, e abordagens de auditoria
- Um modelo de Gestão de Risco da Organização (Enterprise Risk Management - ERM)
- A organização de governança existente na organização, modelos e processos

O COBIT 5 destina-se a organizações de todos os tipos e tamanhos, inclusive de setores públicos e sem fins lucrativos, e foi projetado para entregar benefícios de negócio para as organizações, incluindo:

- Aumento na criação de valor com o uso de TI; satisfação do usuário com a participação e serviços de TI; redução do risco de TI; além de conformidade com as leis, regulamentos e exigências contratuais
- O desenvolvimento de mais soluções e serviços de TI com foco no negócio
- Maior envolvimento de toda a organização com as atividades de TI

Princípios e Habilitadores

O COBIT 5 baseia-se em cinco princípios e sete habilitadores. Os princípios que fundamentam o COBIT 5 são identificados na **figura 2**.

Figura 2- Princípios do COBIT 5



Personal Copy of: Mr. Jorge Diab Maluf Filho

Os habilitadores que devem ser considerados para ajudar a promover a realização dos objetivos do modelo organizacional e entregar valor são:

- Princípios, políticas e modelos
- Processos
- Estruturas organizacionais
- Cultura, ética e comportamento
- Informação
- Serviços, infraestrutura e aplicativos
- Pessoas, habilidades e competências

O COBIT 5 inclui processos que ajudam a orientar a criação e manutenção dos habilitadores de governança e gestão:

- EDM01 Garantir a Definição e Manutenção do Modelo de Governança (cultura, ética e comportamento; princípios, políticas e modelos; estruturas organizacionais; e processos)
- APO01 Gerenciar a Estrutura de Gestão de TI (cultura, ética e comportamento; princípios, políticas e modelos; estruturas organizacionais; e processos)
- APO03 Gerenciar Arquitetura da Organização (informação; serviços, infraestrutura e aplicativos)
- APO07 Gerenciar Recursos Humanos (pessoas, habilidades e competências)

Os processos de governança e gestão do COBIT 5 garantem que as organizações organizem suas atividades de TI de uma forma reproduzível e confiável. O modelo de referência de processo do COBIT 5, com cinco domínios e 37 processos que formam o modelo da orientação detalhada de processo do COBIT 5, é descrito de forma detalhada no COBIT® 5: Habilitando Processos.

O COBIT 5 baseia-se em uma visão corporativa e está alinhado às boas práticas de governança corporativa, permitindo que a GEIT seja implementada como parte integrante da governança corporativa mais ampla. O COBIT 5 também fornece uma base para integrar efetivamente outros modelos, padrões e práticas utilizadas, tais como Information Technology Infrastructure Library (ITIL®), The Open Group Architecture Forum (TOGAF®) e International Organization for Standardization (ISO)/International Electrotechnical Commission (IEC) 27000. Também está alinhado ao padrão de GEIT, ISO/IEC 38500:2008, que define os princípios em alto nível para a governança de TI, cobrindo a responsabilidade, estratégia, aquisição, desempenho, conformidade e comportamento humano que o corpo diretivo, como o Conselho de Administração, deve avaliar, orientar e monitorar. O COBIT 5 é um modelo único primordial que serve como uma fonte consistente e integrada de orientação com uma linguagem comum não técnica e tecnologicamente agnóstica.

Personal Copy of: Mr. Jorge Diab Maluf Filho

CAPÍTULO 3
PRIMEIROS PASSOS EM DIREÇÃO À GEIT

Criação do Ambiente Adequado

É importante a existência de um ambiente adequado ao implementar as melhorias GEIT. Isto ajuda a garantir que a iniciativa seja controlada e adequadamente orientada e apoiada pela administração. Grandes iniciativas de TI geralmente falham devido à inadequada orientação, apoio e supervisão da alta gerência. As implementações GEIT não são diferentes; elas têm maiores chances de sucesso se forem bem controladas e administradas.

A gerência executiva deve especificar e conceber os princípios de orientação, direitos de decisão e modelos de responsabilidade pela governança corporativa de TI

O apoio e orientação inadequados das partes chaves interessadas podem, por exemplo, resultar em iniciativas GEIT que irão produzir novas políticas e procedimentos sem a devida responsabilidade. Melhorias de processo provavelmente não se tornarão práticas de negócio usuais se não houver uma estrutura de gestão que atribua papéis e responsabilidades, comprometida com sua operação contínua e monitoramento das conformidades.

Portanto, um ambiente adequado deve ser criado e mantido para garantir que GEIT seja implementada como parte integrante de uma abordagem de governança corporativa. Isto deve incluir a direção e supervisão adequadas da iniciativa da implementação, incluindo os princípios de orientação. O objetivo é fornecer o compromisso, orientação e controle de atividades suficientes de modo que haja um alinhamento com os objetivos corporativos e apoio adequado à implementação por parte da diretoria e da gerência executiva.

A experiência tem mostrado que em alguns casos uma iniciativa da GEIT identifica deficiências significativas na governança corporativa. O sucesso da GEIT é muito mais difícil dentro de um ambiente de governança corporativa fraca, portanto o apoio e participação ativa da alta administração se tornam ainda mais críticos. O conselho de administração deve ter consciência da necessidade de melhorar a governança como um todo e o risco da GEIT falhar se isto não for considerado.

Independentemente de o tamanho da implementação ser grande ou pequena, a gerência executiva deve ser envolvida na orientação da criação das modelos de governança adequadas. As atividades iniciais geralmente incluem a avaliação das práticas atuais e do projeto das estruturas melhoradas. Em alguns casos, pode levar a uma reorganização da organização, bem como da função de TI e sua relação com as unidades de negócios.

A gerência executiva deve definir e manter o modelo de governança - isto significa especificar as estruturas, processos e práticas da GEIT alinhados com os princípios definidos do projeto de governança, modelos de tomada de decisão, níveis de autoridade bem como a informação necessária para a tomada de decisão informada.[2]

A gerência executiva também deve atribuir papéis e responsabilidades bem definidos para orientação do programa de melhoria da GEIT.

Uma das melhores formas de formalizar a GEIT, melhorar a supervisão executiva e do Conselho de Administração, e definir a direção das atividades de TI é a criação de um comitê executivo de estratégia de TI.

Uma das melhores formas de formalizar a GEIT e fornecer um mecanismo para orientação e supervisão das atividades de TI pela Conselho de administração é a criação de um comitê executivo estratégico de TI.[3] Este comitê atuará em nome do Conselho de Administração (a quem deve reportar) e é responsável pela forma como TI é usada dentro da organização e pela tomada de importantes decisões de TI que afetam a Organização. Ela deve ter um mandato claramente definido, e é melhor presidido por um executivo da área de negócios (preferencialmente um membro do conselho) e composto por executivos de negócios seniores que representam as principais unidades de negócios, além do Diretor de Informática (CIO) e, se necessário, outros gerentes seniores de TI. As áreas de auditoria interna e de risco devem desempenhar um papel consultivo.

Os executivos devem tomar decisões com base em diversas opiniões de gerentes, auditores e demais especialistas em TI e negócios. O Modelo do COBIT 5 facilita isto, fornecendo uma linguagem comum para os executivos comunicarem as metas, objetivos e resultados esperados.

As **figuras 3** e **4** ilustram exemplos de papéis genéricos dos principais participantes e as responsabilidades dos principais envolvidos com a implementação ao criar o ambiente adequado para sustentar a governança e garantir resultados positivos. Tabelas semelhantes são fornecidas para cada fase do ciclo de vida da implementação apresentado na próxima seção.

[2] O Apêndice B apresenta um exemplo de matriz de decisão.
[3] Muitas vezes chamado de comitê diretor de TI, conselho de TI, comitê executivo de TI ou comitê de governança de TI.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 3 - Papéis na Criação do Ambiente Adequado	
Quando você pertencer a	Sua função na criação do ambiente adequado será
Conselho e gerência executiva	Definir a orientação do programa, assegurar o alinhamento com a gestão de risco e a governança corporativa, aprovar os principais papéis do programa e definir as responsabilidades, além de oferecer apoio visível e compromisso. Patrocinar, comunicar e promover a iniciativa definida.
Gerência do negócio	Alocar participantes e líderes adequados para promover o comprometimento e apoiar o programa. Designar os principais papéis do programa bem como definir e atribuir responsabilidades.
Gerência de TI	Garantir que a área de negócios e os executivos entendam e apreciem as questões e objetivos de TI em alto nível. Designar os principais papéis do programa bem como definir e atribuir responsabilidades. Indicar uma pessoa para dirigir o programa em acordo com as áreas de negócios.
Auditoria interna	Definir o papel e o sistema de relatórios para participação da auditoria. Garantir um nível adequado de participação da auditoria seja fornecido durante a vigência do programa.
Área de risco, conformidade e jurídica	Garantir um nível adequado de participação durante a vigência do programa.

Figura 4 - Tabela RACI de Criação do Ambiente Adequado

	Responsabilidades dos Especialistas em Implementação								
Principais Atividades	Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
Definir a orientação do programa.	A	R	R	C	C	I	C	C	C
Fornecer os recursos de gestão do programa.	C	A	R	R	C	C	R	R	I
Criar e manter estruturas e processos de orientação e supervisão.	C	A	C	I	I	I	I	I	R
Criar e manter o programa.	I	A	R	C	C	I	I	I	R
Alinhar as abordagens com as da empresa.	I	A	R	C	C	I	C	C	R

A tabela **RACI** identifica quem é **R**esponsável, Prest**A** Contas, **C**onsultado e/ou **I**nformado.

Aplicação da Abordagem de Ciclo de Vida de Melhoria Contínua

Aplicar uma abordagem de ciclo de vida de melhoria contínua fornece um método para as organizações tratarem a complexidade e desafios geralmente encontrados durante a implementação da GEIT. Existem três componentes inter-relacionados ao ciclo de vida, conforme ilustrado na **figura 5**: o ciclo de vida de melhoria contínua GEIT, a capacitação da mudança (abordando os aspectos culturais e comportamentais da implementação ou melhoria) e a gestão do programa. Na **figura 5**, as iniciativas são representadas como ciclos de vida contínuos para enfatizar o fato de que não se tratam de atividades isoladas, mas parte de um processo contínuo de implementação e melhoria que com o tempo se tornam 'atividade normal', ocasião em que o programa poderá ser encerrado.

As sete fases do ciclo de vida da implementação são ilustradas na **figura 6**. O programa de implementação e melhoria é geralmente contínuo e iterativo. Durante a última fase, novos objetivos e requisitos serão identificados e um novo ciclo será iniciado.

Verificações de integridade, avaliações e auditorias em alto nível frequentemente desencadeiam a consideração de uma iniciativa da GEIT e esses resultados podem ser usados como dados de entrada para a 1ª fase.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 5 - Componentes do Ciclo de Vida

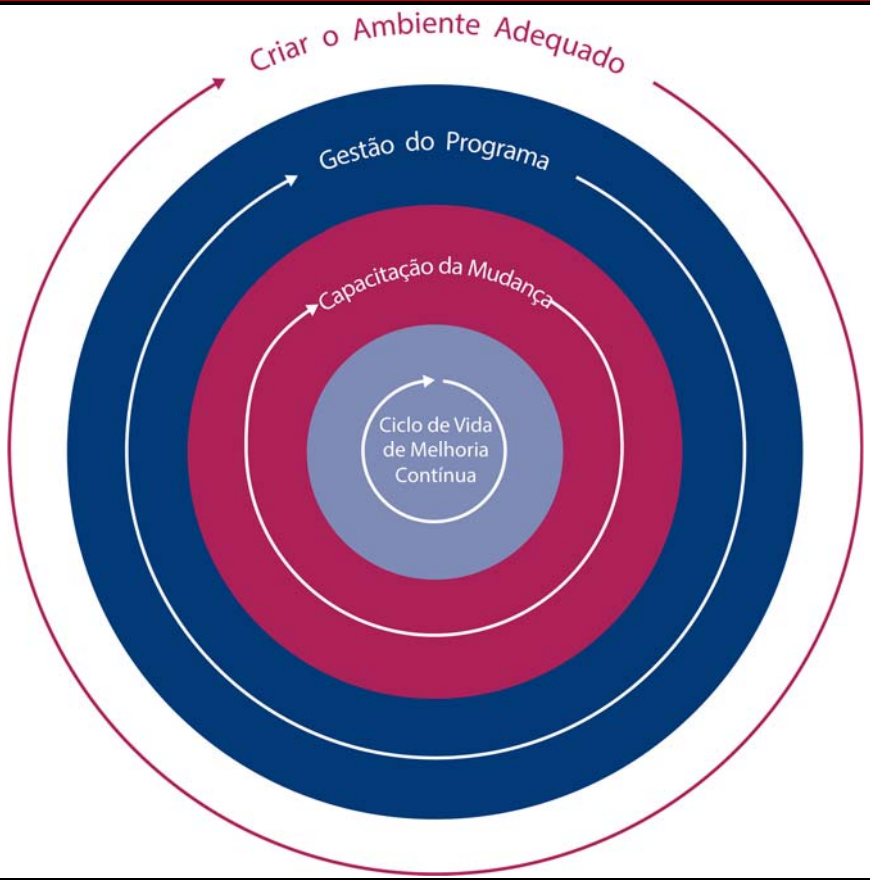
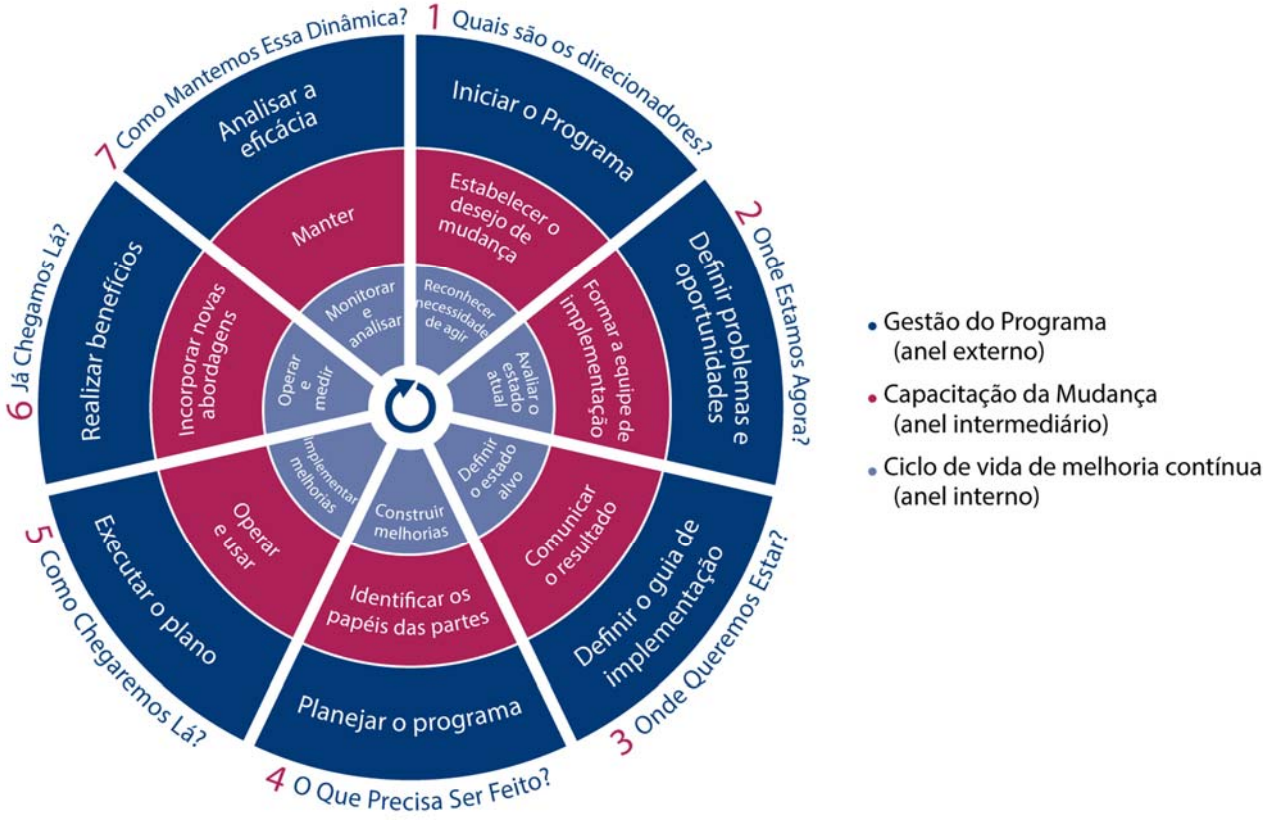


Figura 6 - 7 Fases de Implementação do Ciclo de Vida



Personal Copy of: Mr. Jorge Diab Maluf Filho

1ª Fase - Quais São os Direcionadores?
A 1ª Fase identifica os atuais indicadores da mudança e cria nos níveis de gerência executiva um desejo de mudança que é então expresso em um esboço de caso de negócio (business case). Um indicador de mudança pode ser um evento interno ou externo, condição ou questão importante que serve como um estímulo à mudança. Eventos, tendências (indústria, mercado ou técnica), deficiências no desempenho, implementações de software e até mesmo os objetivos corporativos podem agir como indicadores da mudança. O risco associado à implementação do programa será descrito no caso de negócio e controlado durante todo o ciclo de vida. A preparação, manutenção e monitoramento do caso de negócio são disciplinas fundamentais e importantes para justificar, apoiar e garantir os resultados de sucesso de qualquer iniciativa, inclusive as melhorias da GEIT. Elas garantem o foco contínuo nos benefícios do programa e na sua realização. O Apêndice D contém um exemplo de caso de negócio GEIT.

2ª Fase - Onde Estamos Agora?
A 2ª Fase alinha os objetivos de TI às estratégias e ao risco da organização e prioriza os objetivos corporativos, objetivos de TI e processos mais importantes. O COBIT 5 fornece um mapeamento genérico dos objetivos corporativos para TI relacionados com metas e processos de TI para ajudar na seleção. De acordo com os objetivos corporativos e objetivos de TI selecionados, são identificados processos críticos que devem ter capacidade suficiente para garantir resultados positivos. A administração deve conhecer sua capacidade atual e onde podem existir deficiências. Isto é alcançado através da avaliação do status atual da capacidade dos processos selecionados.

3ª Fase - Onde Queremos Chegar?
A 3ª Fase define uma meta de melhoria seguida por uma análise de falhas para identificação de possíveis soluções. Algumas soluções trarão resultados rápidos enquanto outras, mais desafiadoras, constituem tarefas de longo prazo. Prioridade deve ser dada aos projetos mais fáceis de realizar e que provavelmente trarão os melhores benefícios. Tarefas em longo prazo devem ser divididas em partes gerenciáveis.

4ª Fase - O Que Deve Ser Feito?
A 4ª Fase planeja soluções práticas e viáveis definindo projetos apoiados por estudos de caso justificáveis e desenvolvendo um plano de implementação para a mudança. Um caso de negócio bem desenvolvido ajudará a garantir que os benefícios do projeto sejam identificados e continuamente monitorados.

5ª Fase - Como Chegamos Lá?
A 5ª Fase prevê a implementação das soluções propostas em práticas diárias bem como a criação de medidas e sistemas de monitoramento para garantir que o alinhamento do negócio seja alcançado e o desempenho possa ser medido. O sucesso exige o envolvimento, conscientização e comunicação, entendimento e compromisso da alta administração, bem como o empenho dos donos dos processos de TI e de negócios.

6ª Fase - Já Chegamos Lá?
A 6ª Fase se concentra na transição sustentável das práticas melhoradas de governança e gestão em operações rotineiras do negócio e no monitoramento da consecução das melhorias com o uso das métricas de desempenho e benefícios esperados.

7ª Fase - Como Mantemos Essa Dinâmica?
A 7ª Fase analisa o sucesso global da iniciativa, identifica novos requisitos de governança e gestão e reforça a necessidade de melhoria contínua. Também prioriza novas oportunidades de aperfeiçoamento da GEIT.

O programa e o gerenciamento do projeto baseiam-se em boas práticas e prevê pontos de controle em cada uma das sete fases a fim de garantir que o desempenho do programa esteja sob controle, o caso de negócio e o risco devem ser atualizados e o planejamento da próxima fase deve ser ajustado conforme necessário. Supõe-se que a abordagem padrão da organização deva ser seguida. Mais orientações sobre a gestão do programa e do projeto podem ser encontradas no processo BAI01 do COBIT 5. Embora não sejam explicitamente mencionados em nenhuma das fases, relatórios estão incluídos em todas as fases e iterações.

O tempo gasto por fase poderá ser muito diferente dependendo (entre outros fatores) do ambiente da organização, de sua maturidade, bem como o escopo da implementação ou da iniciativa de melhoria. No entanto, o tempo total gasto em cada iteração do ciclo de vida completo ideal não deve ultrapassar seis meses, com aplicação progressiva das melhorias; caso contrário, há risco de perda da dinâmica, foco e adesão dos participantes. O objetivo é entrar em um ritmo de melhorias regulares. Iniciativas em larga escala devem ser estruturadas como múltiplas iterações do ciclo de vida.

Com o tempo, o ciclo de vida será seguido iterativamente criando assim uma abordagem sustentável. Isto se tornará uma prática comercial normal quando as fases do ciclo de vida passarem a ser atividades cotidianas e a melhoria contínua ocorrer naturalmente.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Primeiros Passos - Identificar a Necessidade de Agir: Reconhecer Dificuldades e Eventos Desencadeadores

Muitos fatores podem indicar a necessidade de práticas GEIT novas ou revisadas. No entanto é importante observar que esses sintomas podem não apenas indicar problemas subjacentes que devem ser abordados, mas também podem ser indicativos de outros problemas (ou uma combinação de fatores). Por exemplo, se o negócio tem a percepção de que os custos de TI são inaceitavelmente altos, isto pode decorrer de problemas com a governança e/ou gerenciamento (tais como critérios inadequados utilizados no processo de gestão dos investimentos em TI), mas também pode ser devido à falta anterior de investimentos em TI que agora se manifesta na necessidade de investimentos significativos.

Ao usar as dificuldades ou eventos desencadeadores como ponto de partida para iniciativas de GEIT, o caso de negócio para melhoria da GEIT pode estar relacionado aos problemas que estão sendo enfrentados, o que aumentará a adesão ao casos de negócio (business case).

Ao reconhecer as dificuldades ou eventos desencadeadores como o ponto de partida para as iniciativas GEIT, o estudo de caso (business case) da melhoria estará relacionado aos problemas que estão sendo enfrentados, o que aumentará a adesão. Um sentido de urgência, necessário para dar início à implementação, pode ser criado na organização. Além disso, resultados rápidos podem ser identificados e o valor agregado pode ser demonstrado nas áreas mais visíveis ou reconhecidas da organização. Isto provê uma plataforma para a introdução de mudanças adicionais e pode auxiliar na obtenção de amplo compromisso e apoio da alta administração para mudanças mais amplas.

Dificuldades Mais Comuns

Práticas GEIT novas ou revisadas geralmente podem resolver ou ser parte de uma solução para os seguintes sintomas:

- **Frustração do negócio com iniciativas fracassadas, aumentando os custos da TI e a percepção de baixo valor ao negócio** - Embora muitas organizações continuem aumentando seus investimentos em tecnologia da informação, o valor desses investimentos e o desempenho geral da TI são frequentemente questionados ou não realizados em sua plenitude. Isto pode indicar um problema de GEIT onde a comunicação entre as áreas de TI e de negócio deve ser aperfeiçoada e uma visão comum sobre o papel e o valor da TI deve ser estabelecida. Pode também ser uma consequência de mecanismos imprecisos de formulação, proposta e aprovação de projeto e portfólio.
- **Incidentes significativos relacionados ao risco do negócio inerente à TI, tais como perda de dados ou falha no projeto** - Esses incidentes significativos muitas vezes são a ponta do iceberg e os impactos podem ser exacerbados se receberem atenção pública e/ou da imprensa. Investigações adicionais geralmente levam à identificação de desalinhamentos estruturais e mais profundos ou até mesmo à completa falta de uma cultura de conscientização do risco de TI na organização. Práticas GEIT mais robustas são então requeridas para a obtenção de uma visão completa e um sólido entendimento do risco inerente à TI e de como este deve ser gerenciado.
- **Problemas com a entrega de serviços terceirizados, tais como o não cumprimento de forma consistente dos níveis de serviço definidos** - Problemas com a prestação de serviço por prestadores de serviços externos podem decorrer de problemas com a governança tais como a falta de definição ou inadequação da personalização dos processos de gerenciamento dos serviços de terceiros (inclusive controle e monitoramento) com as respectivas responsabilidades e obrigações para cumprimento dos requisitos de serviço de TI do negócio.
- **Falha no cumprimento das exigências regulatórias ou contratuais** - Em muitas organizações, mecanismos de governança ineficazes ou ineficientes impedem a integração completa com importantes leis, regulações e termos contratuais em sistemas organizacionais ou carecem de uma abordagem para sua gestão. Requisitos de regulações e conformidade estão aumentando cada vez mais em todo o mundo e impactam frequentemente as atividades habilitadoras de TI.
- **Limitações da TI em agregar às capacidades de inovação e agilidade de negócios da organização** - Uma queixa comum é que o papel da TI é o de prover suporte, enquanto há um requerimento para que as capacidades de inovação proporcionem vantagem competitiva. Esses são sintomas que podem indicar a falta de um alinhamento bidirecional real entre as áreas de negócios e a TI, que pode ser devido a problemas de comunicação ou ao fraco envolvimento da área de negócios na tomada de decisões de TI. Também pode ser devido ao envolvimento de TI pela área de negócios em um estágio muito avançado durante o planejamento estratégico e as iniciativas orientadas ao negócio. Este problema geralmente pode indicar que as condições econômicas exigem respostas rápidas da organização tais como o lançamento de novos produtos ou serviços.
- **Achados das auditorias regulares sobre o fraco desempenho da TI ou relatórios de problemas com a qualidade de serviços de TI** - Isto pode ser um indicativo de que os níveis de serviço não foram adotados ou não estão funcionando bem, ou do envolvimento inadequado da área de negócios na tomada de decisões de TI.
- **Gastos ocultos e não autorizados com TI** - Uma visão suficientemente transparente e abrangente dos gastos e investimentos em TI muitas vezes inexiste. Gastos com TI muitas vezes podem ser ‘escondidos’ nos orçamentos da

Personal Copy of: Mr. Jorge Diab Maluf Filho

unidade de negócios ou não classificados como despesas de TI na contabilidade, criando assim uma visão geral distorcida dos custos de TI.

- **Duplicação ou sobreposição de iniciativas ou desperdício de recursos** - Isto geralmente se deve à falta de uma visão de portfólio/holística de todas iniciativas de TI e indica que as capacidades da estrutura de processo e decisão em torno do gerenciamento de portfólio e desempenho não estão adequadas.
- **Recursos de TI insuficientes, pessoal com competências inadequadas ou pessoal com esgotamento/insatisfação**- Essas são questões importantes da gestão de recursos humanos de TI que exigem efetiva supervisão e boa governança para assegurar que a gestão de pessoas e o desenvolvimento de competências sejam abordadas efetivamente. Pode também ser um indicativo (entre outros fatores) de fragilidades subjacentes na gestão da demanda de TI e nas práticas internas de prestação de serviços.
- **Mudanças habilitadas pela TI frequentemente não cumprem as necessidades do negócio com resultados atemporais ou acima do orçado** – Essas dificuldades poderiam estar relacionadas a problemas com o alinhamento entre a TI e o negócio, a definição dos requisitos do negócio, a falta de um processo de percepção de benefícios ou ainda a implementação imprecisão de processos de gerenciamento de projeto/programa.
- **Esforços múltiplos e complexos para garantia da TI** - Isso poderia ser um indicativo da fraca coordenação entre o negócio e a TI em relação à necessidade e execução das análises de garantia de TI. Uma causa subjacente poderia ser o baixo nível de confiança em TI pelo negócio, fazendo com que a área de negócios inicie suas próprias análises, ou falta da devida prestação de contas por parte da área de negócios pelas análises de garantia de TI, fazendo com que o negócio não tenha conhecimento sobre sua ocorrência.
- **Membros do conselho, executivos ou gerentes seniores que relutam em se envolver com a TI, ou a falta de patrocinadores de TI comprometidos e satisfeitos** – Essas dificuldades frequentemente referem-se à falta de entendimento do negócio e clareza da TI, a falta de visibilidade de TI em níveis apropriados, a falta de estruturas de gerenciamento ou problemas com os mandatos do conselho, geralmente causados pela pobre comunicação entre as áreas de negócios e de TI e a incompreensão do negócio e da TI pelos patrocinadores de negócio da TI.
- **Modelos operacionais de TI complexos** - A complexidade inerente, por exemplo, em organizações de TI descentralizadas ou federadas que frequentemente possuem diferentes estruturas, práticas e políticas requer um forte foco em GEIT para garantir a tomada de decisão de TI otimizada bem como operações eficazes e eficientes. Este ponto de dor geralmente se torna mais significativo com a globalização porque cada território ou região pode ter fatores relativos a ambientes internos e externos específicos e potencialmente isolados a serem tratados.

Eventos Desencadeadores nos Ambientes Internos e Externos

Além dos sintomas descritos anteriormente, outros eventos nos ambientes internos e externos da organização, tais como os seguintes, podem sinalizar ou chamar a atenção para GEIT e posicioná-la no topo da agenda da organização:

- **Fusão, aquisição ou alienação** - As consequências estratégicas e operacionais relativas à TI podem ser significativas após uma fusão, aquisição ou alienação. Durante as diligências da auditoria haverá a necessidade de obter um entendimento das questões de TI no(s) ambiente(s). Além disso, entre todos os outros requisitos de integração ou reestruturação, haverá a necessidade de projetar os mecanismos GEIT adequados para o novo ambiente.
- **Uma mudança no mercado, posição econômica ou competitiva** - Por exemplo, uma recessão econômica poderia levar as organizações a revisar os mecanismos de GEIT para permitir a otimização de custos em larga escala ou a melhoria do desempenho.
- **Mudanças no modelo operacional do negócio ou acordos de terceirização** - Por exemplo, uma mudança de um modelo descentralizado ou federado para um modelo operacional mais centralizado exigirá mudanças nas práticas GEIT para permitir uma tomada de decisão de TI mais centralizada. Outro exemplo poderia ser a implementação de centros de serviços compartilhados para áreas tais como financeira, recursos humanos (RH) ou aquisições. Isto pode provocar impactos sobre a TI tais como a consolidação de aplicativos de TI fragmentados ou domínios de infraestrutura com as respectivas mudanças nas estruturas ou processos de tomada de decisão de TI que os regem. A terceirização de algumas funções de TI e processos de negócios podem levar, de forma semelhante, a um foco em GEIT.
- **Novos requisitos regulatórios ou de conformidade** - Para exemplificar, requisitos de geração de relatórios de governança corporativa mais amplos e regulamentações financeiras provocam a necessidade de melhorar a GEIT e o foco na privacidade da informação causados pelo caráter pervasivo da TI.
- **Mudança significativa na tecnologia ou mudança de paradigma** - Um exemplo é a migração de algumas organizações para uma arquitetura orientada a serviço (SOA) e a computação em nuvem (cloud computing). Isto muda fundamentalmente a forma que a infraestrutura e a funcionalidade do aplicativo é desenvolvida e entregue, o que também pode exigir mudanças na forma em que os processos e demais habilitadores correlatos são governados e gerenciados.
- **Um foco ou projeto de governança em toda a organização** - Esses projetos provocarão iniciativas na área GEIT.
- **Um novo Diretor de TI (CIO), Diretor Financeiro (CFO), Diretor-Executivo (CEO) ou membro do conselho** - A nomeação de novos representantes do C-level pode provocar, frequentemente, uma avaliação dos atuais mecanismos e iniciativas de GEIT para tratar eventuais áreas fracas identificadas.
- **Auditoria externa ou avaliações de consultores** - Uma avaliação feita por um terceiro independente em comparação com as práticas apropriadas normalmente pode representar o ponto de partida de uma iniciativa de melhoria de GEIT.

Personal Copy of: Mr. Jorge Diab Maluf Filho

- **Uma nova estratégia ou prioridade de negócio** - A busca de uma nova estratégia de negócios terá implicações GEIT. Por exemplo, uma estratégia de negócios de se aproximar dos clientes - ou seja, conhecer quem eles são, seus requisitos e como responder a esses requisitos da melhor maneira possível - pode requerer mais liberdade da tomada de decisão de TI para uma unidade de negócios/país em oposição à tomada de decisão centralizada em nível corporativo ou da controladora (holding).
- **Desejo de melhorar significativamente o valor a ser adicionado a partir da TI** - A necessidade de aumentar a vantagem competitiva, ser inovador, otimizar ativos ou criar novas oportunidades de negócios pode chamar a atenção para a GEIT.

A necessidade de agir deve ser reconhecida e amplamente estimulada e comunicada. Esta comunicação pode ser feita na forma deu um 'alerta' (quando as dificuldades aparecerem) ou uma expressão da oportunidade de melhoria a ser perseguida e dos benefícios que serão percebidos. Os pontos fracos atuais de dor ou os eventos desencadeadores da GEIT fornecem um ponto de partida - a identificação destes pode geralmente normalmente ser feita por meio de avaliações de alto nível de integridade, diagnósticos ou avaliações de capacidade em alto nível. Essas técnicas têm a vantagem de criar consenso sobre as questões a serem abordadas. Pode ser benéfico solicitar a um terceiro para que este realize uma revisão a fim de obter uma opinião independente e objetiva em alto nível sobre a situação atual, o que poderá aumentar a adesão à causa.

É necessário buscar o compromisso e a adesão do conselho e da gerência executiva desde o início. Para isso, o programa de GEIT e seus objetivos e benefícios, devem ser claramente expressos em termos de negócio. O nível correto de urgência deve ser incutido, e a diretoria, o conselho de administração e a gerência executiva devem ter conhecimento do valor que a TI bem governada e gerenciada pode acrescentar à organização bem como, do risco de não agir. Isto também irá assegurar que o alinhamento entre o programa de GEIT e os objetivos e estratégia corporativos, objetivos organizacionais para a TI, governança corporativa e iniciativas ERM (se houver) sejam considerados desde o início. A identificação e realização de alguns resultados rápidos (problemas visíveis que podem ser abordados de forma relativamente rápida e ajudar a estabelecer a credibilidade da iniciativa global, demonstrando seus benefícios) pode ser um mecanismo útil para a obtenção do compromisso do conselho.

Como a direção foi definida no topo, uma visão geral da capacitação da mudança deverá ser adotada em todos os níveis. A escala e escopo mais amplos da mudança devem ser entendidos primeiramente em termos de negócios, mas também a partir de uma perspectiva humana e comportamental. Todas as partes interessadas envolvidas com ou afetadas pela mudança devem ser identificadas e suas posições em relação à mudança estabelecidas. A pesquisa[4] de GEIT em 2011 demonstrou que a condução da mudança pode ser um dos maiores desafios à implementação de GEIT: 38% dos entrevistados mencionaram a gestão de gerenciamento da mudança como um desafio e 41% reportou problemas de comunicação. Um motivador-chave importante para a mudança é a identificação de incentivos para os gerentes de TI e de negócios promoverem a implementação de GEIT.

Envolvimento das partes interessadas

Há muitas partes interessadas que devem colaborar para atingir o objetivo geral de melhoria no desempenho de TI. O COBIT 5 baseia-se nas necessidades das partes interessadas e a abordagem fornecida neste guia ajudará a desenvolver um entendimento comum e bem definido sobre o que deve ser feito atingido para responder às preocupações específicas das partes interessadas de forma coordenada e harmonizada. As partes interessadas mais importantes e suas preocupações são:

- **Diretoria e gerência executiva** - Como definimos e aplicamos a orientação da organização para o uso de TI e monitorar a criação dos habilitadores de GEIT pertinentes e necessários de Governança e Gestão Corporativa de TI (GEIT) de modo a criar valor para o negócio e mitigar o risco de TI?
- **Gerência executiva de negócios, gerência de TI e responsáveis pelos processos** - Como capacitamos a organização para definir/alinhar os objetivos de TI a fim de assegurar a criação de valor ao negócio com o uso de TI, bem como, a mitigação do risco de TI?
- **Gerência de negócios, gerência de TI e responsáveis pelos processos** - Como planejamos, criamos, entregamos e monitoramos as informações, soluções de TI e a capacidade dos serviços conforme exigido pelo negócio e orientado pela diretoria?
- **Especialistas em risco, conformidade e leis** - Como nos asseguramos que estamos em conformidade com as políticas, regulamentações, leis e contratos, e que o risco foi identificado, avaliado e mitigado?
- **Auditoria interna** - Como oferecemos garantia independente sobre a entrega de valor e mitigação do risco?

Os fatores-chave para o sucesso da implementação são:

- A alta administração fornece a orientação e a ordem.
- Todas as partes entendem os objetivos corporativos e de TI.
- Existência de comunicação efetiva e habilitação das mudanças organizacionais e processuais necessárias.
- Personalização do modelo e boas práticas para atender aos propósitos e o estilo da organização.

[4] *Op cit* ITGI GEIT Status Report

Personal Copy of: Mr. Jorge Diab Maluf Filho

- O foco inicial é em resultados rápidos e na priorização das melhorias mais benéficas que são mais fáceis de implementar com o intuito de demonstrar a vantagem e criar confiança para mais melhorias.

Reconhecimento dos Papéis e Requisitos das Partes Interessadas

Partes Interessadas Internas

A **figura 7** fornece uma visão geral das partes interessadas internas, suas responsabilidades mais importantes e obrigações em alto nível mais importantes no processo de melhoria e de seus interesses nos resultados do programa de implementação. Estes são exemplos genéricos. Como tal, adaptações, ampliações e personalizações podem ser necessárias.

Figura 7 - Visão Geral das Partes Interessadas Internas de GEIT

Partes Interessadas Internas	Importantes Obrigações e Responsabilidades em Alto Nível	Interesse nos Resultados do Programa de Implementação
Diretoria e gerência executiva	Definir a orientação geral, o contexto, e objetivos do programa de melhoria e garantir o alinhamento com a estratégia de negócios, governança e gestão de risco da organização. Fornecer apoio e compromisso visíveis para a iniciativa, inclusive as os papéis de patrocínio e promoção da iniciativa. Aprovar os resultados do programa e assegurar que os benefícios esperados sejam alcançados e as medidas corretivas sejam tomadas conforme apropriado. Garantir que os recursos necessários (financeiros, humanos e outros) estejam disponíveis para a iniciativa. Definir a orientação no topo e liderar por exemplos.	A diretoria e a gerência executiva estão interessadas em obter o máximo dos benefícios para o negócio a partir do programa de implementação. Elas desejam assegurar que todas as questões e áreas importantes sejam abordadas, as atividades necessárias sejam realizadas e os resultados esperados sejam obtidos com sucesso.
Gerência de negócios e responsáveis pelos processos de negócios	Fornecer recursos de negócios aplicáveis à equipe de implementação principal. Trabalhar com TI para assegurar que os resultados do programa de melhoria estejam alinhados e apropriados ao ambiente de negócios da organização, bem como, a entrega de valor entregue e a gestão do o risco gerenciado. Apoiar visivelmente o programa de melhoria e trabalhar com TI para resolver os problemas que surgirem. Assegurar que a área de negócios seja adequadamente envolvida durante a implementação e transição para o ambiente de produção.	Estas partes interessadas gostariam que o programa resultasse em um melhor alinhamento entre TI e o ambiente geral de negócios e suas áreas específicas.
Diretor de TI (CIO)	Exercer liderança sobre o programa e fornecer os recursos de TI aplicáveis à equipe de implementação principal. Trabalhar com a gerência e executivos de negócios para definir os objetivos, orientação e abordagem adequados ao programa.	O Diretor de Informática TI deseja garantir que todos os objetivos da implementação da GEIT sejam atingidos. Para o Diretor de TI, o programa deve resultar em mecanismos que possam melhorar continuamente o relacionamento e o alinhamento com o negócio (inclusive ter uma visão compartilhada sobre desempenho de TI), conduzir a uma melhor administração gestão da oferta e demanda de TI e aperfeiçoar a gestão de risco de negócio relacionado à TI.
Gerência de TI e responsáveis pelos processos de TI, por exemplo, chefe de operações, arquiteto-chefe, gerente de segurança de TI, especialista em gestão de continuidade do negócio	Exercer liderança sobre os fluxos de trabalho do programa e recursos aplicáveis e fornecer recursos para a equipe de implementação. Fazer considerações importantes na avaliação do desempenho atual e definição das metas de melhoria para as áreas de processo com os respectivos domínios. Fornecer dados sobre boas práticas pertinentes que deveriam ser incorporadas e prestar recomendações especializadas. Garantir que o caso de negócio e o plano do programa sejam realistas e realizáveis.	Essas partes estão interessadas em garantir que a iniciativa de melhoria resulte em melhor governança geral de TI e de suas áreas individuais e que os dados das áreas de negócios necessários para isso sejam obtidos da melhor forma possível.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 7 - Visão Geral das Partes Interessadas Internas de GEIT		
Partes Interessadas Internas	Importantes Obrigações e Responsabilidades em Alto Nível	Interesse nos Resultados do Programa de Implementação
Especialistas em conformidade, gestão de risco e leis	Participar conforme necessário durante todo o programa e fornecer dados sobre os assuntos relevantes de conformidade, gestão de risco e leis. Assegurar o alinhamento com a abordagem geral ERM (se houver) e confirmar se os principais objetivos de conformidade e gestão de risco foram alcançados, se os problemas foram considerados e se os benefícios atingidos. Fornecer as orientações necessárias durante a implementação.	As partes interessadas querem garantir que a iniciativa seja adotada ou que melhore os mecanismos a fim de assegurar a conformidade legal e contratual, bem como, a efetiva gestão de risco de negócio relacionado à TI, e que estes estejam alinhados às abordagens que possam existir em toda a organização.
Auditoria interna	Participar conforme necessário durante todo o programa e fornecer opiniões e recomendações de auditoria sobre os principais problemas. Prestar recomendação em relação aos problemas vivenciados e entradas sobre as abordagens e práticas de controle. Analisar a viabilidade dos estudos de caso e os planos de implementação. Fornecer orientações quando necessárias durante a implementação. Um papel potencial também poderia ser de verificar os resultados da avaliação de forma independente.	Estas partes interessadas estão atentas aos resultados do programa de implementação no que diz respeito às abordagens e práticas de controle, e como os mecanismos adotados ou aperfeiçoados habilitarão o tratamento dos atuais apontamentos de auditoria.
Equipe de implementação (equipe combinada de negócios e de TI, formada por pessoas das categorias anteriores de participantes)	Orientar, projetar, controlar, direcionar e executar o programa de ponta a ponta a partir da identificação dos objetivos e requisitos até a eventual avaliação do programa em comparação com os objetivos do caso de negócio e a identificação de novos desencadeadores e objetivos para os novos ciclos de implementação ou melhoria adicionais. Assegurar a transferência de habilidades durante a transição desde o ambiente de implementação até os ambientes de operação, uso e manutenção.	A equipe quer garantir que todos os resultados esperados da iniciativa de GEIT sejam obtidos e maximizados.
Funcionários	Apoiar a GEIT.	As partes interessadas estão atentas aos impactos que a iniciativa terá em seu dia a dia - seus empregos, papéis, e responsabilidades e atividades.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Partes Interessadas Externas

Além das partes interessadas internas relacionados na **figura 7**, também há diversas outras partes externas. Embora essas partes não tenham nenhuma obrigação ou responsabilidade direta no programa de melhoria, elas podem ter exigências que devem ser atendidas. A **figura 8** apresenta exemplos genéricos.

Figura 8 - Exemplos de Participantes Externos GEIT

Participantes Externos	Interesse nos Resultados do Programa de Implementação
Prestadores de serviço de TI	A gestão da organização deve assegurar que haja um alinhamento e conexão entre a GEIT da organização e a governança e gestão dos serviços que eles prestam.
Reguladores	Reguladores estão interessados em saber se os resultados do programa de implementação atendem e/ou fornecem estruturas e mecanismos para satisfazer todos os requisitos regulamentares e de conformidade aplicáveis.
Acionistas (quando pertinente)	Os acionistas podem basear parcialmente suas decisões de investimentos no estado de governança corporativa organização e seu histórico nesta área.
Clientes	Os clientes podem ser afetados pelo grau em que os objetivos de GEIT forem cumpridos. Um exemplo é a gestão de risco de negócio relacionado à TI. Se uma organização for exposta no domínio de segurança, por exemplo, através da perda dos dados bancários do cliente, o cliente será afetado. O cliente tem um interesse indireto nos resultados positivos do programa de implementação.
Auditores externos	Auditores externos podem ser capazes de ter um maior nível conforto nos controles de TI em decorrência de um programa efetivo de implementação estando interessados em aspectos de conformidade regulatória e relatórios financeiros.
Parceiros comerciais, por exemplo, fornecedores	Parceiros comerciais que usam operações eletrônicas automatizadas junto à organização podem ter um interesse nos resultados do programa de implementação em relação à melhoria da integridade, segurança e conveniência da informação. Eles também podem estar interessados em conformidade regulatória e certificações de padrões internacionais que poderiam ser resultados do programa.

Avaliação Independente e o Papel dos Auditores

Os gerentes de TI e partes interessadas de TI devem ter conhecimento do papel dos profissionais de auditoria - eles podem ser auditores internos, auditores externos, auditores dos padrões ISO/IEC ou qualquer profissional contratado para fazer uma avaliação dos serviços e processos de TI. Cada vez mais, a diretoria e a gerência executiva irão buscar assessoria e opiniões independentes em relação às funções e serviços críticos de TI. Há também um aumento geral na necessidade de demonstrar a conformidade com as regulamentações nacionais e internacionais.

Personal Copy of: Mr. Jorge Diab Maluf Filho

CAPÍTULO 4
IDENTIFICAÇÃO DOS DESAFIOS E FATORES DE SUCESSO DA IMPLEMENTAÇÃO

Experiências com implementações de GEIT demonstraram que pode haver diversas questões práticas que devem ser superadas para o sucesso da iniciativa e para a sustentação da melhoria contínua. Este capítulo descreve diversos destes desafios, bem como, as possíveis causas raiz e os fatores que devem ser considerados para garantir assegurar resultados positivos.

Criação do Ambiente Adequado

1ª Fase - Quais São os Direcionadores?

A **figura 9** relaciona os desafios e suas causas raiz e fatores de sucesso na 1ª fase.

Figura 9 - 1ª Fase - Quais São os Direcionadores?	
Desafios	Falta de adesão, compromisso e apoio da alta administração Dificuldade em demonstrar o valor e benefícios
Causas raiz	▪ Falta de entendimento (e comprovação) da importância, urgência e valor da melhoria da governança da organização ▪ Entendimento pobre do escopo da GEIT e das diferenças entre governança e gestão de TI ▪ Implementação conduzida por uma reação em curto prazo a um problema em vez de uma mais ampla e proativa justificativa para a melhoria ▪ Preocupação com "mais um projeto com probabilidade de fracasso" – falta de confiança na gestão de TI ▪ Comunicação pobre das questões e benefícios da governança – benefícios e prazos não são claramente articulados ▪ Ausência de executivo sênior disposto a patrocinar ou assumir a responsabilidade ▪ Baixa percepção da credibilidade da função de TI – O Diretor de TI não impõe respeito suficiente ▪ A gerência executiva acredita que a GEIT é de responsabilidade exclusiva da gestão de TI ▪ Ausência de equipe adequada (especialistas) responsáveis pela GEIT ou falta das habilidades necessárias para assumir a tarefa ▪ Uso desinformado de modelos disponíveis/falta de treinamento e conscientização ▪ Posicionamento incorreto da GEIT no contexto da governança corporativa atual ▪ Iniciativa conduzida por entusiastas "convertidos" que pregam abordagens rígidas, exatamente como listadas nos livros
Fatores de sucesso	▪ Tornar a GEIT, item de discussão da agenda da diretoria, comitê de auditoria e comitê de risco. ▪ Criar um comitê ou alavancar um comitê já existente, como o comitê executivo de estratégia de TI, para ficar encarregado e prestar contas pela ação. ▪ Evitar fazer com que a GEIT pareça ser uma solução "a procura de um problema" - deve haver uma necessidade real e benefício potencial. ▪ Identificar líder(es) e patrocinador(es) com a autoridade, conhecimento e credibilidade para assumir a responsabilidade pelo sucesso da implementação. ▪ Identificar e comunicar pontos fracos que podem motivar um desejo de mudança do status quo. ▪ Utilizar linguagem, abordagens e comunicações apropriados ao público alvo – evitar jargões e termos que eles não reconheçam. ▪ Definir e acordar (conjuntamente com a área de negócios) sobre o valor esperado de TI. ▪ Expressar os benefícios em termos/métricas de negócio. ▪ Obter, se necessário, apoio e capacitação junto a auditores externos, consultores e/ou assessores. ▪ Desenvolver princípios de orientação que definam o tom e contexto para o esforço da transformação. ▪ Produzir imperativos com base no esforço da transformação específica para a organização, criando a confiança e a parceria necessárias para o sucesso. ▪ Produzir um caso de negócio adaptado ao público alvo que demonstre os benefícios para o negócio relativos ao investimento proposto para TI. ▪ Priorizar e alinhar o caso de negócio com base no foco estratégico e nos pontos fracos atuais da organização. ▪ Alinhar o caso de negócio aos objetivos gerais de governança corporativa. ▪ Obter formação e treinamento em questões e modelos de GEIT.
Desafios	Dificuldade na obtenção da participação necessária da área de negócios Dificuldade na identificação de participantes e especialistas
Causas raiz	▪ GEIT não é uma prioridade para os executivos de negócios (não é um indicador chave de desempenho [KPI – Key Performance Indicator]) ▪ Preferência da gestão de TI em trabalhar em isolamento – provando o conceito antes de envolver o "cliente"

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 9 - 1ª Fase - Quais São os Direcionadores?	
	▪ Obstáculos entre TI e o negócio inibem a participação. ▪ Ausência de papéis e responsabilidades bem definidas para envolvimento da área de negócios ▪ Principais executivos de negócio e formadores de opinião não envolvidos ou engajados ▪ Entendimento limitado dos benefícios e valor da GEIT pelos executivos de negócios e responsáveis pelos processos
Fatores de sucesso	▪ Incentivar a alta administração e o comitê executivo de estratégia de TI a definir as obrigações e insistir nos papéis e responsabilidades da área de negócios em relação à GEIT. ▪ Adotar um processo para envolver as partes interessadas. ▪ Explicar claramente e incutir os benefícios do negócio. ▪ Explicar o risco do não envolvimento. ▪ Identificar serviços críticos ou iniciativas importantes de TI e usá-los como pilotos/modelos para o envolvimento da área de negócios na melhoria da GEIT. ▪ Encontrar aqueles que acreditam – usuários da área de negócios que reconhecem o valor de uma melhor GEIT. ▪ Promover o pensamento livre e o empoderamento, mas somente de acordo com políticas bem definidas e uma estrutura de governança. ▪ Assegurar que os responsáveis pela mudança e sua direção obtenham o apoio do patrocinador. ▪ Criar fóruns para a participação da área de negócios - ex: comitê executivo de estratégia de TI – e realizar seminários (workshops) para discutir abertamente os atuais problemas e oportunidades para melhoria. ▪ Envolver os representantes do negócio nas avaliações de alto nível da situação atual.
Desafio	Falta de insight do negócio entre a gestão de TI
Causas raiz	▪ Liderança de TI com experiência técnica operacional – não envolvida suficientemente nas questões relativas aos negócios da organização ▪ Gestão de TI isolada dentro da organização – não envolvida em altos escalões ▪ Processo de relacionamento com o negócio fraco ▪ Herança de fraco desempenho percebido que tem levado TI e o Diretor de TI a um modo de operação defensiva ▪ Diretor de Informática e gestão de TI em uma posição vulnerável, relutantes em revelar fraquezas internas
Fatores de Sucesso	▪ Criar credibilidade baseando-se em sucessos e no desempenho de profissionais respeitados de TI. ▪ A gestão de TI deveria ser, idealmente, um membro permanente do comitê executivo a fim de assegurar que a gestão de TI tenha a compreensão organizacional adequada e seja envolvida nas novas iniciativas desde o início. ▪ Implementar um processo efetivo de relacionamento com a área de negócios. ▪ Convidar a participação e envolvimento da área de negócios. Considerar a alocação de pessoal de negócios em TI e vice-versa com o intuito de ganhar experiência e melhorar a comunicação. ▪ Se necessário, reorganizar os papéis da gestão de TI e implementar interligações formais com outras funções da organização, ex: finanças e RH. ▪ Assegurar que o Diretor de TI tenha experiência em negócios. Considerar a nomeação de um Diretor de Informática proveniente da área de negócios. ▪ Usar consultores para criar uma forte estratégia de GEIT orientada ao negócio. ▪ Criar mecanismos de governança, tais como, gerentes de relacionamento de negócio dentro de TI, para permitir uma compreensão mais ampla do negócio.
Desafios	Falta de política e orientação atuais da organização Fraca governança atual da organização
Causas Raiz	▪ Problemas de compromisso e liderança, possivelmente devidos à imaturidade organizacional ▪ Cultura atual autocrática, com base em comandos individuais em vez de uma política corporativa ▪ Promoção da cultura do pensamento livre e abordagens informais em vez de um “ambiente de controle” ▪ Fraca gestão de risco da organização
Fatores de Sucesso	▪ Levantar os problemas e preocupações junto aos executivos da diretoria, incluindo não executivos, sobre o risco da má governança, com base em problemas reais relativos à conformidade e ao desempenho da organização. ▪ Levantar os problemas junto ao comitê de auditoria ou auditoria interna. ▪ Obter informações e orientações dos auditores externos. ▪ Considerar como a cultura talvez tenha de ser modificada para permitir a melhoria das práticas de governança. ▪ Levantar a questão junto ao Diretor-Presidente e à diretoria. ▪ Garantir que a gestão de risco seja aplicada em toda a organização.

2ª Fase - Onde Estamos Agora? e 3ª Fase - Onde Queremos Chegar?

A **figura 10** relaciona os desafios e suas causas raiz e fatores de sucesso para as 2ª e 3ª Fases.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 10 - 2ª Fase - Onde Estamos Agora? e 3ª Fase - Onde Queremos Chegar?	
Desafios	Incapacidade de obter e sustentar o apoio aos objetivos de melhoria Falha de comunicação entre TI e o negócio
Causas raiz	▪ Motivos justificáveis para agir não claramente articulados ou não existentes ▪ Os benefícios percebidos não justificam suficientemente o investimento necessário (custo) ▪ Preocupação com a perda de produtividade ou eficiência devido à mudança ▪ Falta de responsabilidades bem definidas para patrocínio e compromisso com os objetivos de melhoria ▪ Falta de estruturas apropriadas com o envolvimento de negócios desde a estratégia até os níveis tático e operacional ▪ Forma inadequada de comunicação (não mantendo a simplicidade, não usando linguagem simplificada e de negócios, não compatíveis com as políticas e cultura) ou não adaptando o estilo aos diferentes públicos-alvo ▪ Caso de negócio para melhorias mal desenvolvido ou mal articulado ▪ Foco insuficiente na capacitação de mudança e na obtenção da adesão em todos os níveis necessários
Fatores de sucesso	▪ Desenvolver o entendimento consensual do valor da melhoria da GEIT da organização. ▪ Dispor das estruturas apropriadas, ex: comitê diretor de TI, comitê de auditoria, para facilitar a comunicação e aceitação dos objetivos, definir agenda de reuniões para discutir o status da estratégia, esclarecer mal-entendidos e compartilhar informações. ▪ Implementar um processo efetivo de relacionamento com a área de negócios. ▪ Desenvolver e executar uma estratégia de capacitação de mudança e um plano de comunicação que explique a necessidade de atingir um nível mais alto de maturidade. ▪ Usar a linguagem correta e terminologia comum adaptando o estilo aos subgrupos de públicos-alvo (tornar o assunto interessante, utilizar recursos visuais). ▪ Desenvolver o caso de negócio de GEIT inicial e produzir um caso de negócio detalhado para especificação das melhorias específicas, com uma clara articulação do risco. Foco no valor agregado ao negócio (expresso em termos de negócios), bem como, nos custos. ▪ Formar e treinar em COBIT 5 e neste método de implementação.
Desafios	O custo das melhorias supera os benefícios observados
Causas raiz	▪ Tendência a se concentrar exclusivamente na melhoria dos controles e do desempenho e não em melhorias de eficiência e inovação ▪ Programa de melhoria inadequadamente sequenciado e com falta de uma clara associação entre os benefícios e o custo das melhorias ▪ Priorização de soluções complexas e custosas em vez de soluções mais fáceis e de baixo custo ▪ Orçamento significativo de TI e mão de obra já comprometidos com a manutenção da infraestrutura existente, limitando assim a inclinação a dirigir fundos ou tempo da equipe dedicada a tratar da GEIT da organização
Fatores de sucesso	▪ Identificar áreas em infraestrutura, processos e RH, ex., Padronização, níveis mais altos de maturidade e menos incidentes, onde a eficiência e economia de custos diretos podem ser feitas por uma melhor governança. ▪ Priorizar com base no benefício e na facilidade de implementação, especialmente resultados rápidos.
Desafios	Falta de confiança e bons relacionamentos entre TI e a organização
Causas raiz	▪ Problemas antigos sustentados por um fraco histórico de TI em relação à entrega de projetos e serviços ▪ Falta de entendimento por TI dos problemas com o negócio e vice-versa ▪ Escopo e expectativas mal articulados e administrados ▪ Papéis, responsabilidades e obrigações por prestar contas de governança pouco claras em relação ao negócio, causando abdicação das decisões principais ▪ Falta de informações de apoio e métricas para ilustrar a necessidade de melhoria ▪ Relutância em perder uma argumentação, resistência geral à mudança
Fatores de sucesso	▪ Fomentar a comunicação aberta e transparente sobre o desempenho, como conexões com a gestão do desempenho corporativo. ▪ Focar nas interfaces do negócio e mentalidade de serviço. ▪ Publicar os resultados positivos e as lições aprendidas para ajudar a estabelecer e manter a credibilidade. ▪ Garantir que o Diretor de TI tenha credibilidade e liderança para criar confiança e relacionamentos. ▪ Formalizar os papéis e responsabilidades da governança nos negócios de modo que as obrigações de prestar contas pelas decisões sejam claras. ▪ Identificar e comunicar evidências de problemas reais, riscos que devem ser evitados e benefícios a serem obtidos (em termos de negócios) em relação às melhorias propostas. ▪ Focar no planejamento de capacitação da mudança.

Personal Copy of: Mr. Jorge Diab Maluf Filho

4ª Fase - O Que Deve Ser Feito?

A **figura 11** relaciona os desafios e suas causas raiz e fatores de sucesso na 4ª fase.

Figura 11 - 4ª Fase - O Que Deve Ser Feito?	
Desafios	Incapacidade de entender o ambiente
Causas raiz	▪ Consideração insuficiente das mudanças culturais, percepções das partes interessadas e mudanças organizacionais necessárias ▪ Consideração insuficiente dos pontos fortes atuais e práticas de governança de TI e da organização como um todo
Fatores de sucesso	▪ Fazer uma avaliação das partes interessadas e concentrar-se em um plano de capacitação da mudança. ▪ Basear-se em e usar os atuais pontos fortes e boas práticas de TI e da organização como um todo. Evitar "reinventar a roda" apenas para TI. ▪ Entender os diferentes públicos, seus objetivos e modo de pensar
Desafios	Diversos níveis de complexidade (técnico, organizacional, modelo operacional)
Causas raiz	▪ Fraco entendimento das práticas de GEIT ▪ Tentativa de implementar muita coisa de uma só vez ▪ Priorização de melhorias críticas e difíceis com pouca experiência prática ▪ Modelos operacionais complexos e/ou múltiplos modelos operacionais
Fatores de sucesso	▪ Formar e treinar em COBIT 5 e neste método de implementação. ▪ Dividir em projetos menores, dando um passo de cada vez, e priorizar resultados rápidos. ▪ Levantar as necessidades de melhoria dos diversos públicos, correlacioná-las, priorizá-las, e mapeá-las no programa de capacitação de mudança. ▪ Concentrar-se nas prioridades do negócio ao fasear a implementação.
Desafios	Dificuldade de entendimento do COBIT 5 e modelos, procedimentos e práticas correlatas
Causas raiz	▪ Habilidades e conhecimento inadequados ▪ Copiar as melhores práticas, sem adaptá-las ▪ Focar somente nos procedimentos e não nos demais habilitadores tais como, nos papéis e responsabilidades bem como nas habilidades aplicadas
Fatores de sucesso	▪ Formar e treinar em COBIT 5, outros padrões e melhores práticas correlatas, bem como neste método de implementação. ▪ Se necessário, obter orientação e suporte externos qualificados e experientes. ▪ Adaptar e personalizar as melhores práticas para adequá-las ao ambiente corporativo. ▪ Considerar e tratar as habilidades, papéis e responsabilidades, responsabilidade pelos processos, metas e objetivos, bem como, os demais facilitadores habilitadores necessários ao elaborar os processos
Desafios	Resistência à mudança
Causas raiz	Resistência é uma resposta comportamental natural quando o status quo é ameaçado, mas também pode indicar uma preocupação subjacente como, por exemplo: ▪ Incompreensão do que é necessário e do por que é útil ▪ Percepção de que a carga de trabalho e o custo aumentarão ▪ Relutância em admitir deficiências ▪ Síndrome de "não foi inventado aqui", sustentada por modelos de governança genéricas forçadas para implementação na Organização ▪ Pensamento arraigado/ameaça aos papéis à função ou base de poder
Fatores de sucesso	▪ Concentrar as comunicações de conscientização em pontos fracos e direcionadores específicos. ▪ Aumentar a consciência, treinando os gerentes e participantes das áreas de TI e de negócios. ▪ Usar um agente de mudança experiente com habilidades em TI e em negócios. ▪ Acompanhar os marcos regulares, com o uso de metas regulares, para garantir que os benefícios da implementação sejam percebidos pelas partes envolvidas. ▪ Buscar resultados rápidos e que podem ser obtidos com mais facilidade como fomentadores para os valores criados. ▪ Tornar modelos genéricos tais como o COBIT 5 relevantes para o contexto da organização. ▪ Focar no planejamento da capacitação da mudança, como por exemplo: – Desenvolvimento – Treinamento

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 11 - 4ª Fase - O Que Deve Ser Feito?	
	– Instrução – Orientação – Transferência de habilidades ▪ Organizar viagens de exposição itinerantes e encontrar líderes para promover os benefícios.
Desafios	Falha na adoção das melhorias
Causas raiz	▪ Especialistas externos projetando soluções isoladas ou impondo soluções sem a explicação adequada. ▪ Equipe de GEIT interna operando de forma isolada e agindo como um substituto informal dos verdadeiros responsáveis donos dos pelos processos, causando mal-entendidos e resistência à mudança. ▪ Apoio e orientação inadequados dos principais participantes, resultando em projetos de GEIT que produzem novas políticas e procedimentos que não têm um responsável válido
Fatores de sucesso	▪ Envolver os responsáveis pelo processo e os demais participantes durante o projeto. ▪ Usar pilotos e programas demonstrativos (demos), se for o caso, para treinar e obter adesão e apoio. ▪ Começar com resultados rápidos, demonstrar os benefícios e evoluir a partir dali. ▪ Procurar líderes que desejam melhorar, em vez ao invés de forçar as pessoas resistentes. ▪ Incentivar uma estrutura de gestão que atribua papéis e responsabilidades, seja comprometida com sua operação contínua e monitore a conformidade. ▪ Forçar a transferência de conhecimento dos especialistas externos para os responsáveis pelos processos. ▪ Delegar responsabilidade e dar poder aos responsáveis pelos donos dos processos.
Desafios	Dificuldade de integrar a abordagem de governança interna com os modelos de governança dos parceiros terceirizados
Causas raiz	▪ Receio em revelar práticas inadequadas ▪ Falha em definir e/ou compartilhar os requisitos de GEIT com o prestador terceirizado ▪ Divisão pouco clara dos papéis e responsabilidades ▪ Diferenças na abordagem e expectativas
Fatores de sucesso	▪ Envolver fornecedores/terceiros na implementação e atividades operacionais, se for o caso. ▪ Incorporar as condições e o direito de auditoria nos contratos. ▪ Procurar formas de integrar estruturas e abordagens. ▪ Atribuir papéis, responsabilidades e estruturas de governança junto aos terceiros, logo no início, e não como uma reflexão tardia. ▪ Evidenciar a correspondência (através de auditoria e análise de documentos) dos processos do prestador de serviço, pessoas e tecnologia com as práticas e níveis de GEIT requeridos.

5ª Fase - Como Chegamos Lá?

A **figura 12** relaciona os desafios e suas causas raiz e fatores de sucesso na 5ª fase.

Figura 12 - 5ª Fase - Como Chegamos Lá?	
Desafios	Falha na realização dos compromissos de implementação
Causas raiz	▪ Objetivos excessivamente otimistas, subestimação dos esforços necessários ▪ TI no modo "apagar incêndio", somente reativo aos problemas e com foco em questões operacionais ▪ Falta de recursos ou capacidade dedicados ▪ Prioridades alocadas incorretamente ▪ Escopo não alinhado aos requisitos ou mal interpretado pelos implementadores ▪ Princípios de gestão do programa, por exemplo, caso de negócio, mal aplicados ▪ Conhecimento insuficiente do ambiente de negócios, por exemplo, do modelo operacional
Fatores de sucesso	▪ Gerenciar as expectativas. ▪ Seguir os princípios de orientação. ▪ Manter a simplicidade, o realismo e a praticidade. ▪ Dividir o projeto geral em projetos menores e atingíveis, gerando experiência e benefícios. ▪ Garantir que o escopo da implementação sustente os requisitos e todos os participantes tenham o mesmo entendimento daquilo que o escopo abrangerá. ▪ Concentrar-se nas implementações que agreguem valor ao negócio. ▪ Assegurar que os recursos dedicados sejam alocados. ▪ Aplicar a gestão do programa e os princípios de governança.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 12 - 5ª Fase - Como Chegamos Lá?	
	▪ Potencializar os mecanismos existentes e as formas de trabalho. ▪ Garantir a compreensão adequada sobre o ambiente de negócios.
Desafios	Tentativa de fazer muito de uma só vez; resolver problemas muito complexos e/ou difíceis
Causas raiz	▪ Falta de entendimento do escopo e do esforço (também em relação aos aspectos humanos, criando uma linguagem comum) ▪ Falta de capacidade de entendimento para absorver a mudança (muitas outras iniciativas) ▪ Falta de planejamento e gestão formais do programa; falta de criação de uma base e amadurecimento do esforço a partir dali ▪ Pressão indevida para implementação ▪ Deixar de tirar proveito dos resultados rápidos ▪ Reinventar a roda e não aproveitar a base que já está implementada ▪ Falta de percepção de cenário organizacional ▪ Falta de habilidades
Fatores de sucesso	▪ Aplicar princípios de gestão do projeto e do programa. ▪ Usar marcos. ▪ Priorizar tarefas 80/20 (80% do benefício com 20% do esforço) e tomar cuidado com a ordem correta do sequenciamento. Capitalizar os resultados rápidos ▪ Criar confiança. Ter as habilidades e experiência para manter a implementação simples e prática. ▪ Reutilizar o que já existe como base
Desafios	TI e/ou negócios no modo "apagar incêndio" e/ou não priorizando bem e incapaz de concentrar-se na governança
Causas raiz	▪ Falta de recursos ou habilidades ▪ Falta de processos internos, ineficiências internas ▪ Falta de uma forte liderança forte de TI ▪ Excesso de soluções alternativas dede contorno
Fatores de sucesso	▪ Aplicar as boas práticas de liderança. ▪ Obter o comprometimento e condução da alta administração de modo que as pessoas possam se concentrar na GEIT. ▪ Abordar as causas raiz no ambiente operacional (intervenção externa, priorização da TI pela administração). ▪ Aplicar uma disciplina mais rigorosa sobre os requisitos do negócio ou sua gestão. ▪ Usar recursos externos, quando apropriado. ▪ Obter assessoria externa.
Desafios	Falta de habilidades e competências de TI necessárias, por exemplo, entendimento da governança, gestão, negócios, processos, habilidades sociais
Causas raiz	▪ Entendimento insuficiente do COBIT e das melhores práticas de gerenciamento de TI ▪ Habilidades em gerenciamento e negócios frequentemente não são incluídas no treinamento ▪ Pessoal de TI não interessado em áreas não técnicas ▪ Pessoal do negócio não interessado em TI
Fatores de sucesso	▪ Foco no planejamento da habilitação da mudança: – Desenvolvimento – Treinamento – Instrução – Orientação – Feedback sobre o processo de recrutamento – Treinamentos cruzados

Personal Copy of: Mr. Jorge Diab Maluf Filho

6ª Fase - Já Chegamos Lá? e 7ª Fase - Como Mantemos Essa Dinâmica?

A **figura 13** relaciona os desafios e suas causas raiz e fatores de sucesso da 6ª e 7ª Fases.

Figura 13 - 6ª Fase - Já Chegamos Lá? e 7ª Fase - Como Mantemos Essa Dinâmica?	
Desafios	Falha em adotar ou aplicar as melhorias
Causas raiz	▪ Soluções muito complexas ou impraticáveis ▪ Soluções desenvolvidas de forma isolada pelos consultores ou uma equipe de especialistas ▪ Melhores práticas copiadas, mas não personalizadas para ajustar-se à operação da organização ▪ Soluções não "assumidas" pelos proprietários responsáveis pelos processos e/ou pela equipe ▪ Organização sem papéis e responsabilidades bem definidos ▪ A alta direção não está exigindo e apoiando a mudança ▪ Resistência à mudança ▪ Fraco entendimento de como aplicar os novos processos ou ferramentas desenvolvidos ▪ As habilidades e perfil não correspondem aos requisitados pela função
Fatores de sucesso	▪ Foco em resultados rápidos e projetos gerenciáveis. ▪ Implementar pequenas melhorias a fim de testar a abordagem e certificar-se de que funciona. ▪ Envolver os proprietários dos processos e as demais partes interessadas no desenvolvimento da melhoria. ▪ Certificar-se de que os papéis e responsabilidades são claras e aceitas, alterando papéis e descrições de cargo, se necessário. ▪ Direcionar a melhoria a partir da alta direção, em toda a organização. ▪ Aplicar o treinamento adequado, sempre que necessário. ▪ Desenvolver processos antes de tentar automatizar. ▪ Reorganizar, se necessário, para estabelecer uma melhor responsabilidade pelos processos. ▪ Identificar os papéis (especialmente aqueles que são fundamentais para a adoção bem sucedida) de acordo com as capacidades e características individuais. ▪ Prover formação e treinamento eficazes.
Desafios	Dificuldade em demonstrar ou comprovar os benefícios
Causas raiz	▪ Objetivos e métricas não estabelecidas ou funcionando sem eficiência ▪ Acompanhamento dos benefícios não aplicado após a implementação ▪ Perda do foco sobre os benefícios e o valor a serem obtidos ▪ Má comunicação dos resultados positivos
Fatores de sucesso	▪ Definir objetivos claros, mensuráveis e realistas (o resultado esperado da melhoria). ▪ Definir métricas de desempenho práticas (para monitorar se a melhoria está atingindo os objetivos). ▪ Produzir relatórios para demonstrar como o desempenho está sendo medido. ▪ Comunicar em termos de negócio, os resultados e benefícios que estão sendo obtidos. ▪ Implementar "ganhos rápidos" e entregar soluções em curto espaço de tempo
Desafios	Perda de interesse e dinâmica
Causas raiz	▪ Melhoria contínua não faz parte da cultura da organização ▪ A alta direção não está orientando resultados sustentáveis ▪ Recursos destinados a "apagar incêndios" e à prestação do serviço, não à melhoria ▪ Pessoal desmotivado, não consegue ver o benefício da adoção e implementação da mudança
Fatores de sucesso	▪ Garantir que a alta direção comunique e reforce regularmente a necessidade de serviços robustos e confiáveis, soluções e boa governança. Comunicar às partes interessadas, o sucesso das melhorias já alcançadas. ▪ Revisitar as partes interessadas e obter o seu apoio para "alimentar" a dinâmica. ▪ Se os recursos são escassos, crie oportunidades para implementar as melhorias como parte da rotina diária de trabalho. ▪ Foco em tarefas de melhoria regulares e gerenciáveis. ▪ Obter auxílio externo, mas continuar engajado. ▪ Alinhar os sistemas de recompensas pessoais com os processos, objetivos e métricas de melhoria de desempenho da organização.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página deixada intencionalmente em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

CAPÍTULO 5
HABILITANDO A MUDANÇA

A Necessidade de Habilitação para a Mudança

A implementação ou melhoria bem sucedida depende da implementação da mudança apropriada (as boas práticas) de forma correta. Muitas organizações focam significativamente no primeiro aspecto, mas não enfatizam suficientemente a gestão dos aspectos humanos, comportamentais e culturais da mudança e não motivam as partes interessadas em aderir à mudança. A habilitação da mudança é um dos maiores desafios da implementação da GEIT.

Não se deve presumir que as diversas partes interessadas, envolvidas ou afetadas pelos novos ou revisados arranjos de governança necessariamente aceitarão e adotarão prontamente a mudança. A possibilidade de desconhecimento e/ou resistência à mudança deve ser abordada por meio de uma abordagem estruturada e proativa. Além disso, a conscientização ideal do programa deve ser alcançada através de um plano de comunicação que defina o que será comunicado, de que forma e por quem, durante todas as fases do programa.

Ao analisar uma recente e importante iniciativa de transformação de TI, o Departamento de Assuntos de Veteranos dos EUA (VA) observou: "O principal desafio que o VA enfrentará para alcançar esta transformação será obter a aceitação e o apoio de todo o pessoal, inclusive liderança, gerentes de nível médio e pessoal de campo".[5] O VA afirmou que seu esforço não terá sucesso se tratar somente da transformação tecnológica; ele reconhece que o fator humano necessário para obter a aceitação, mudar a organização e a forma como os negócios são conduzidos são críticos para o sucesso.

Muitas organizações não enfatizam suficientemente a gestão dos aspectos humanos, comportamentais e culturais da mudança e não motivam os participantes em aderir à mudança.

O COBIT 5 define a habilitação da mudança como:

> *Um processo sistemático de garantia de que todas as partes interessadas estejam preparadas e comprometidas com as mudanças necessárias à transformação da condição atual para a condição desejada.*

As principais partes interessadas deverão ser envolvidas. Em um alto nível, a capacitação da mudança geralmente implica:

- Avaliar o impacto da mudança sobre a organização, seus funcionários e demais partes interessadas
- Estabelecer a condição futura (visão) em termos humanos/ comportamentais e as respectivas medidas que a descrevem
- Criar "planos de resposta à mudança" para administrar pro-ativamente os impactos da mudança e maximizar o compromisso durante o processo. Esses planos poderão incluir treinamento, comunicação, projeto de organização (o conteúdo do trabalho, estrutura organizacional), redesenho de processos e atualização dos sistemas de gerenciamento de desempenho.
- Medir continuamente o progresso da mudança em relação à condição futura desejada

Em termos de uma típica implementação da GEIT, o objetivo da habilitação da mudança é fazer com que as partes interessadas da organização, das áreas de TI e de negócios, por exemplo, liderem e incentivem o pessoal de todos os níveis a trabalhar de acordo com a nova forma desejada. Exemplos do comportamento desejado incluem:

- Seguir os processos definidos
- Participar das estruturas de GEIT definidas, como aprovador de mudanças ou conselho consultivo
- Aplicar os princípios de orientação, políticas, padrões, processos ou práticas definidas, tais como uma política de novos investimentos ou de segurança

Isto pode ser alcançado obtendo-se o compromisso das partes interessadas (com diligência e o devido cuidado, liderança e através de comunicação e suporte aos envolvidos na força de trabalho) e conscientizando-os dos benefícios. Se necessário, pode ser requerido reforçar a conformidade. Em outras palavras, os obstáculos humanos, comportamentais e culturais devem ser superados para criar um interesse comum em adotar, incutir a vontade de adotar e assegurar a capacidade de adotar um novo caminho. Pode ser útil recorrer aos critérios de habilitação da mudança disponíveis na organização ou, se necessário, de consultores externos para facilitar a mudança de comportamento.

[5] 5 Walters, Jonathan; 'Transforming Information Technology at the Department of Veterans Affairs', IBM Center for the Business of Government, EUA, 2009

Personal Copy of: Mr. Jorge Diab Maluf Filho

Habilitação da Mudança da Implementação da GEIT

Diversas abordagens habilitadoras da mudança foram definidas nos últimos anos e elas fornecem informações valiosas que podem ser utilizadas durante o ciclo de vida da implementação.

Obstáculos humanos, comportamentais e culturais devem ser superados para criar um interesse comum em adotar, incutir a vontade de adotar e assegurar a capacidade de adotar um novo caminho.

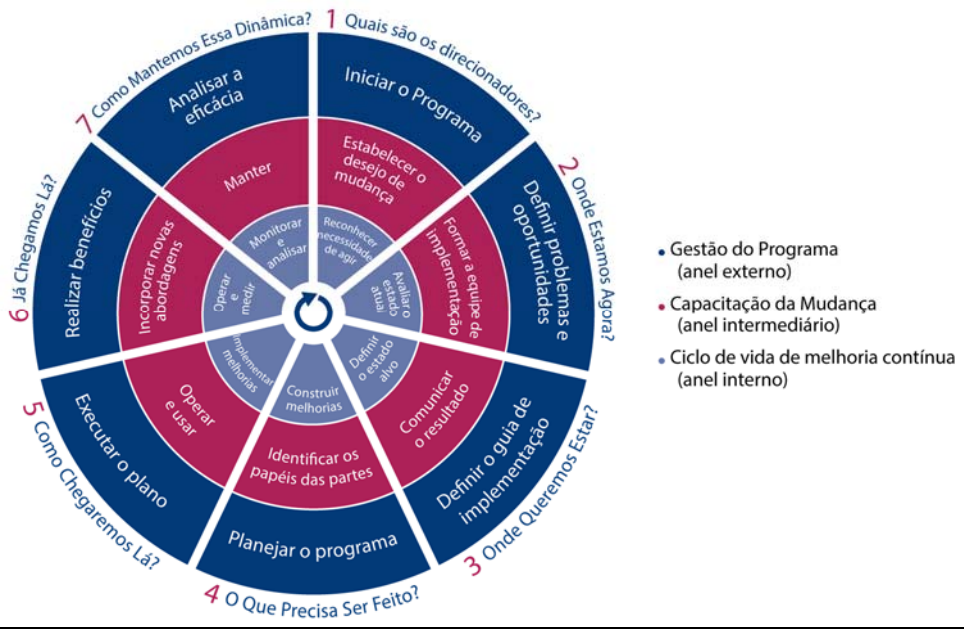
Uma das abordagens de habilitação da mudança mais amplamente aceitas foi desenvolvida por John Kotter:[6]

1. Criar um senso de urgência.
2. Formar uma poderosa coalizão para guiar.
3. Criar uma visão bem clara e expressá-la de forma simples.
4. Comunicar a visão.
5. Capacitar outras pessoas a agir com esta visão.
6. Planejar e produzir resultados rápidos.
7. Consolidar as melhorias e produzir mais mudanças.
8. Institucionalizar novas abordagens.

A abordagem de Kotter foi escolhida como um exemplo e adaptada aos requisitos específicos de uma implementação ou melhoria da GEIT. Isto é ilustrado pelo ciclo de vida de habilitação da mudança contido na **figura 14**.

As seguintes subseções criam uma visão em alto nível, porém holística, discutindo cada fase do ciclo de vida de habilitação da mudança aplicado a uma típica implementação da GEIT.

Figura 14 - 7 Fases do Ciclo de Vida da Implementação



As Fases do Ciclo de Vida de Habilitação da Mudança Criam o Ambiente Adequado

O ambiente da organização como um todo deve ser analisado para determinar a abordagem mais apropriada de habilitação da mudança. Isto incluirá aspectos tais como o estilo de gestão, cultura (formas de trabalhar), relacionamentos formais e informais, bem como atitudes. Também é importante entender as demais iniciativas da organização ou de TI em andamento ou planejadas para garantir que as dependências e impactos sejam considerados.

Deve-se assegurar desde o início que as habilidades, competências e experiência necessárias para habilitação da mudança sejam disponibilizadas e utilizadas, por exemplo, envolvendo os recursos da função de RH ou obtendo ajuda externa.

Como uma saída (resultado) desta fase, o equilíbrio adequado das atividades diretivas e inclusivas de habilitação da mudança necessárias para gerar benefícios sustentáveis pode ser projetado.

[6] Kotter, John; *Leading Change*, Harvard Business School Press, EUA, 1996

Personal Copy of: Mr. Jorge Diab Maluf Filho

1ª Fase - Estabelecendo o Desejo de Mudança

O objetivo desta fase é entender a amplitude e profundidade da mudança desejada, as diversas partes interessadas afetadas, a natureza de seu impacto e o envolvimento necessário de cada uma das partes interessadas, bem como a prontidão e capacidade atual de aceitar a mudança.

Os atuais pontos fracos e eventos desencadeadores podem fornecer uma boa base para estabelecer o desejo de mudança. O 'despertar' e uma comunicação inicial sobre o programa pode estar relacionada a problemas reais que a organização possa estar enfrentando. Além disso, os benefícios iniciais podem estar associados às áreas mais visíveis da organização, criando uma plataforma para mudanças futuras com maior compromisso e adesão.

Embora a comunicação seja o fio condutor de toda a iniciativa de implementação ou melhoria, a comunicação inicial ou divulgação inicial ou o 'despertar' é um dos mais importantes e deve demonstrar o compromisso da alta administração. Portanto, ela deve ser comunicada preferencialmente pelo comitê executivo ou pelo Diretor-Presidente.

2ª Fase - Formar uma Equipe de Implementação Efetiva

As dimensões a considerar na montagem de uma equipe de implementação eficiente incluem a participação das áreas envolvidas de TI e de negócios bem como o conhecimento e competência, experiência, credibilidade e autoridade dos membros da equipe. A obtenção de uma visão independente e objetiva, como as de participantes externos tais como consultores e de um agente da mudança, poderiam ser altamente benéficas ao auxiliar o processo de implementação ou abordar a falta de habilidades que possam existir na organização. Portanto, outra dimensão a considerar é o mescla adequada de recursos internos e externos.

A essência da equipe deve ser o compromisso com:

- Uma clara visão do sucesso e metas ambiciosas
- Extrair o melhor de cada membro da equipe, em todas as ocasiões
- Clareza e transparência nos processos, responsabilidades e comunicações da equipe
- Integridade, apoio e compromisso com o sucesso mútuo
- Responsabilidade mútua e responsabilidade coletiva
- Medição contínua de seu desempenho próprio e a maneira como ele se comporta em equipe
- Sair da sua zona de conforto, sempre buscando formas de melhorar, descobrindo novas possibilidades e aderindo à mudança

É importante identificar potenciais agentes da mudança em diferentes partes da organização que possa suportar a visão e desdobrar em mudança a níveis inferiores para a equipe principal.

3ª Fase - Comunicar a Visão Desejada

Um plano em alto nível de capacitação da mudança deve ser desenvolvido em conjunto com o plano geral do programa. Um componente importante do plano de capacitação da mudança é a estratégia de comunicação, que deve definir quem são os principais grupos de públicos, seus perfis de comportamento, informações requeridas, canais de comunicação e seus princípios.

A visão desejada do programa de implementação ou melhoria deve ser comunicada na linguagem daqueles afetados por ela. A comunicação deve conter a justificativa para a mudança e seus benefícios bem como os impactos da não implementação da mudança (propósito), a visão (panorama), o roteiro para a realização da visão (plano) e o envolvimento exigido das diversas partes interessadas (participantes).[7] A alta administração deve encarregar-se de entregar as principais mensagens (como, por exemplo, a visão desejada). Deve ser observado na comunicação que ambos os aspectos comportamental/cultural e lógico devem ser abordados, e que a ênfase está na comunicação bidirecional. Críticas, sugestões e outros comentários devem ser retidos e analisados.

4ª Fase - Capacitar Especialistas e Identificar Resultados Rápidos

Quando as principais melhorias são projetadas e criadas, os planos de resposta à mudança serão desenvolvidos a fim de capacitar os diversos especialistas. Seu escopo pode incluir:

- Mudanças no projeto organizacional tais como descrição de cargo ou estrutura das equipes
- Mudanças operacionais tais como fluxos de processo ou logística
- Mudanças na gestão de recursos humanos tais como treinamento e/ou mudanças na gestão de desempenho ou sistemas de bonificação

Todos os resultados rápidos que possam ser obtidos são importantes do ponto de vista de capacitação da mudança. Eles podem estar relacionados aos pontos fracos e eventos desencadeadores discutidos no Capítulo 3. Resultados rápidos visíveis e inequívocos podem criar força e credibilidade para o programa e ajudar a enfrentar qualquer ceticismo que possa existir.

[7] Os 'quatro Ps' (propósito, panorama, plano e participantes) foram extraídos de: Bridges, William; Managing Transitions: *Making the Most of Change*, Addison-Wesley, EUA, 1999

Personal Copy of: Mr. Jorge Diab Maluf Filho

É imperativo usar uma abordagem participativa na concepção e criação das principais melhorias. Ao envolver as pessoas afetadas pela mudança no projeto real, por exemplo, através de seminários (workshops) e sessões de análise, a adesão pode ser ampliada.

5ª Fase - Facilitar a Operação e o Uso

Quando as iniciativas são implementadas dentro do ciclo de vida principal da implementação, os planos de resposta à mudança também serão implementados. Os resultados rápidos identificados serão compreendidos como base, e os aspectos comportamentais e culturais da transição mais ampla serão abordados (questões como lidar com o medo da perda de responsabilidade, novas expectativas e tarefas desconhecidas).

É importante equilibrar as intervenções em grupo e individuais para aumentar o envolvimento a fim de garantir que todas as partes interessadas obtenham uma visão holística da mudança.

As soluções serão implementadas, e durante este processo, orientação e treinamento serão críticos para garantir a aceitação no ambiente do usuário. Os requisitos e objetivos da mudança definidos inicialmente devem ser revistos a fim garantir que foram devidamente considerados.

As medidas de sucesso devem ser definidas e ambas devem incluir medidas de negócios difíceis e medidas de percepção que acompanhem como as pessoas se sentem em relação à mudança.

As mudanças são sustentadas pelas partes interessadas que lideram por exemplo, através do reforço da conscientização e de uma campanha de comunicação contínua.

6ª Fase - Incorporar Novas Abordagens

Quando resultados sólidos são obtidos, as novas maneiras de trabalhar devem se tornar parte da cultura da organização e enraizadas em suas normas e valores (a forma como fazemos as coisas por aqui), por exemplo, implementando políticas, padrões e procedimentos. As mudanças implementadas devem ser acompanhadas, a eficácia dos planos de resposta à mudança deve ser avaliada e as medidas corretivas tomadas conforme o caso. Isto pode incluir a aplicação da conformidade onde ainda for necessário.

A estratégia de comunicação deve ser mantida para sustentar a constante conscientização.

7ª Fase - Manter

As mudanças são mantidas através do reforço da conscientização e de uma campanha de comunicação contínua, e são mantidas e demonstradas pelo constante compromisso da alta administração.

Os planos de ações corretivos são implementados, as lições aprendidas são retidas e o conhecimento é compartilhado em toda a organização.

Personal Copy of: Mr. Jorge Diab Maluf Filho

CAPÍTULO 6
ATIVIDADES, PAPÉIS E RESPONSABILIDADES DO CLICO DE VIDA DA IMPLEMENTAÇÃO

Introdução

A melhoria contínua da GEIT é alcançada com o uso das sete fases do ciclo de vida da implementação. Cada fase é descrita com:

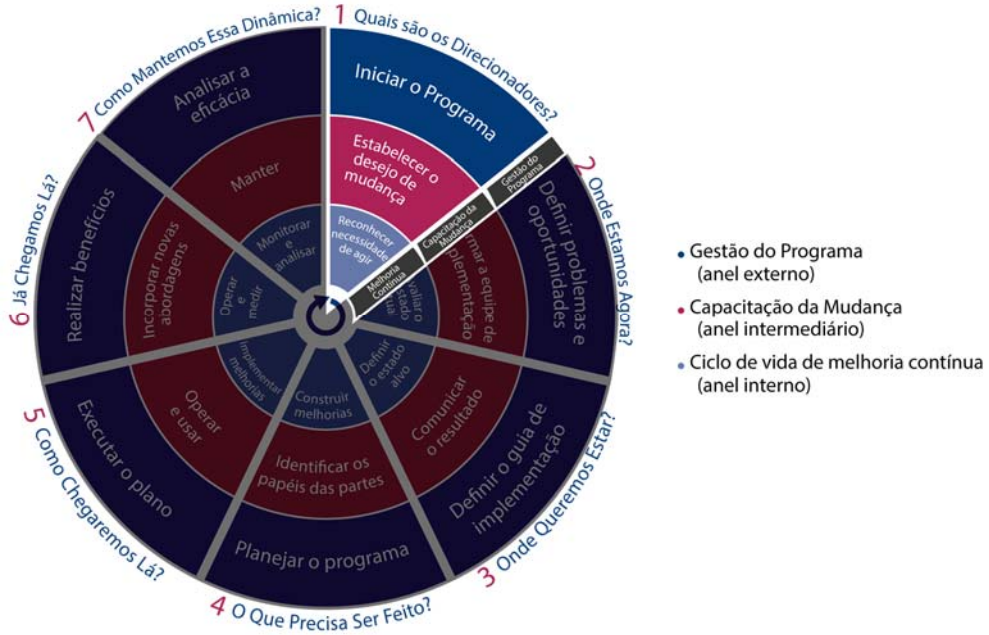
- Uma tabela que resume as responsabilidades de cada grupo de especialistas na fase. Observe que esses papéis são genéricos e cada papel não deve necessariamente existir como uma função específica.
- Uma tabela para cada fase contendo:
  - Objetivo da fase
  - Descrição da fase
  - Tarefas de melhoria contínua
  - Tarefas de capacitação de mudança
  - Tarefas de gerenciamento do programa
  - Exemplos das entradas provavelmente necessárias
  - Sugestão da ISACA e de outros modelos a serem utilizados
  - Os resultados (saídas) que devem ser produzidos
- Uma tabela RACI que descreve quem é o responsável, prestador de contas, consultado e informado pelas principais atividades selecionadas entre as tarefas de melhoria contínua (continual improvement - CI), habilitação da mudança (change enablement - CE) e gerenciamento do programa (programme management - PM), com as respectivas referências cruzadas. As atividades cobertas pela tabela RACI são as mais importantes, por exemplo, atividades que produzem resultados ou saídas para a próxima fase, que têm metas associadas a elas ou que são críticas para o sucesso da iniciativa geral. Nem todas as atividades foram incluídas, com a finalidade de manter este guia conciso.

Este guia não pretende ser prescritivo, mas sim uma fase genérica e um plano de tarefas que devem ser adaptadas a fim de atender uma implementação específica.

1ª Fase - Quais São os Direcionadores?

As **figuras 15, 16, 17** e **18** descrevem a 1ª Fase.

Figura 15 - Fase 1 do da Melhoria Continua do Ciclo de Vida



Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 16 - Papéis na 1ª Fase	
Quando você pertencer a...	Sua função nesta fase é...
Diretoria e administração	Fornecer orientação em relação às necessidades das partes interessadas, estratégia de negócios, prioridades, objetivos e princípios de orientação em relação à governança e gestão de TI da organização. Aprovar a abordagem em alto nível.
Administração do negócio	Juntamente com TI, garantir que as necessidades das partes interessadas e os objetivos corporativos sejam definidos com a clareza suficiente para permitir a interpretação em objetivos corporativos de TI, e fornecer dados para entendimento do risco e das prioridades.
Gerência de TI	Reunir os requisitos e objetivos de todas as partes interessadas, obtendo um consenso sobre a abordagem e o escopo. Fornecer recomendação e orientação em relação às questões de TI.
Auditoria interna	Fornecer recomendação e desafiar as atividades e ações propostas, garantindo assim que os objetivos e tomada de decisões são feitas de maneira equilibrada. Fornecer recomendação sobre os controles e práticas de gestão de riscos e abordagens.
Área de risco, conformidade e jurídica	Fornecer recomendação e orientação sobre o risco, conformidade e questões jurídicas. Garantir que a abordagem proposta pelos gestores é apropriada para atender o risco e cumprir os requisitos de conformidade e jurídicos.

Figura 17 - Descrição da 1ª Fase	
1ª Fase	Quais São os Direcionadores?
Objetivo da fase	Obter um entendimento do contexto e objetivos do programa e da atual abordagem de governança. Definir o caso de negócio inicial do conceito do programa. Obter a adesão e o compromisso de todas as principais partes interessadas.
Descrição da fase	Esta fase articula as justificativas para agir dentro do contexto organizacional. Neste âmbito o contexto, objetivos e a atual cultura de governança do programa são definidos. O caso de negócio inicial do conceito do programa é definido. A adesão e o compromisso de todas as principais partes interessadas são obtidos.
Tarefas de melhoria contínua (CI)	Reconhecer a necessidade de agir: 1. Identificar o atual contexto de governança, TI aplicado ao negócio e pontos fracos de TI e eventos e sintomas que desencadeiam a necessidade de agir. 2. Identificar os indicadores de governança e de negócios e os requisitos de conformidade para melhoria da GEIT e avaliar as atuais necessidades das partes interessadas. 3. Identificar as prioridades do negócio e a estratégia de negócios dependentes de TI, inclusive os projetos atuais significativos. 4. Alinhar com as políticas, estratégias e princípios orientadores da organização e quaisquer iniciativas de governança em andamento. 5. Aumentar a conscientização executiva da importância de TI e o valor da GEIT da organização. 6. Definir a política, objetivos, princípios orientadores e as metas de melhoria da GEIT em alto nível. 7. Garantir que os executivos e a diretoria entendam e aprovem a abordagem em alto nível e aceitem o risco de não tomar nenhuma ação em relação às questões importantes.
Tarefas de capacitação de mudança (CE)	Criar o desejo de mudança: 1. Garantir a integração com as abordagens ou programas corporativos globais de habilitação de mudanças, caso existam. 2. Analisar o ambiente organizacional em que a mudança deve ser habilitada, inclusive a estrutura organizacional, estilo(s) de administração, cultura, formas de trabalho, relacionamentos formais e informais, bem como atitudes. 3. Determinar outras iniciativas corporativas em andamento ou planejadas a fim de entender as dependências ou impactos da mudança. 4. Entender a amplitude e profundidade da mudança. 5. Identificar os participantes envolvidos na iniciativa das diversas áreas da organização (ex.: negócios, TI, auditoria, gestão de risco) bem como os diferentes níveis (ex.: executivos, gerentes de nível médio) e considerar suas necessidades. 6. Determinar o nível de apoio e envolvimento necessário de cada grupo de participantes ou participante individual, sua influência e o impacto da iniciativa de mudança sobre eles. 7. Determinar a prontidão e a capacidade de implementar a mudança de cada grupo de participantes ou participante individual. 8. Estabelecer a divulgação inicial, usando os pontos fracos e eventos desencadeadores como ponto de partida, e que seja comunicada pelo comitê executivo de estratégia de TI ou pelo comitê diretor (ou uma

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 17 - Descrição da 1ª Fase	
	estrutura de governança equivalente) a fim de criar conscientização sobre o programa, seus motivadores e seus objetivos entre todos os participantes. 9. Eliminar quaisquer falsos sinais de segurança ou complacência destacando, por exemplo, números relativos à conformidade ou exceções. 10. Incutir o nível adequado de urgência, dependendo da prioridade e do impacto da mudança.
Tarefas da gestão do programa (PM)	Iniciar o programa: 1. Fornecer orientação estratégica em alto nível e definir os objetivos do programa em alto nível em consenso com o comitê executivo de estratégia de TI ou equivalente (se houver). 2. Definir e atribuir os papéis e responsabilidades do programa em alto nível, desde o patrocinador executivo até o gerente do programa além de todos os participantes importantes. 3. Criar as linhas gerais do caso de negócio indicando os fatores de sucesso a serem usados para permitir o monitoramento do desempenho e a divulgação dos sucessos da melhoria na governança. 4. Obter o patrocínio executivo.
Entrada	▪ Políticas, estratégias, planos de negócios e de governança e relatórios de auditoria da organização. ▪ Outras iniciativas corporativas importantes entre as quais poderá haver dependências ou impactos. ▪ Relatórios de desempenho do comitê diretor de TI, estatísticas do help desk, pesquisas com o cliente de TI ou outros dados que indiquem os atuais problemas de TI. ▪ Quaisquer estudos de caso e histórias de sucesso úteis e relevantes sobre o setor, em www.isaca.org/cobitcasestudies ▪ Requisitos específicos do cliente, estratégias de marketing e atendimento, posição de mercado, declarações da visão e missão da organização.
Recursos da ISACA	▪ COBIT 5 (objetivos corporativos, habilitadores) ▪ COBIT 5: Habilitando Processos (EDM01, APO01 e MEA01), www.isaca.org/cobit ▪ COBIT 5 Implementação (apêndices A. Mapeamento de Pontos Fracos em Processos do COBIT 5, B. Exemplo de Matriz de Decisão e D. Exemplo de Caso de negócio) ▪ Produtos de apoio da ISACA conforme definição mais atual em www.isaca.org ▪ O Guia: Using Val IT 2.0
Saída	▪ Linhas gerais do caso de negócio ▪ O Guia: Using Val IT 2.0 ▪ Mapa de participantes identificados, inclusive o apoio e envolvimento necessários, influência e impacto, e o entendimento definido dos esforços necessários para administrar a mudança humana ▪ Divulgação inicial do programa (todos os participantes) ▪ Comunicação de início do programa (partes interessadas chaves)

Figura 18 - Tabela RACI da 1ª Fase

Principais Atividades	Responsabilidades dos Especialistas em Implementação: Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
Identificar os problemas que desencadeiam a necessidade de agir (CI1).	C/I	A	R	R	C	C	C	C	R
Identificar prioridades e estratégias de negócios que afetam TI (CI3).	C	A	R	R	C	C	C	C	R
Obter o consentimento da administração para agir e obter o patrocínio executivo (CI7).	C	A/R	R	C	I	I	I	I	R
Incutir o nível adequado de urgência da mudança (CE10).	I	A	R	R	C	C	C	C	R
Produzir um estudo de caso preliminar convincente (PM3).	I	A	R	C	C	C	C	C	R

A tabela **RACI** identifica quem é **R**esponsável, Prest**A** Contas, **C**onsultado e/ou **I**nformado.

Personal Copy of: Mr. Jorge Diab Maluf Filho

2ª Fase - Onde Estamos Agora?

As **figuras 19, 20, 21** e **22** descrevem a 2ª Fase

Figura 19 - 2ª Fase do Ciclo de Vida de Melhoria Contínua

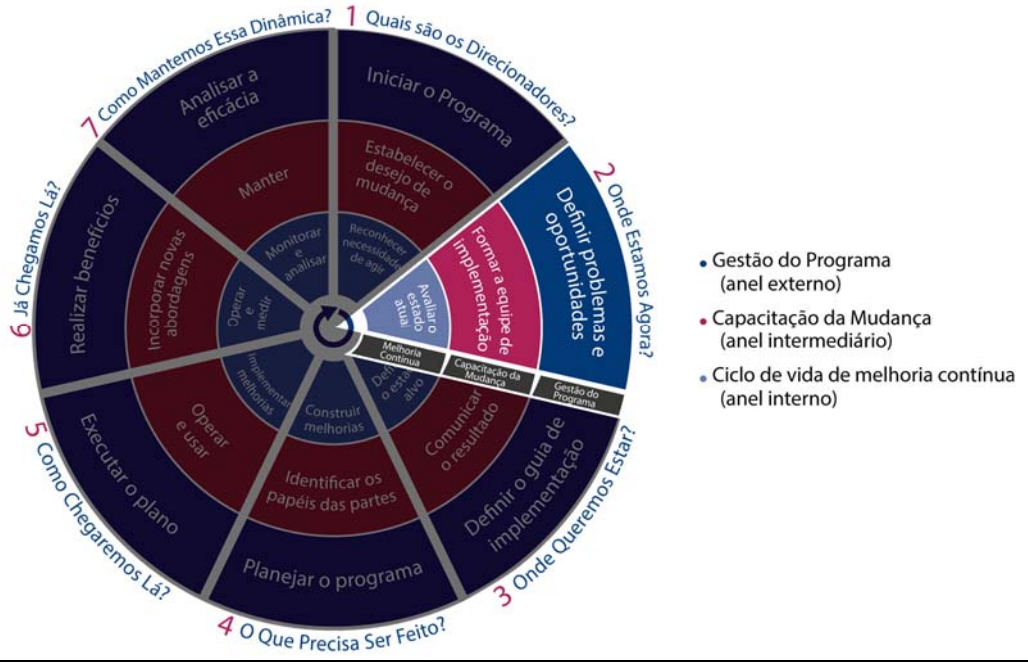


Figura 20 - Papéis na 2ª Fase	
Quando você pertencer a...	Sua função nesta fase é...
Diretoria e administração	Verificar e interpretar os resultados/conclusões das avaliações.
Administração do negócio	Auxiliar TI com ponderação das avaliações atuais fornecendo a visão do cliente.
Gerência de TI	Garantir avaliações abertas e justas das atividades de TI. Orientar a avaliação das práticas atuais. Obter consenso.
Auditoria interna	Prestar assessoria, fornecer dados e ajudar nas avaliações do estado atual. Se necessário, verificar os resultados da avaliação de forma independente.
Área de risco, conformidade e jurídica	Analisar a avaliação para garantir que o risco, conformidade e questões jurídicas tenham sido adequadamente consideradas.

Figura 21 - Descrição da 2ª Fase	
2ª Fase	Onde Estamos Agora?
Objetivo da fase	Garantir que a equipe do programa conheça e entenda os objetivos corporativos e como as funções de negócios e de TI devem criar valor a partir da TI para sustentar os objetivos corporativos, inclusive os projetos significativos em andamento. Identificar os processos críticos ou outros habilitadores a ser considerados no plano de melhoria. Identificar as práticas de gestão apropriadas para cada processo selecionado. Obter um entendimento da atitude atual e futura da organização quanto a sua posição em relação ao risco em geral e ao risco de TI e determinar como isso afetará o programa. Determinar a atual capacidade dos processos selecionados. Entender a capacidade da organização e a capacidade para a mudança.
Descrição da fase	Esta fase identifica os objetivos corporativos e de TI, ou seja, como TI contribui com os objetivos corporativos identificados através de suas soluções e serviços. O foco está na identificação e análise de como a TI cria valor para a organização habilitando a transformação do negócio de forma ágil, tornando os atuais processos de negócios mais eficientes, tornando a organização mais eficaz, e atendendo aos requisitos de governança tais como gestão de risco, garantindo a segurança e cumprindo as exigências legais e regulatórias.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 21 - Descrição da 2ª Fase	
2ª Fase	Onde Estamos Agora?
	Com base no perfil de risco da organização, seu histórico e inclinação ao risco, bem como o risco efetivo da habilitação de benefício/valor, definir o risco da habilitação do benefício/valor, risco na entrega de programas/projetos e na prestação do serviço/operações de TI para os objetivos corporativos e de TI. O Apêndice C contém uma tabela mapeando cenários de risco genéricos aos processos do COBIT 5 que podem ser usados para apoiar esta análise. O entendimento dos motivadores de negócio e governança além e uma avaliação de risco, são usados para se concentrar nos processos críticos garantindo que os objetivos de TI sejam alcançados. Então, é necessário definir o nível de maturidade, gestão e execução desses processos, com base nas descrições, políticas, padrões, procedimentos e especificações técnicas desses processos, a fim de determinar se são capazes de apoiar os requisitos de TI e do negócio. Isto é alcançado avaliando a capacidade de cada processo. A presença de pontos fracos específicos em uma organização também poderia contribuir com a seleção dos processos de TI nos quais se concentrar. O Apêndice A deste documento contém exemplos de mapeamentos de pontos fracos comuns (discutidos no Capítulo 4) em processos do COBIT 5. Há também uma ilustração de todos os 37 processos contidos no modelo de referência de processo.
Tarefas de melhoria contínua (CI)	Avaliar o estado atual: 1. Entender como TI deve apoiar os atuais objetivos da organização (o material 'cascata de objetivos do COBIT 5' contido no COBIT 5 Modelo Corporativo para a Governança e Gestão de TI da Organização e no COBIT 5: Habilitando Processos, apresenta exemplos genéricos e relacionamentos que podem ser usados): 2. Identificar os principais objetivos corporativos e de apoio, relacionados a TI. 3. Definir a importância e natureza das contribuições de TI (soluções e serviços) necessárias para sustentar os objetivos corporativos. 4. Identificar os principais problemas e pontos fracos da governança relacionados às soluções e serviços atuais e necessários no futuro, a arquitetura da organização necessária para apoiar os objetivos de TI, bem como quaisquer restrições ou limitações. 5. Identificar e selecionar os processos críticos para apoiar os objetivos de TI e, se for o caso, as principais práticas de gestão de cada processo selecionado. 6. Avaliar o risco de habilitação do benefício/valor, risco na entrega de programas/projetos e na prestação de serviço/ operações de TI relacionados aos processos críticos de TI. 7. Identificar e selecionar os processos de TI, críticos para garantir que o risco seja evitado. 8. Entender a posição de aceitação do risco definida pela administração. 9. Avaliar o desempenho real (consultar o Capítulo 7. Uso dos Componentes do COBIT 5): 10. Definir o método para realização da análise. 11. Documentar o entendimento de como o processo atual realmente trata das práticas de gestão selecionadas anteriormente. 12. Analisar o atual nível de capacidade. 13. Definir a atual classificação de capacidade do processo.
Tarefas de capacitação de mudança (CE)	Formar uma equipe eficaz de implementação: 1. Montar uma equipe principal com pessoal de TI e de negócios com conhecimento, habilidade, perfil, experiência, credibilidade e autoridade adequados para conduzir a iniciativa. Identificar a pessoa adequada (líder eficaz e digno da confiança dos participantes) para liderar esta equipe. Considerar o uso de terceiros, tais como consultores, como parte da equipe para fornecer uma visão independente e objetiva, ou para preencher quaisquer lacunas de habilidades que possam existir. 2. Identificar e administrar qualquer potencial interesses declarado que possa existir dentro da equipe para criar o nível necessário de confiança. 3. Criar o ambiente adequado para o trabalho em equipe. Isto inclui garantir que possa haver necessário envolvimento e tempo dedicado. 4. Realizar um seminário (workshop) para criar consenso (visão compartilhada) dentro da equipe e adotar uma convenção para a iniciativa de mudança. 5. Identificar agentes de mudança com os quais a equipe principal possa trabalhar usando o princípio de cadeia de patrocínio (ter patrocinadores em diversos níveis da hierarquia apoiando a visão, disseminando a ideia de benefícios rápidos, desencadeando as mudanças nos níveis inferiores, trabalhando com os resistentes e céticos que possam existir) a fim de garantir a ampla adesão dos participantes durante cada fase do ciclo de vida. 6. Documentar os pontos fortes identificados durante a avaliação do estado atual que podem ser usados como elementos positivos nas comunicações, bem como potenciais benefícios rápidos que possam ser alavancados sob a perspectiva de habilitação de mudanças.
Tarefas da gestão do programa (PM)	Definir os problemas e oportunidades: 7. Analisar e avaliar o caso de negócio preliminar, a viabilidade do programa e o potencial retorno sobre o investimento (Return on Investment - ROI).

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 21 - Descrição da 2ª Fase	
2ª Fase	Onde Estamos Agora?
	8. Atribuir papéis, responsabilidades e responsáveis pelos processos e assegurar o compromisso e apoio dos participantes afetados na definição e execução do programa. 9. Identificar os desafios e fatores de sucesso.
Entrada	▪ Caso de negócio preliminar ▪ Papéis e responsabilidades em alto nível ▪ Mapa de das partes interessadas identificadas identificados, incluindo apoio e envolvimento necessários, influência e impacto, bem como a prontidão e capacidade para implementar ou aderir à mudança ▪ Divulgação inicial do programa (toda as partes interessadas) ▪ Comunicado de início do programa (todas as partes interessadas) ▪ Planos e estratégias de TI e de negócios ▪ Descrições de processos, políticas, padrões, procedimentos e especificações técnicas de TI ▪ Entendimento da contribuição de TI e do negócio ▪ Relatórios de auditoria, política de gestão de risco, relatórios/painéis (dashboards)/scorecards índices de desempenho de TI (scorecards) ▪ Planos de continuidade do negócio (Business Continuity Plan - BCPs), análises de impacto, exigências regulatórias, arquiteturas da organização, acordos de nível de serviço (Service Level Agreement - SLAs), acordos de nível operacional (Operational Level Agreement - OLAs) ▪ Programa de investimentos e portfólios de projetos, planos de programas e projetos, metodologias de gestão de projetos, relatórios de projetos
Recursos da ISACA	▪ COBIT 5 (objetivos corporativos – escalonamento dos objetivos de TI e mapeamento das necessidades dos participantes em objetivos), www.isaca.org/cobit ▪ COBIT 5: Habilitando Processos APO01; APO02; APO05; APO12; BAI01; MEA01; MEA02; MEA03 (usados para a seleção do processo bem como para o planejamento e implementação do programa) ▪ COBIT 5 Implementação (Capítulo 5. Capacitação da Mudança e Apêndice E. COBIT 4.1 Tabela de Atributos de Maturidade) ▪ Guia de auto avaliação do COBIT 5 (publicação em elaboração) ▪ Produtos de apoio da ISACA conforme definição atual em www.isaca.org
Saída	▪ Objetivos corporativos definidos para TI e o impacto sobre TI ▪ Um entendimento consensual do risco e impactos decorrentes do não alinhamento dos objetivos de TI e falhas na execução do projeto e prestação do serviço ▪ Processos e metas selecionados ▪ Classificação da capacidade atual dos processos selecionados ▪ Posição de aceitação ao risco e perfil de risco ▪ Risco na habilitação do valor agregado, entrega do programa/projeto e avaliações de risco às operações/serviços de TI. ▪ Pontos fortes nos quais se basear ▪ Agentes da mudança em diferentes partes e em diferentes níveis da organização ▪ Equipe principal com papéis e responsabilidades atribuídas ▪ Avaliação das linhas gerais do caso de negócio ▪ Entendimento consensual dos problemas e desafios (inclusive com níveis de capacidade dos processos)

***

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 22 - Tabela RACI da 2ª Fase

Principais Atividades	Responsabilidades dos Especialistas em Implementação								
	Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
Identificar os principais objetivos de TI que apoiam os objetivos corporativos (CI1).	I	C	R	C	R	C	C	C	A
Identificar processos críticos para apoiar os objetivos corporativos e de TI (CI4).		I	R	C	R	C	C	C	A
Avaliar o risco associado ao cumprimento das metas (CI5).		I	R	C	R	R	C	R	A
Identificar processos críticos para garantir que o principal risco seja evitado (CI6).		I	R	R	R	C	C	R	A
Avaliar o desempenho atual dos processos críticos (CI1 a CI11).		I	R	C	R	R	C	C	A
Montar uma equipe principal com o pessoal de TI e de negócios (CE1).		I	R	R	C	C	C	C	A
Analisar e avaliar o estudo de caso (PM1).	I	A	R	R	C	C	C	C	R

A tabela **RACI** identifica quem é **R**esponsável, **A**provador, **C**onsultado e/ou **I**nformado.

3ª Fase - Onde Queremos Chegar?

As figuras 23, 24, 25 e 26 descrevem a 3ª Fase.

Figura 23 - 3ª Fase do Ciclo de Vida de Melhoria Contínua

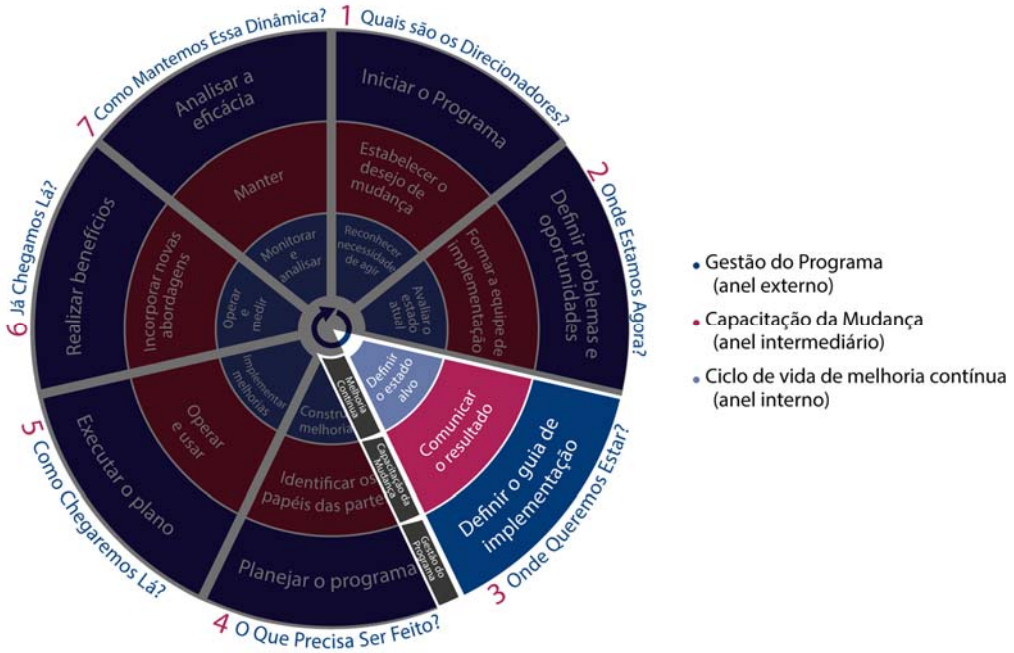


Figura 24 - Papéis na 3ª Fase

Quando você pertencer a...	Sua função nesta fase é...
Diretoria e administração	Definir prioridades, cronogramas e expectativas em relação à capacidade futura exigida de TI.
Administração do negócio	Auxiliar TI com a definição das metas de capacidade. Garantir que as soluções previstas estejam alinhadas aos objetivos corporativos.
Gerência de TI	Aplicar critérios profissionais na formulação dos planos e iniciativas de melhoria prioritários. Obter consenso sobre a meta de capacidade necessária. Garantir que as soluções previstas estejam alinhadas aos objetivos de TI.
Auditoria interna	Prestar assessoria e auxiliar com o posicionamento do propósito-alvo e priorização dos problemas a serem resolvidos. Se necessário, verificar os resultados da avaliação através de consultores independentes.
Área de risco, conformidade e jurídica	Analisar os planos para garantir que o risco, conformidade e questões jurídicas tenham sido adequadamente considerados.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 25 - Descrição da 3ª Fase	
3ª Fase	Onde Queremos Chegar?
Objetivo da fase	Determinar a capacidade desejada para cada um dos processos selecionados. Determinar as diferenças entre as posições atual e desejadas dos processos selecionados, e converter essas diferenças em oportunidades de melhoria. Usar estas informações para criar um caso de negócio detalhado e um plano do programa em alto nível.
Descrição da fase	Com base nos atuais níveis de capacidade de processo, e com o uso dos resultados da análise dos objetivos corporativos em relação aos objetivos de TI e a identificação da importância do processo realizada anteriormente, o nível de capacidade desejado deve ser determinado para cada processo. O nível escolhido deve levar em consideração as referências internas e externas disponíveis. É importante assegurar a adequação do nível escolhido ao negócio. Depois que a atual capacidade do processo tiver sido determinada e a capacidade alvo planejada, as diferenças entre os estados atual e desejado deverão ser avaliadas e as oportunidades de melhoria identificadas. Após estas diferenças tiverem sido definidas, as causas raiz, problemas comuns, risco residual, os atuais pontos fortes e melhores práticas para eliminar essas diferenças deverão ser determinados. Esta fase poderá identificar algumas melhorias relativamente fáceis de implementar tais como a melhoria do treinamento, o compartilhamento das boas práticas e a padronização de procedimentos; entretanto, a análise de falhas provavelmente exigirá experiência considerável em técnicas de gestão de negócios e de TI para o desenvolvimento de soluções práticas. Também será necessária experiência no entendimento da mudança comportamental e organizacional. Poderá ser necessário o entendimento de técnicas de processo, negócios avançados e expertise técnica, bem como conhecimento do negócio e dos aplicativos e serviços de gerenciamento do sistema. Para garantir que esta fase seja executada com eficácia, é importante que a equipe trabalhe em conjunto com os responsáveis pelos processos de negócios e de TI e demais participantes necessários, envolvendo especialistas internos. Se necessário, assessoria externa também deverá ser obtida. O risco que não puder ser mitigado após a eliminação das diferenças deverá ser identificado e formalmente aceito pela administração.
Tarefas de melhoria contínua (CI)	Definir o estado desejado e analisar as falhas: 1. Definir a meta de melhoria: – Com base nos requisitos de desempenho e conformidade da organização, definir os níveis iniciais ideais da capacidade a ser atingida a curto e a longo prazo em cada processo. – Na medida do possível, avaliar o desempenho interno a fim de identificar as melhores práticas que possam ser adotadas. – Na medida do possível, avaliar o desempenho externo junto a concorrentes e colegas para ajudar a decidir sobre adequação do nível-alvo definido. – Fazer uma "validação de senso comum" da razoabilidade do nível desejado (de forma isolada ou como um todo), observando o que for atingível e desejável e possa ter o maior impacto positivo dentro do prazo escolhido. 2. Analisar falhas – Usar o entendimento da capacidade atual (por atributo) e compará-la ao nível de capacidade desejado. – Potencializar os atuais pontos fortes sempre que possível para corrigir as falhas, e buscar a orientação nas práticas e atividades de gestão do COBIT 5 e outras boas práticas e padrões específicos tais como ITIL/IEC 27000, TOGAF e Project Management Body of Knowledge (PMBOK) para corrigir outras falhas. – Identificar padrões que indiquem as causas raiz a serem abordadas. 3. Identificar melhorias potenciais: – Agrupar falhas em melhorias potenciais. – Identificar o risco residual não mitigado e garantir aceitação formal.
Tarefas de capacitação de mudança (CE)	Descrever e comunicar o resultado (saída) desejado: 1. Descrever o plano e objetivos de habilitação da mudança em alto nível, que irão incluir as seguintes tarefas e componentes. 2. Desenvolver uma estratégia de comunicação (inclusive os principais grupos de público, o perfil comportamental e as informações necessárias por grupo, mensagens principais, canais de comunicação ideais, bem como os princípios de comunicação) a fim de aumentar a conscientização e a adesão. 3. Assegurar a vontade de participar (quadro da mudança). 4. Articular as justificativas e os benefícios da mudança a fim de apoiar a visão e descrever os impacto(s) de não implementar a mudança (objetivo da mudança). 5. Referir-se novamente aos objetivos da iniciativa nas comunicações e demonstrar como a mudança gerará o benefício.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 25 - Descrição da 3ª Fase	
3ª Fase	Onde Queremos Chegar?
	6. Descrever o guia de implementação em alto nível para alcançar a visão (planejamento para a mudança) bem como o envolvimento exigido dos participantes (papel desempenhado na mudança). 7. Usar a alta administração para entregar as principais mensagens para "definir a linha de orientação no topo da organização". 8. Usar agentes da mudança para comunicações informais em adição às formais. 9. Comunicar através da ação - a equipe de orientação deve dar o exemplo. 10. Utilizar a empatia sempre que necessário para levar as pessoas a mudar de comportamento. 11. Capturar o feedback da comunicação inicial (críticas e sugestões) e adaptar a estratégia de comunicação de forma correspondente.
Tarefas da gestão do programa (PM)	Definir o guia de implementação: 1. Definir a orientação, escopo, benefícios e objetivos do programa em alto nível. 2. Garantir o alinhamento dos objetivos com as estratégias de TI e de negócios. 3. Considerar o risco e ajustar o escopo de forma correspondente. 4. Considerar as implicações da habilitação da mudança. 5. Obter os orçamentos necessários e definir as obrigações e responsabilidades do programa. 6. Criar e avaliar um caso de negócio detalhado, orçamento, prazos e o plano do programa em alto nível.
Entrada	▪ Objetivos corporativos definidos e o impacto sobre os objetivos de TI ▪ Classificação da capacidade atual dos processos selecionados ▪ Definição dos objetivos de TI ▪ Processos e metas selecionados ▪ Posição de aceitação do risco e perfil de risco ▪ Avaliação do risco de capacitação do benefício/valor, execução do programa/projeto e avaliações de risco das operações de TI/prestação do serviço ▪ Pontos fortes nos quais se basear ▪ Agentes da mudança em diferentes partes e em diferentes níveis da organização ▪ Equipe principal e as papéis e responsabilidades atribuídas ▪ Avaliação das linhas gerais do caso de negócio ▪ Desafios e fatores de sucesso. ▪ Benchmarks de capacidade interna e externas ▪ Boas práticas do COBIT 5 e outras referências ▪ Análise da parte interessada
Recursos da ISACA	▪ COBIT 5 (objetivos corporativos), www.isaca.org/cobit ▪ COBIT 5: Habilitando Processos (práticas e atividades de gestão para definição do estado-alvo e análise de falhas; APO01, APO02) ▪ Guia de auto avaliação do COBIT 5 (publicação planejada) ▪ Produtos de apoio da ISACA - ex: mapeamentos do COBIT 4.1 para outros modelos e melhores práticas – conforme definição atual em www.isaca.org
Saída	▪ Classificação da capacidade alvo dos processos selecionados ▪ Descrição das oportunidades de melhoria ▪ Documento de resposta ao risco, inclusive o risco não mitigado ▪ Plano e objetivos de habilitação da mudança ▪ Estratégia de comunicação e comunicação da visão de mudança cobrindo os quatro Ps (panorama, propósito, plano e participante) ▪ Caso de negócio detalhado ▪ Plano do programa em alto nível ▪ Principais métricas a serem utilizadas para acompanhar o programa e o desempenho operacional

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 26 - Tabela RACI da Fase 3

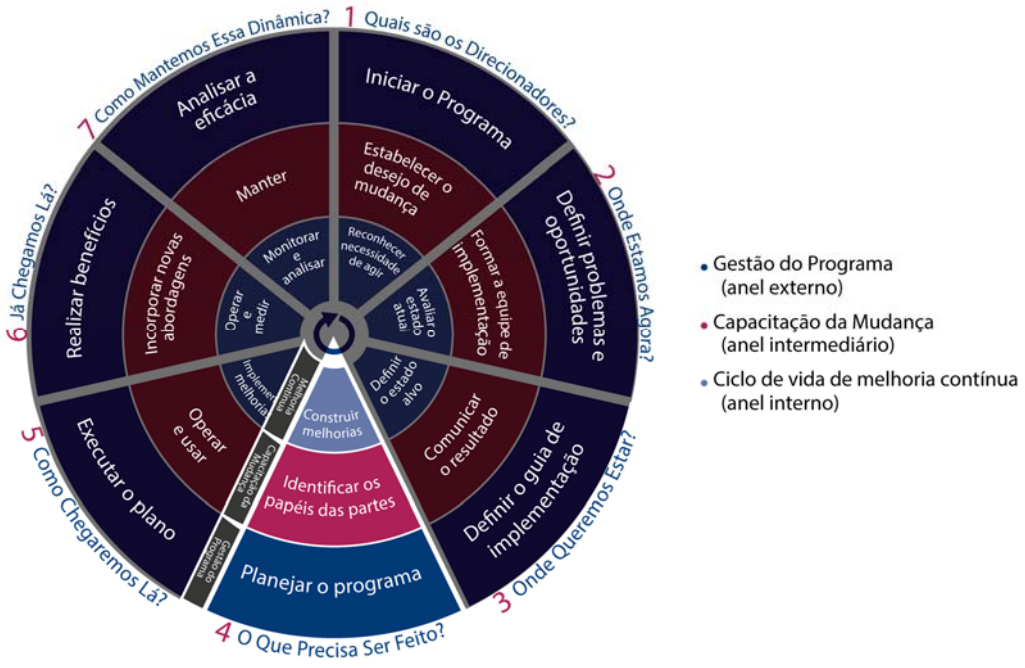
Principais Atividades	Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
	Responsabilidades dos Especialistas em Implementação								
Definir a meta de melhoria (CI1).	I	A	R	C	R	R	C	C	R
Analisar falhas (CI2).		I	R	C	R	R	C	C	A
Identificar melhorias possíveis (CI3).		I	R	C	R	R	C	C	A
Comunicar a visão da mudança (CE3).		A	R	R	C	I	I	I	R
Definir a orientação do programa e preparar o estudo de caso detalhado (PM1, PM6).	I	A	R	C	C	C	I	I	R

A tabela **RACI** identifica quem é **R**esponsável, **A**provador, **C**onsultado e/ou **I**nformado.

4ª Fase - O Que Necessita Ser Feito?

As **figuras 27**, **28**, **29** e **30** descrevem a 4ª Fase.

Figura 27 - 4ª Fase do Ciclo de Vida



Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 28 - Papéis na 1ª Fase	
Quando você pertencer a...	Sua função nesta fase é...
Diretoria e administração	Considerar e desafiar propostas, apoiar ações justificadas, fornecer orçamentos e definir prioridades, conforme o caso.
Administração do negócio	Juntamente com TI, garantir que as ações de melhoria propostas sejam alinhadas aos objetivos corporativos e de TI definidos e que quaisquer atividades que exijam dados (entrada) ou ação da organização sejam apoiadas. Garantir que os recursos necessários ao negócio sejam alocados e disponibilizados. Definir junto a TI as métricas para medir os resultados do programa de melhoria.
Gerência de TI	Garantir a viabilidade e razoabilidade do plano do programa. Garantir que o plano seja atingível e que hajam recursos disponíveis para executar o plano. Considerar o plano juntamente com as prioridades do portfólio da organização de investimentos capacitados por TI a fim de definir uma base para o financiamento do investimento.
Auditoria interna	Fornecer a garantia independente de que os problemas identificados são válidos, os estudos de caso serão apresentados de forma objetiva e precisa e os planos pareçam atingíveis. Prestar consultoria e orientação de especialistas, se for o caso.
Área de risco, conformidade e jurídica	Garantir que os problemas identificados relacionados ao risco, conformidade e questões jurídicas estejam sendo tratados e as propostas estejam em conformidade com as políticas e regulamentos pertinentes.

Figura 29 - Descrição da 4ª Fase	
1ª Fase	O Que Deve Ser Feito?
Objetivo da fase	Converter as oportunidades de melhoria em projetos de contribuição justificáveis. Priorizar e focar nos projetos de alto impacto. Integrar os projetos de melhoria no plano geral do programa. Obter resultados rápidos.
Descrição da fase	Quando todas as iniciativas de melhoria em potencial forem identificadas, estas iniciativas devem ser priorizadas em projetos formais e justificáveis. Os projetos com alto benefício e relativamente fáceis de implementar devem primeiramente ser selecionados e convertidos em projetos formais e justificáveis, cada um com um plano de projeto que inclua a contribuição do projeto aos objetivos do programa. É importante verificar se os objetivos ainda estão em conformidade com os direcionadores de valor e risco originais. Os projetos serão incluídos em um caso de negócio do programa atualizado. Detalhes de quaisquer propostas do projeto de melhoria não aprovadas devem ser armazenados em um registro para possível consideração futura e as oportunidades devem ser apresentadas aos patrocinadores para sua reavaliação e, conforme o caso, suas recomendações deverão ser reenviadas em uma data posterior. Com base em um quadro de oportunidades, as definições do projeto, o plano de recursos e o orçamento de TI e as melhorias identificadas e priorizadas são agora transformadas em um conjunto de projetos documentados que apoiam o programa de melhoria geral. O impacto da execução do programa sobre a organização é determinado e um plano de mudança preparado descrevendo as atividades do programa que, em termos práticos, garantirão que as melhorias proporcionadas pelos projetos serão aplicadas na organização de forma sustentável. Um elemento importante nesta fase é a definição de métricas -ou seja, as métricas de sucesso do programa - que medirão a probabilidade de as melhorias do processo gerarem os benefícios do negócio original. A programação completa do programa de melhoria deve ser documentada em uma tabela Gantt. Novos projetos podem identificar uma necessidade de mudar ou melhorar as estruturas organizacionais ou outros facilitadores necessários para sustentar a governança eficaz. Se for o caso, poderá ser necessário incluir ações para melhoria do ambiente (conforme descrito no Capítulo 5).
Tarefas de melhoria contínua (CI)	Projetar e aplicar as melhorias: 1. Para cada melhoria, considerar o benefício potencial e a facilidade de implementação (custo, esforço, sustentabilidade). 2. Traçar melhorias em um quadro de oportunidades a fim de identificar as ações prioritárias (com base no benefício e facilidade de implementação). 3. Concentrar-se em alternativas que apresentem alto benefício/facilidade de implementação. 4. Considerar quaisquer outras ações que demonstrem alto benefício/facilidade de implementação para possíveis melhorias em menor escala (decompor em melhorias menores e reavaliar os benefícios e facilidade de implementação). 5. Priorizar e selecionar as melhorias. 6. Analisar as melhorias selecionadas com o detalhamento necessário para a definição do projeto em alto nível, considerando a abordagem, resultados, recursos necessários, custos estimados, cronogramas estimados, dependências e risco do projeto. Usar as boas práticas e padrões disponíveis para refinar ainda mais os requisitos de melhoria detalhados. Debater com os gerentes e as equipes responsáveis pela área do processo.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 29 - Descrição da 4ª Fase	
1ª Fase	O Que Deve Ser Feito?
	7. Considerar a viabilidade, associá-la novamente aos orientadores de valor e risco originais e definir os projetos a serem incluídos no caso de negócio para aprovação. 8. Registrar os projetos e iniciativas não aprovados em um livro de registros para possível consideração futura.
Tarefas de capacitação de mudança (CE)	Capacitar especialistas e identificar resultados rápidos: 1. Obter adesão envolvendo no projeto as pessoas afetadas pela mudança através de mecanismos tais como seminários (workshops) ou processos de análise e atribuindo a elas a responsabilidade pela aceitação da qualidade dos resultados. 2. Elaborar planos de resposta à mudança para gerenciar pro-ativamente os impactos da mudança e maximizar a participação em todo o processo de implementação (isto poderia incluir mudanças organizacionais tais como descrição de cargos ou estrutura organizacional; mudanças na gestão de pessoas tais como treinamento; sistemas de controle de desempenho; ou sistemas de incentivos/remuneração e gratificação). 3. Identificar resultados rápidos que comprovem o conceito do programa de melhoria. Estes devem ser visíveis e sem ambiguidades, gerar dinâmica e fornecer um reforço positivo do processo. 4. Se possível, basear-se em quaisquer dos pontos fortes existentes identificados na 2ª fase a fim de gerar resultados rápidos. 5. Identificar os pontos fortes nos atuais processos da organização que podem ser potencializados. Por exemplo, pontos fortes no gerenciamento do projeto podem existir em outras áreas da organização tais como desenvolvimento de produtos (evitar reinventar a roda e alinhar-se sempre que possível às atuais abordagens da organização).
Tarefas da gestão do programa (PM)	Desenvolver o plano do programa: 1. Organizar os projetos em potencial no programa geral, na sequência preferida, considerando a contribuição aos resultados desejados, os recursos necessários e as dependências. 2. Usar as técnicas de gestão de portfólio para garantir que o programa esteja em conformidade com os objetivos estratégicos e que TI possua um conjunto equilibrado de iniciativas. 3. Identificar o impacto do programa de melhoria sobre as organizações de TI e do negócio e indicar como a dinâmica de melhoria deverá ser mantida. 4. Desenvolver um plano de mudança documentando qualquer migração, conversão, teste, treinamento, processo ou outras atividades que possam ser incluídas no programa como parte da implementação. 5. Identificar e definir as métricas para medir os resultados do programa de melhoria em termos dos fatores de sucesso do programa original. 6. Orientar a alocação e priorização dos recursos do negócio, de TI e de auditoria necessários à consecução dos objetivos do programa e do projeto. 7. Definir um portfólio dos projetos que produzirão os resultados previstos pelo programa. 8. Definir os resultados necessários, considerando todo o escopo de atividades necessárias para cumprir os objetivos. 9. Indicar, se necessário, comitês diretores de projeto para projetos específicos do programa. 10. Definir os planos do projeto e procedimentos de relatório a fim de permitir que o progresso seja monitorado.
Entrada	▪ Classificação de maturidade alvo dos processos selecionados ▪ Descrição das oportunidades de melhoria ▪ Documento de resposta ao risco ▪ Plano e objetivos de capacitação da mudança ▪ Estratégia de comunicação e comunicação da visão de mudança cobrindo os quatro Ps (panorama, propósito, plano e participante) ▪ Caso de negócio detalhado ▪ Planilha de oportunidades, boas práticas e padrões, avaliações externas e avaliações técnicas ▪ Quadro de oportunidades, definições de projeto, plano de gestão do portfólio do projeto, plano de recursos e orçamento de TI ▪ Pontos fortes identificados nas fases anteriores
Recursos da ISACA	▪ COBIT 5 (modelos de facilitador), www.isaca.org/cobit ▪ COBIT 5: Habilitando Processos (APO05, APO12, BAI01; metas e métricas) ▪ Produtos de apoio da ISACA conforme definição atual em www.isaca.org
Saída	▪ Definições do projeto de melhoria ▪ Planos definidos de resposta à mudança ▪ Resultados rápidos identificados ▪ Registro de projetos não aprovados

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 29 - Descrição da 4ª Fase	
1ª Fase	O Que Deve Ser Feito?
	▪ Plano do programa que sequencia os planos individuais de acordo com os recursos alocados, prioridades e resultados ▪ Planos do projeto e procedimentos de reporte capacitados através dos recursos dedicados, ex: habilidades, investimento ▪ Métricas de sucesso

Figura 30 - Tabela RACI da 4ª Fase

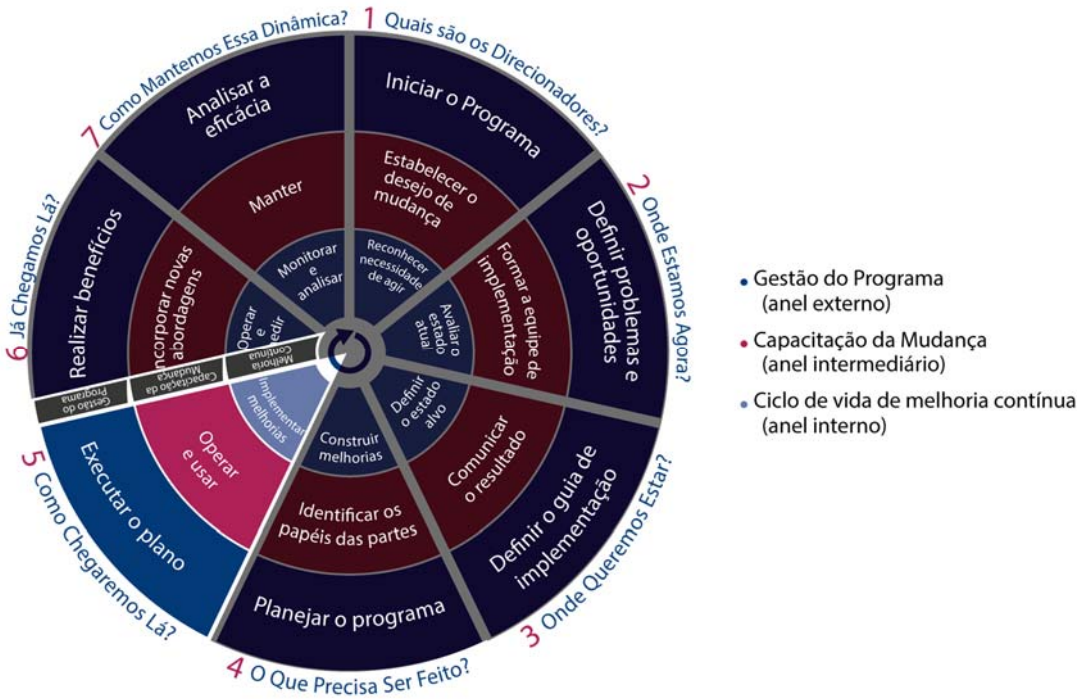
Principais Atividades	Responsabilidades dos Especialistas em Implementação								
	Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
Priorizar e selecionar as melhorias (CI5).		A	R	C	C	R	C	C	R
Definir e justificar os projetos (CI6 e CI7).		I	R	C	R	R	C	C	A
Projetar os planos de resposta à mudança (CE2).		I	R	R	C	C	C	C	A
Identificar resultados rápidos e basear-se nos atuais pontos fortes (CE3).		I	C	C/I	R	R	C/I	C/I	A
Desenvolver o plano do programa com os recursos alocados e planos do projeto (PM1 a PM10).		A	C	C	R	C	I	I	R

A tabela **RACI** identifica quem é **R**esponsável, Prest**A** Contas, **C**onsultado e/ou **I**nformado.

5ª Fase - Como Chegamos lá?

As **figuras 31**, **32**, **33** e **34** descrevem a 5ª fase.

Figura 31 - 5ª Fase do Ciclo de Vida de Melhoria Contínua



Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 32 – Papéis da Fase 5ª	
Quando você pertencer a...	Sua função nesta fase é...
Diretoria e administração	Monitorar a implementação e fornecer apoio e orientação conforme necessário.
Administração do negócio	Responsabilizar-se pela participação da organização na implementação, especialmente quando os processos de negócios forem afetados e os processos de TI exigirem o envolvimento do usuário/cliente.
Gerência de TI	Garantir que a implementação inclua todo o escopo de atividades necessárias (ex: mudanças na política e nos processos, soluções de tecnologia, mudanças organizacionais, novas papéis e responsabilidades, outros facilitadores) e que sejam práticos e atingíveis e que possam ser adotados e usados. Garantir que os responsáveis pelo processo sejam envolvidos, adotem a nova abordagem e respondam pelos processos resultantes. Solucionar os problemas e gerenciar o risco encontrado durante a implementação.
Auditoria interna	Analisar e fornecer dados (entrada) durante a implementação a fim de evitar a identificação de habilitadores ausentes e especialmente os principais controles após o fato. Fornecer orientação sobre a implementação dos aspectos de controle. Se necessário, fornecer um serviço de análise de risco do projeto/implementação, monitorando o risco que possa comprometer a implementação e fornecendo feedback independente às equipes do programa e do projeto.
Área de risco, conformidade e jurídica	Fornecer a orientação necessária sobre risco, conformidade e aspectos legais durante a implementação.

Figura 33 - Descrição da 5ª Fase	
5ª Fase	Como Chegamos lá?
Objetivo da fase	Implementar os projetos de melhoria detalhados, potencializando as capacidades, padrões e práticas de gestão do projeto e do programa da organização. Monitorar, medir e reportar o andamento do projeto.
Descrição da fase	Os projetos de melhoria aprovados, inclusive as atividades de mudança necessárias, agora estão prontos para implementação, de modo que as soluções definidas pelo programa podem agora ser adquiridas ou desenvolvidas e implementadas na organização. Desta forma, os projetos se tornam parte do ciclo de vida normal de desenvolvimento e devem ser regidos pelos métodos de gestão de projeto e programa definidos. A implementação da solução deve estar em consonância com as definições do projeto aprovado e do plano de mudança para que as melhorias sejam sustentáveis. Esta fase geralmente exigirá mais esforço e tempo entre todas as fases do ciclo de vida. É recomendado, entretanto, que a dimensão e o tempo total não seja excessivo garantindo que seja gerenciável e que os benefícios sejam realizados em um prazo razoável. Isto é particularmente verdadeiro nas primeiras iterações, uma vez que também será uma experiência de aprendizado para todos os envolvidos. Monitorar o desempenho de cada projeto para garantir que os objetivos estejam sendo alcançados. Enviar relatórios de volta aos participantes em intervalos regulares para garantir que o progresso seja entendido e esteja no caminho certo.
Tarefas de melhoria contínua (CI)	Implementar as melhorias: 1. Desenvolver e, quando necessário, adquirir soluções que incluam todo o escopo das atividades necessárias, ex: cultura, ética e comportamento; estruturas organizacionais; princípios e políticas; processos; capacidades de serviço; habilidades e competências; e informação. 2. Ao usar as boas práticas, adotar e adaptar a orientação disponível a fim de adequar a abordagem da organização às políticas e procedimentos. 3. Testar a praticidade e adequação das soluções no ambiente de produção. 4. Implementar as soluções levando em consideração os processos existentes e requisitos de migração.
Tarefas de capacitação de mudança (CE)	Capacitar a operação e o uso: 1. Basear-se na dinâmica e credibilidade que possam ser criadas pelos resultados rápidos, e então introduzir aspectos de mudança mais amplos e desafiadores. 2. Comunicar os resultados rápidos obtidos e reconhecer e recompensar os responsáveis por eles. 3. Implementar os planos de resposta à mudança. 4. Garantir que a base mais ampla dos especialistas tenha as habilidades, recursos e conhecimento, bem como a adesão e o compromisso com a mudança. 5. Equilibrar as intervenções individuais e em grupo para garantir que uma visão holística da mudança seja obtida pelos participantes. 6. Planejar os aspectos culturais e comportamentais da transição mais ampla (tratando o medo de perda de responsabilidade/independência/poder de decisão, novas expectativas e tarefas desconhecidas).

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 33 - Descrição da 5ª Fase

5ª Fase	Como Chegamos lá?
	7. Comunicar as papéis e responsabilidades pelo uso. 8. Definir as medidas de sucesso, inclusive aquelas do ponto de vista da organização e medidas de percepção. 9. Implementar orientação e treinamento para garantir a absorção e a adesão. 10. Fechar o ciclo e garantir que todos os requisitos da mudança tenham sido abordados. 11. Monitorar a eficácia da capacitação da mudança e aplicar as ações corretivas quando necessário.
Tarefas da gestão do programa (PM)	Executar o plano: 1. Garantir que a execução do programa tenha como base um plano de projetos atualizado e integrado (negócios e TI) dentro do programa. 2. Orientar e monitorar a contribuição de todos os projetos no programa para garantir a obtenção dos resultados esperados. 3. Fornecer regularmente relatórios atualizados aos participantes para garantir que o progresso seja entendido e esteja no caminho certo. 4. Documentar e monitorar os riscos e problemas significativos do programa, e definir ações corretivas. 5. Aprovar o início de cada fase importante do programa e comunicar isso a todos os participantes. 6. Aprovar eventuais mudanças importantes nos planos do projeto e do programa.
Entrada	▪ Definições do projeto de melhoria ▪ Planos de resposta à mudança definidos ▪ Resultados rápidos identificados ▪ Registro de projetos não aprovados ▪ Plano do programa com os recursos alocados, prioridades e resultados ▪ Planos do projeto e procedimentos de relatório ▪ Métricas do sucesso ▪ Definições do projeto, Gráfico de Gantt do projeto, planos de resposta à mudança, estratégia de mudança ▪ Planos integrados do projeto e do programa
Recursos da ISACA	▪ COBIT 5: Habilitando Processos (como entrada de boas práticas e BAI01), www.isaca.org/cobit ▪ Produtos de apoio da ISACA conforme definição atual em www.isaca.org
Saída	▪ Melhorias implementadas ▪ Planos de resposta à mudança implementados. ▪ Resultados rápidos obtidos e visibilidade do sucesso da mudança ▪ Comunicações do sucesso ▪ Papéis e responsabilidades definidas e comunicadas no ambiente de negócios de forma habitual ▪ Logs de mudança do projeto e logs de problemas/risco ▪ Medidas definidas do negócio e da percepção do sucesso ▪ Benefícios acompanhados para monitorar a realização

Figura 34 - Tabela RACI da 5ª Fase

Principais Atividades	Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
	Responsabilidades dos Especialistas em Implementação								
Desenvolver e, se necessário, adquirir soluções (CI1).		A	C	C	R	R	C	C	R
Adotar e adaptar boas práticas (CI2).		I	R	C	R	R	C	C	A
Testar e implementar soluções (CI3 e CI4).		I	R	C	R	R	C	C	A
Capitalizar os resultados rápidos (CE1 e CE2).		I	C	C/I	R	R	C/I	C/I	A
Implementar planos de resposta à mudança (CE3).	I	I	R	C	R	R	I	I	A
Orientar e monitorar os projetos do programa (PM2).	I	A	C	C	R	C	I	I	R

A tabela **RACI** identifica quem é **R**esponsável, Prest**A** Contas, **C**onsultado e/ou **I**nformado.

Personal Copy of: Mr. Jorge Diab Maluf Filho

6ª Fase -Já Chegamos Lá?

As **figuras 35**, **36**, **37** e **38** descrevem a 6ª fase.

Figura 35 - 6ª Fase do Ciclo de Vida de Melhoria Contínua

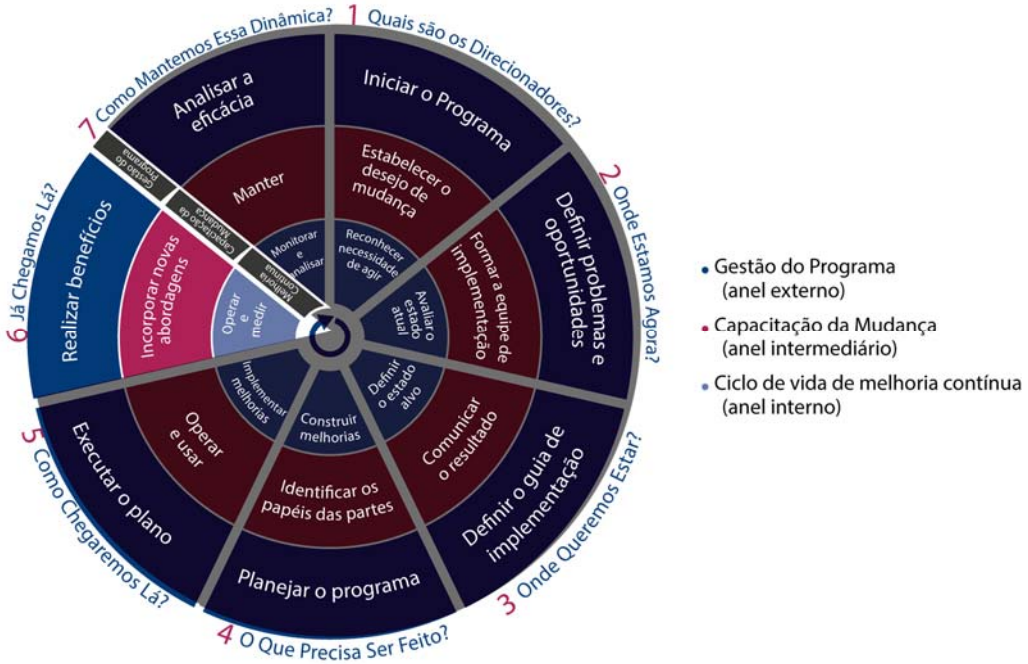


Figura 36 - Papéis na 6ª Fase

Quando você pertencer a...	Sua função nesta fase é...
Diretoria e administração	Avaliar o desempenho no cumprimento dos objetivos originais e confirmar a obtenção dos resultados desejados. Considerar a necessidade de reorientar as atividades futuras e aplicar medidas corretivas. Auxiliar na resolução de problemas significativos, se necessário.
Administração do negócio	Fornecer feedback e considerar a eficácia da contribuição da organização à iniciativa. Usar os resultados positivos para melhorar as atuais atividades relacionadas ao negócio. Usar as lições aprendidas para adaptar e melhorar a abordagem da organização às futuras iniciativas.
Gerência de TI	Fornecer feedback e considerar a eficácia da contribuição de TI à iniciativa. Usar resultados positivos para melhorar as atuais atividades de TI. Monitorar os projetos com base na sua criticidade conforme forem desenvolvidos, usando técnicas de gestão do programa e do projeto, e preparar-se para alterar o plano e/ou cancelar um ou mais projetos ou aplicar outra ação corretiva se os indicadores prévios mostrarem que um projeto está no caminho errado e pode não atender às metas críticas. Usar as lições aprendidas para adaptar e melhorar a abordagem de TI às futuras iniciativas.
Auditoria interna	Fornecer avaliação independente da eficácia e eficiência geral da iniciativa. Fornecer feedback e considerar a eficácia da contribuição da auditoria à iniciativa. Usar os resultados positivos para melhorar as atuais atividades relacionadas à auditoria. Usar as lições aprendidas para adaptar e melhorar a abordagem da auditoria às iniciativas futuras.
Área de risco, conformidade e jurídica	Avaliar se a iniciativa melhorou a capacidade da organização de identificar e gerenciar o risco e os requisitos legais, regulatórios e contratuais. Fornecer feedback e fazer as recomendações necessárias às melhorias.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 37 - Descrição da 5ª Fase	
6ª Fase	Já Chegamos Lá?
Objetivo da fase	Integrar as métricas de desempenho do projeto e a realização de benefícios do programa de melhoria da governança geral no sistema de medição de desempenho em relação ao monitoramento regular e contínuo.
Descrição da fase	É essencial que as melhorias descritas no programa sejam monitoradas através dos objetivos de TI e das metas do processo usando técnicas adequadas tais como um scorecard equilibrado de TI (BSC) e de um registro de benefícios para verificar se os resultados da mudança foram atingidos. Isto garantirá que as iniciativas permaneçam no caminho certo de acordo com os objetivos corporativos e de TI originais e continuem a gerar os benefícios esperados do negócio. Para cada métrica, as metas precisam ser definidas, comparadas regularmente com a realidade e comunicadas através de um relatório de desempenho. Para garantir o sucesso, é crucial que os resultados positivos e negativos das medições de desempenho sejam reportados a todas as partes interessadas, o que criará confiança e permitirá que quaisquer ações corretivas sejam tomadas em tempo hábil. Os projetos devem ser monitorados conforme são desenvolvidos, usando técnicas de gestão de programa e de projeto, e a preparação deve ser feita para alterar o plano e/ou cancelar o projeto se os primeiros indicadores mostrarem que um projeto está no caminho errado e pode não atender às metas críticas.
Tarefas de melhoria contínua (CI)	Operar e medir: 1. Definir as metas de cada métrica para um prazo definido. As metas devem permitir que o desempenho e as ações de melhoria de TI sejam monitoradas e o sucesso ou possíveis falhas determinadas. 2. Quando possível, obter as atuais medidas vigentes destas métricas. 3. Reunir as medidas vigentes e compará-las com as metas regularmente, ex: mensalmente, e investigar eventuais variações significativas. 4. Quando variações indicarem que ações corretivas são necessárias, desenvolver e determinar as medidas corretivas propostas. 5. Ajustar as metas de longo prazo com base na experiência, se necessário. 6. Comunicar os resultados positivos e negativos do monitoramento do desempenho às partes interessadas, com recomendações para quaisquer medidas corretivas.
Tarefas de capacitação de mudança (CE)	Incorporar novas abordagens: 1. Garantir que novas formas de trabalho se tornem parte da cultura corporativa (a forma como fazemos as coisas por aqui), ou seja, as enraizado nas normas e valores da organização. Isto é importante para concretizar os resultados a serem alcançados. 2. Na transição do modo de projeto para a atividade normal de negócio, os comportamentos devem ser moldados pelas descrições de cargo revisadas, sistemas de remuneração e gratificação, KPIs e procedimentos operacionais implementados através dos planos de resposta à mudança. 3. Monitorar se as papéis e responsabilidades atribuídas foram assumidas. 4. Acompanhar a mudança e avaliar a eficácia dos planos de resposta à mudança, associando os resultados às metas e aos objetivos originais da mudança. Isto deve incluir severas medidas ao negócio e medidas de percepção, ex: pesquisas de percepção, sessões de feedback, formulários de avaliação de treinamento. 5. Potencializar áreas de excelência para fornecer uma fonte de inspiração. 6. Manter a estratégia de comunicação para atingir uma conscientização contínua e destacar os sucessos. 7. Garantir que haja comunicação aberta entre todos os atores com o objetivo de solucionar problemas. 8. Quanto problemas que não puderem ser resolvidos, escalar aos responsáveis. 9. Se ainda for necessário, aplicar a mudança por meio do gerenciamento da autoridade. 10. Documentar lições de habilitação aprendidas com mudanças para futuras iniciativas de implementação.
Tarefas da gestão do programa (PM)	Realizar os benefícios: 1. Monitorar o desempenho geral do programa em comparação com os objetivos do business case. 2. Monitorar o desempenho do investimento (custo comparado ao orçamento e realização de benefícios). 3. Documentar as lições aprendidas (positivas e negativas) para iniciativas de melhoria subsequentes.
Entrada	▪ Melhorias implementadas. ▪ Planos de resposta à mudança implementados. ▪ Resultados rápidos obtidos e comunicações do sucesso. ▪ Papéis e responsabilidades definidos e comunicados no ambiente normal de negócio. ▪ Logs de mudança do projeto e logs de problema/risco. ▪ Medidas de sucesso do negócio e da percepção definidas. ▪ Objetivos de TI e metas do processo de TI identificadas em decorrência das análises de requisitos. ▪ Métricas e/ou processos de registro existentes (scorecards) ▪ Benefícios do caso de negócio (business case).

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 37 - Descrição da 5ª Fase	
6ª Fase	Já Chegamos Lá?
	▪ Planos de resposta à mudança e estratégia de comunicação
Recursos da ISACA	▪ COBIT 5: Habilitando Processos (como dados (entrada) de boas práticas e EDM05, APO05, BAI01, MEA01), www.isaca.org/cobit ▪ Produtos de apoio da ISACA conforme definição atual em www.isaca.org
Saída	▪ Processos de registro de medidas (Scorecards) do projeto e programa atualizados. ▪ Medidas de eficácia da mudança (medidas do negócio e das percepções.) ▪ Relatório explicando os resultados dos processos de registros de medida (scorecard) ▪ Melhorias enraizadas nas operações. ▪ Principais métricas adicionadas na abordagem contínua de medição do desempenho de TI.

Figura 38 - Tabela RACI da 6ª Fase

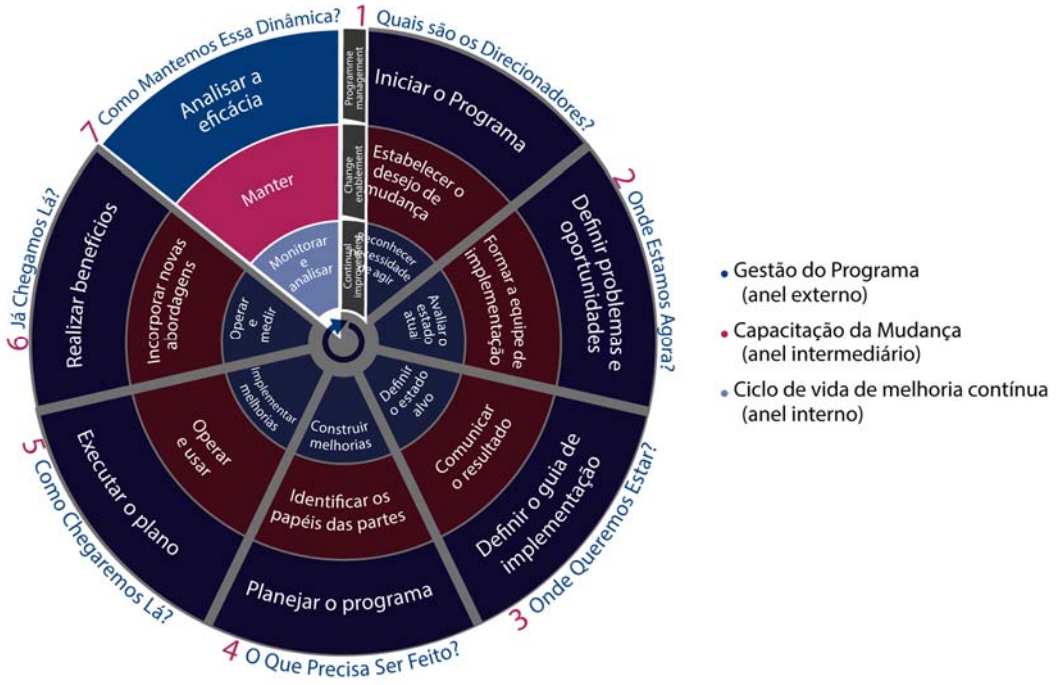
Principais Atividades	Responsabilidades dos Especialistas em Implementação								
	Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
Operar as soluções e obter feedback sobre o desempenho (CI1 a CI3).		I	A	R	R	R	I	I	I
Monitorar o desempenho em comparação com as métricas de sucesso (CI4 a CI5).		I	A	C	R	R	C	C	I
Comunicar os resultados positivos e negativos (CI6).	I	I	A	C	R	C	I	I	I
Monitorar a propriedade das funções e responsabilidades (CE3).		A	R	C	C	C	C	C	I
Monitorar os resultados do programa (atingimento de objetivos e realização de benefícios) (PM1 e PM2).	I	A	C	C	C	C	C	C	R

A tabela **RACI** identifica quem é **R**esponsável, Prest**A** Contas, **C**onsultado e/ou **I**nformado.

7ª Fase - Como Mantemos a Dinâmica?

As **figuras 39**, **40**, **41** e **42** descrevem a 7ª fase.

Figura 39 - 7ª Fase do Ciclo de Vida de Melhoria Contínua



Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 40 – Papéis da Fase 7ª	
Quando você pertencer a...	Sua função nesta fase é...
Diretoria e administração	Fornecer orientação, definir os objetivos e alocar as papéis e responsabilidades para abordagem corporativa contínua e melhoria do GEIT. Continuar a "definir o tom no alto escalão", desenvolver estruturas organizacionais e incentivar uma cultura de boa governança e prestação de contas para responsabilidade entre os executivos de negócios e de TI. Garantir que TI está ciente e, se apropriado, envolvida nos novos objetivos e requisitos do negócio da forma mais oportuna possível.
Administração do negócio	Demonstrar apoio e compromisso continuando a trabalhar positivamente com TI para melhorar a GEIT e torná-la uma atividade normal de negócio. Verificar se os novos objetivos da GEIT estão alinhados aos atuais objetivos corporativos.
Gerência de TI	Orientar e exercer uma forte liderança para sustentar a dinâmica do programa de melhoria. Participar das atividades de governança como parte da prática normal de negócio. Criar políticas, padrões e processos para garantir que a governança se torne uma atividade normal de negócio.
Auditoria interna	Fornecer dados (entrada) objetivos e construtivos, incentivar a auto avaliação e garantir à administração que a governança está trabalhando eficientemente, criando assim confiança em TI. Fornecer auditorias contínuas com base em uma abordagem de governança integrada usando critérios compartilhados com as áreas de TI e de negócio com base no modelo do COBIT.
Área de risco, conformidade e jurídica	Trabalhar com as áreas de TI e de negócio para antecipar as exigências legais e regulatórias e identificar e responder ao risco relacionado de TI como uma atividade normal na GEIT.

Figura 41 - Descrição da 7ª Fase	
6ª Fase	Como Mantemos essa Dinâmica?
Objetivo da fase	Avaliar os resultados e a experiência obtidos com o programa. Registrar e compartilhar quaisquer lições aprendidas. Melhorar as estruturas organizacionais, processos, papéis e responsabilidades para mudar o comportamento da organização de modo que a GEIT se torne uma atividade normal de negócio e constantemente otimizada. Garantir que novas ações necessárias orientem as demais iterações do ciclo de vida. Monitorar continuamente o desempenho, garantir que os resultados sejam reportados regularmente e orientar o compromisso e a propriedade da prestação de contas e responsabilidades.
Descrição da fase	Esta fase permite que a equipe determine se o programa produziu os resultados esperados. Isto pode ser feito comparando os resultados com o critério de sucesso original e reunindo o feedback da equipe de implementação e partes interessadas através de entrevistas, seminários e pesquisas de satisfação. As lições aprendidas podem conter informações valiosas para os membros da equipe e partes interessadas do projeto para uso em iniciativas contínuas e projetos de melhoria. Isto envolve o monitoramento contínuo, reporte regular e transparente e a confirmação os prestadores de contas das Demais melhorias são identificadas e usadas como dados (entrada) na próxima iteração do ciclo de vida. Nesta fase, a organização deve basear-se nos sucessos e nas lições aprendidas com o(s) projeto(s) de implementação da governança para criar e reforçar o compromisso entre as partes interessadas em TI e negócios para um continuo aperfeiçoamento da governança de TI. Políticas, estruturas organizacionais, papéis e responsabilidades e processos de governança devem ser desenvolvidos e otimizados de modo que GEIT opere efetivamente como parte da prática normal de negócio e haja uma cultura de apoio a ela, demonstrada pela alta administração.
Tarefas de melhoria contínua (CI)	Monitorar e avaliar: 1. Identificar novos objetivos e requisitos de governança com base nas experiências obtidas, atuais objetivos de negócio para TI ou outros eventos desencadeadores: a. Recolher feedback e conduzir uma pesquisa de satisfação com as partes interessadas. b. Medir e reportar os resultados reais em comparação com as medidas de sucesso do projeto originalmente definidas e incorporar o monitoramento e reporte contínuos. c. Realizar um processo facilitado de revisão e análise de projeto com os membros da equipe e as partes interessadas do projeto para registro e aprovação das lições aprendidas. d. Buscar novas oportunidades de alto impacto e baixo custo para melhorar ainda mais a GEIT. 2. Identificar as lições aprendidas.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 41 - Descrição da 7ª Fase	
	3. Comunicar os requisitos das novas melhorias às partes interessadas e documentá-las para uso como entrada na próxima iteração do ciclo de vida.
Tarefas de capacitação de mudança (CE)	Sustentar: 1. Fornecer um reforço consciente e uma campanha de comunicação contínua, bem como demonstrar o compromisso contínuo da alta administração. 2. Confirmar a conformidade com os objetivos e requisitos. 3. Monitorar continuamente a eficácia da mudança em si, as atividades de capacitação da mudança e a adesão das partes interessadas. 4. Implementar planos de ação corretiva quando necessário. 5. Fornecer feedback sobre o desempenho, recompensar objetivos alcançados e divulgar os sucessos. 6. Basear-se nas lições aprendidas. 7. Compartilhar o conhecimento da iniciativa com toda a organização.
Tarefas da gestão do programa (PM)	Analisar a eficácia do programa: 1. No encerramento do programa, garantir que aconteça uma revisão do programa e aprovação das conclusões. 2. Revisar a eficácia do programa.
Entrada	▪ Indicadores do projeto e do programa atualizados. ▪ Medidas da eficácia da mudança (medidas do negócio e das percepções) ▪ Relatório explicando os resultados dos indicadores ▪ Relatório de revisão da pós-implementação ▪ Relatórios de desempenho ▪ Estratégia de TI e do negócio ▪ Novos desencadeadores tais como novos requisitos regulatórios
Recursos da ISACA	▪ COBIT 5: Habilitando Processos (EDM01, APO01, BAI08 e MEA01), www.isaca.org/cobit ▪ Produtos de apoio da ISACA conforme definição atual em www.isaca.org
Saída	▪ Recomendações para novas atividades GEIT ▪ Pesquisa de satisfação das partes interessadas. ▪ Documentação das histórias de sucesso e lições aprendidas ▪ Plano de comunicação contínuo ▪ Esquema de gratificação por desempenho

Figura 42 – Tabela RACI da 7ª Fase

Principais Atividades	Responsabilidades dos Especialistas em Implementação								
	Conselho	Comitê Executivo de TI	Diretor de TI (CIO)	Executivo de Negócios	Gerentes de TI	Dono de Processo de TI	Auditoria de TI	Risco e Conformidade	Dirigente do Programa
Identificar novos objetivos de governança (CI1).	C	A	R	R	C	C	C	C	I
Identificar lições aprendidas (CI2).		I	A	C	R	R	C	C	I
Sustentar e reforçar as mudanças (CE1).		A	R	R	R	R	C	C	I
Confirmar a conformidade com os objetivos e requisitos (CE2).	I	A	R	C	R	R	R	I	R
Encerrar o programa com uma revisão formal de eficácia (PM1).	I	A	C	C	C	C	C	C	R

A tabela **RACI** identifica quem é **R**esponsável, Prest**A** Contas, **C**onsultado e/ou **I**nformado.

Personal Copy of: Mr. Jorge Diab Maluf Filho

CAPÍTULO 7
USO OS COMPONENTES DO COBIT 5

Considerações sobre Transição para Usuários do COBIT 4.1, Val IT e Risk IT

Os usuários do COBIT 4.1, Val IT e Risk IT que já estão envolvidos em atividades de implementação da Governança e Gestão Corporativa de TI - GEIT podem passar a usar o COBIT 5 e beneficiar-se da mais recente e aperfeiçoada orientação oferecida durante as próximas iterações do ciclo de vida de melhoria de suas organizações. O COBIT 5 baseia-se nas versões anteriores do COBIT, Val IT e Risk IT de modo que as organizações também podem se basear naquilo que desenvolveram utilizando as versões anteriores. As implementações serão sempre adaptadas ao ambiente e às necessidades específicas da organização seguindo a versão do COBIT mais recente e outras orientações, conforme apropriado. Estes materiais continuarão a evoluir com o tempo de acordo com a mudança das condições e o aperfeiçoamento das práticas. Os princípios do COBIT 5 são apresentados na **figura 43**.

Figura 43 - Princípios do COBIT 5



Segue abaixo um resumo das principais mudanças no COBIT 5 e como elas podem afetar a implementação.

Novos princípios da GEIT:

- **Maior foco nos habilitadores** - O COBIT 5 introduz um maior foco nos habilitadores necessários para uma GEIT eficiente, além dos modelos de habilitadores do processo conhecidos. Estes habilitadores adicionais também são referenciados em diversos processos do COBIT 5 conforme descrição no Capítulo 2.
- **Novo Modelo de Referência de Processo** - O COBIT 5 baseia-se em um modelo de processo revisado com um novo domínio de governança e diversos processos novos e modificados que agora cobrem as atividades corporativas de ponta a ponta, ou seja, negócios e TI. O COBIT 5 consolida o COBIT 4.1, Val IT e Risk IT em um único modelo renovado para se alinhar às boas práticas atuais. O novo modelo pode ser usado como um guia para ajustar, conforme necessário, o próprio modelo de processo da organização.
- **Processos novos e modificados**:
  - O COBIT 5 apresenta cinco novos processos de governança que potencializaram e melhoraram as abordagens de governança do COBIT 4.1, Val IT e Risk IT e ajudarão a aperfeiçoar e fortalecer as práticas da Governança e Gestão Corporativa de TI - GEIT em nível de gestão executiva integradas às práticas de governança corporativa existentes e alinhadas ao ISO/IEC 38500.
  - O COBIT 5 simplificou os processos de gestão e integrando o conteúdo do COBIT 4.1, Val IT e Risk IT em um único modelo. COBIT 5: Habilitando Processos fornece uma referência cruzada completa no Apêndice A. Diversos processos foram criados e modificados para refletir o pensamento atual, especificamente em:
    - APO03 Gerenciar Arquitetura da Organização.
    - APO04 Gerenciar Inovação.
    - APO05 Gerenciar Portfólio
    - APO06 Gerenciar Orçamento e Custos.
    - APO08 Gerenciar Relacionamentos.
    - APO13 Gerenciar Segurança.
    - BAI05 Gerenciar Capacitação da Mudança Organizacional.
    - BAI08 Gerenciar Conhecimento
    - BAI09 Gerenciar Ativos

Personal Copy of: Mr. Jorge Diab Maluf Filho

  - DSS05 Gerenciar Serviços de Segurança.
  - DSS06 Gerenciar Controles do Processo de Negócio.
- Os processos do COBIT 5 agora abordam de ponta a ponta as atividades do negócio e de TI, ou seja, uma visão corporativa completa. Dessa maneira provendo uma cobertura mais holística e completa das práticas, refletindo a disposição presente na organização em relação ao uso de TI. Isto torna o envolvimento, responsabilidades e prestação de contas as partes interessadas da área de negócios explícitas e transparentes.

. **Práticas e atividades**:
- A governança do COBIT 5 ou práticas de gerenciamento– são equivalentes aos objetivos de controle do COBIT 4.1 e processos do Val IT e Risk IT.
- As atividades do COBIT 5 são equivalentes às práticas de controle do COBIT 4.1 e práticas de gerenciamento do Val IT e Risk IT.
- O COBIT 5 integra e atualiza todo o conteúdo anterior em um único e novo modelo, com um nível consistente de detalhamento, com toda a orientação fornecida no COBIT 5: Habilitando Processos, facilitando aos usuários o entendimento e o uso deste material ao implementar as melhorias.

. **Metas e métricas**:
- O COBIT 5 segue os mesmos conceitos de metas e métricas do COBIT 4.1, Val IT e Risk IT, mas estes estão renomeados em objetivos corporativos, metas de TI e metas do processo, refletindo assim uma visão do nível corporativo macro.
- O COBIT 5 fornece um escalonamento revisado dos objetivos com base agora nos objetivos corporativos que orientam os objetivos de TI que, por sua vez, são apoiados por processos críticos. Isto é semelhante ao escalonamento de objetivos do COBIT 4.1 com um conjunto atualizado de objetivos e relacionamentos, além de relacionamentos primários e secundários mais detalhados. Este escalonamento continua sendo uma ferramenta importante na definição do alinhamento estratégico e escopo dos processos importantes.
- O COBIT 5 fornece exemplos de metas e métricas da organização, processos e níveis de prática de gestão. Isto é diferente do COBIT 4.1, Val IT e Risk IT, que cobriam um nível menor.

. **Entradas e saídas**:
- O COBIT 5 fornece entradas e saídas para cada prática de gestão, sendo que o COBIT 4.1 fornece isto somente ao nível de processo. Isto oferece uma orientação mais detalhada para o desenvolvimento de processos incluindo produtos do trabalho críticos e auxiliando na integração dos processos.

. **Tabelas RACI**:
- O COBIT 5 disponibiliza uma tabela RACI que descreve as papéis e responsabilidades de forma semelhante ao COBIT 4.1, Val IT e Risk IT.
- O COBIT 5 disponibiliza uma série de tabelas genéricas e de especialistas em TI e em negócios mais completa, detalhada e clara do que o COBIT 4.1 para cada prática de gestão, habilitando uma melhor definição das responsabilidades do especialista ou nível de envolvimento no desenvolvimento e implementação dos processos.

. **Modelos e avaliações de maturidade da capacidade do processo** (consultar também a 2ª e 3ª Fases na discussão do ciclo de vida da implementação):
- O COBIT 5 interrompe a abordagem da maturidade de capacidade com base no modelo do Capability Maturity Model (CMM) do COBIT 4.1, Val IT e Risk IT, e agora apoia um novo esquema de avaliação de capacidade com base no ISO/IEC 15504. Uma orientação sobre como realizar uma auto avaliação de capacidade será fornecida no guia de auto avaliação planejado para o COBIT 5.

Segue abaixo um resumo de como fazer uma análise de deficiências com base no padrão:

. Identificar e priorizar áreas de melhoria (conforme definição na 3ª Fase) considerando:
- Pontos fortes, pontos fracos e riscos identificados
- Objetivos corporativos
- Oportunidades para melhorar o nível de satisfação do cliente
- Orientação do COBIT 5 e outros padrões e boas práticas relacionadas
- Referências que fornecem uma estrutura básica de comparação para os resultados da avaliação
- Atuais metas e métricas de desempenho do processo que possam indicar as causas raízes dos orientadores de melhoria
- Risco de não concluir os objetivos de melhoria estabelecidos

. Analisar a avaliação dos pontos fortes e fracos:
- Os pontos fortes são identificados como processos com as mais elevadas classificações de nível de capacidade de processo. Considerar:
  - A experiência de boas práticas que possam ser seguidas e institucionalizadas
  - A oportunidade para melhoria da eficácia dos processos inter-relacionados
- Os pontos fortes são identificados e derivados de:
  - Classificações baixas em atributos do processo
  - Processos com práticas ausentes (considerar as práticas e atividades de gestão do COBIT 5 e de outros habilitadores bem como os padrões e boas práticas relacionados) necessárias para atingir a meta do processo

Personal Copy of: Mr. Jorge Diab Maluf Filho

  - Classificações de atributos do processo desequilibradas dentro dos níveis de capacidade necessários para atingir um objetivo corporativo específico
- Classificações baixas de atributos do processo em um grupo de processos avaliados podem indicar pontos fracos em categorias específicas do processo (por exemplo, pontuação baixa no nível 2 da capacidade do processo pode significar um ponto fraco nas categorias de processo de Gestão e Suporte).
- Da mesma forma, as classificações de atributos dos processos correlatos devem ser comparadas. Ações de melhoria podem ser necessárias para corrigir eventuais desequilíbrios.

As abordagens do COBIT 4.1, Val IT e Risk IT com base no CMM não são consideradas compatíveis com a abordagem do COBIT 5 - ISO/IEC 15504 pois os métodos usam atributos e escalas de medição diferentes. A abordagem do COBIT 5 é considerada pela ISACA por ser mais robusta, confiável e repetitiva e também apoiará uma avaliação formal por avaliadores credenciados, permitindo à organização obter uma avaliação independente e certificada, alinhada ao padrão ISO/IEC. O Capítulo 8 do COBIT 5 fornece uma descrição completa do novo modelo de capacidade de processo do COBIT 5 e como ele se compara à abordagem anterior usada no COBIT 4.1, Val IT e Risk IT.

Os usuários do COBIT 4.1, Val IT e Risk IT que desejam adotar a nova abordagem do COBIT 5 deverão realinhar suas classificações anteriores, adotar e aprender o novo método e iniciar um novo conjunto de avaliações para obter os benefícios desta nova abordagem. Embora algumas das informações reunidas nas avaliações anteriores possam ser reutilizadas, será necessário cuidado na migração desta informação porque há diferenças significativas nos requisitos.

Os usuários do COBIT 4.1, Val IT e Risk IT que desejam continuar com a abordagem baseada no CMM, seja como uma abordagem parcial ou contínua, podem usar a orientação do COBIT 5, mas devem usar a tabela de atributos genéricos do COBIT 4.1 sem os modelos de maturidade em alto nível. O procedimento em linhas gerais é o seguinte:

1. Comparar o escopo do processo com as práticas e atividades de governança e gestão do COBIT 5 a fim de identificar eventuais falhas (assumindo que a administração tenha aceitado e concordado com o escopo integral da orientação do COBIT 5). Para atender ao nível 3 (definido) e acima, todas as práticas deverão ter sido contempladas.
2. Comparar o detalhamento do processo com a tabela de atributos de maturidade do COBIT 4.1 (Apêndice E) e avaliar o nível alcançado por cada atributo. Além disso, ao avaliar cada atributo, considerar se as seguintes orientações de processo do COBIT 5 estão sendo bem aplicadas de modo geral:
   - Conscientização e comunicação - EDM01.02 e APO01.04
   - Políticas, planos e procedimentos - EDM01.02, APO01.03 e APO01.08
   - Ferramentas e automação - APO03.02
   - Habilidades e expertise - APO07.03
   - Responsabilidade e obrigação - Tabela RACI do processo e EDM01.02 e APO01.02
   - Definição e medição das metas - APO07.04 e MEA01
3. Comparar com qualquer caso de negócio e modelos disponíveis que possam existir para verificar a razoabilidade da avaliação.
4. Definir o nível geral de maturidade para o atributo com o nível mais baixo (a menos que um atributo não seja considerado de forma substancialmente significativa para a capacidade do processo) embora também considerando a cobertura das práticas de governança e gestão. Usar classificações com números inteiros ao invés de "frações" ou porcentagens. O êxito em um nível é alcançado somente quando todos os pontos de melhoria forem atendidos. A administração necessita de uma visão transparente e realista se esta ter de patrocinar as melhorias.
5. Analisar a diferença entre os níveis atuais e esperados considerando os pontos fortes e fracos do atual processo em comparação com a orientação sobre as práticas e atividades de governança e gestão do COBIT 5, os habilitadores do COBIT 5 e outros padrões e boas práticas significativas.

Planejamento e Escopo

O COBIT 5 e o material de apoio deste guia são uma forma eficiente de entender as prioridades e requisitos do negócio e de governança e este conhecimento pode ser utilizado ao implementar habilitadores de governança e gestão melhorados. Esta abordagem também aprimora a elaboração dos estudos de caso de melhorias na governança, obtendo o apoio das partes interessadas bem como a realização e monitoramento dos benefícios esperados.

A relação pode ser resumida neste fluxo descendente. O COBIT 5 ajuda a garantir o alinhamento estratégico e orienta sobre o que fazer, apoiado pelo escalonamento dos objetivos corporativos em objetivos de TI para os processos de TI fornecidos e explicados conforme a seguir:

- Objetivos corporativos
  - Objetivos de TI
    - Requisitos de Governança e Gestão
      - Processos críticos de TI
        - Práticas e atividades de governança e gestão priorizadas

Personal Copy of: Mr. Jorge Diab Maluf Filho

Ter um claro reconhecimento das atuais necessidades da parte interessada em relação à Governança e Gestão Corporativa de TI – GEIT (conforme descrito no Capítulo 3, figuras 7 e 8 e mencionado no COBIT 5) e dos atuais objetivos corporativos e como eles afetam a Governança e Gestão Corporativa de TI – GEIT é muito útil por três motivos:

- As necessidades do participante e os objetivos corporativos influenciam os requisitos e prioridades da Governança e Gestão Corporativa de TI. Por exemplo, pode haver um foco na redução de custo, conformidade ou lançamento de um novo produto da organização, cada um dos quais poderia colocar uma ênfase diferente nas atuais prioridades de governança.
- As necessidades do participante e os objetivos corporativos ajudam a se concentrar nos pontos certos ao aperfeiçoar a Governança e Gestão Corporativa de TI – GEIT na organização.
- TI auxilia as funções de TI e do negócio a realizar um melhor planejamento futuro das oportunidades para agregar valor à organização. O COBIT 5 fornece uma orientação útil e exemplos para a definição dos objetivos corporativos e objetivos de TI bem como seu inter-relacionamento. Um conjunto genérico de objetivos corporativos e objetivos de TI é apresentado de forma escalonada no COBIT 5 e no COBIT 5: Habilitando Processos. Estes exemplos permitem que os usuários do COBIT relacionem seu atual ambiente corporativo e de TI com objetivos específicos mapeando-os então em processos que possam ser pertinentes no alcance bem-sucedido destes objetivos.

Controle de Desempenho

Um princípio importante de boa governança é o de que a administração deve fornecer orientação usando objetivos claramente definidos e comunicados e então gerenciar a adesão aos objetivos através da aplicação das práticas adequadas. Monitorar o desempenho usando métricas permite que a administração garanta o alcance dos objetivos.

Os objetivos corporativos e de TI do COBIT 5 são usados como uma base para definir as metas de TI e definir uma estrutura de medição de desempenho. Os objetivos de TI são expressos como metas e devem ser alinhados aos objetivos corporativos. O COBIT 5 fornece estruturas para definir estes objetivos em três níveis: Organização, TI em geral e Processos de TI. Estes objetivos são baseados em métricas conhecidas como medições de resultado porque medem o resultado do objetivo desejado. As métricas em um nível específico também atuam como orientadores de desempenho visando o alcance dos objetivos em alto nível. Estas metas e métricas podem ser usadas para definir os objetivos e monitorar o desempenho implementando uma análise por pontos (scorecards) e relatórios de desempenho, e também para orientar melhorias.

O COBIT 5 fornece orientação sobre como dividir e classificar os objetivos corporativos e criar métricas de monitoramento com base no Balanced Scorecard (BSC).

Práticas e Atividades de Governança e Gestão

O COBIT 5 simplifica a distinção entre as práticas de governança e de gestão com a adição de um novo domínio de governança. O modelo do COBIT 5 explica as diferenças entre governança e gestão de TI na organização. A elaboração de processos e procedimentos específicos com base no COBIT 5 deve sempre se adequar às necessidades da cultura, estilo de gestão e ambiente de TI da organização. A orientação contida no COBIT 5 deve ser adaptada de forma adequada. Sugerimos a adoção das boas práticas recomendadas, porém devem ser adaptadas de modo a serem práticas e apropriadas a cada objetivo e necessidade da organização. As atividades fornecem orientação sobre o que deve ser implementado para cumprir uma prática de gestão específica.

As práticas e atividades do COBIT 5 baseiam-se nos atuais padrões e boas práticas pertinentes que também devem ser utilizados para obter uma orientação mais detalhada.

Papéis e Responsabilidades

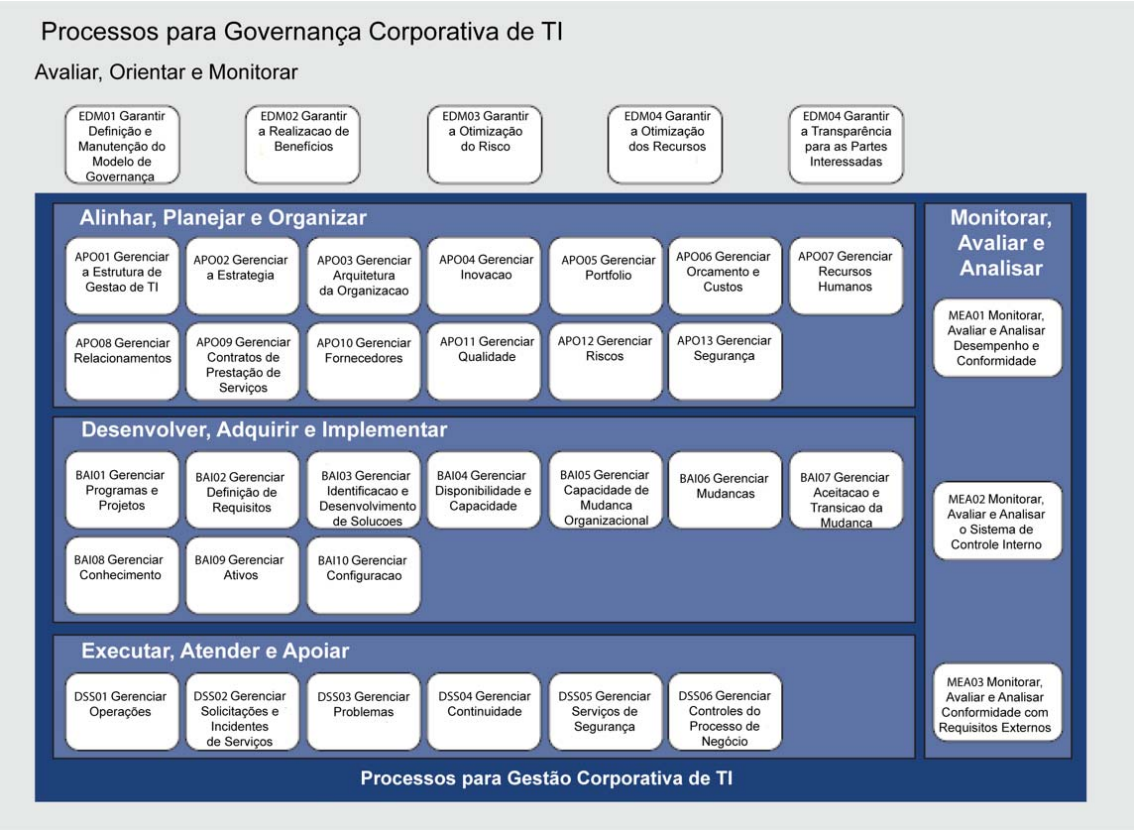
Para cada processo, o COBIT 5 fornece exemplos de tabelas RACI que indicam quem é o Responsável, quem Presta Contas e quem deve ser Consultado ou Informado sobre as atividades do processo para uma série de especialistas comuns (de ponta a ponta, negócios e TI). Os especialistas podem ser pessoas (tais como o Diretor Financeiro ou Diretor de Operações) ou estruturas (tais como a administração ou comitê de risco corporativo). Definir a responsabilidade e a obrigação é um princípio importante da GEIT da organização. Estas tabelas podem ser usadas como uma base para adaptar as tabelas RACI específicas para os processos de TI.

Personal Copy of: Mr. Jorge Diab Maluf Filho

APÊNDICE A
MAPEAMENTO DE DIFICULDADES (PAIN POINTS) EM PROCESSOS DO COBIT 5

A **figura 44** mostra o conjunto completo com os 37 processos de governança e de gestão do COBIT 5. O detalhamento dos processos, de acordo com o modelo de processo descrito anteriormente, foi incluído no COBIT 5: Habilitando Processos.

Figura 44 - Modelo de Referência de Processo do COBIT 5



Personal Copy of: Mr. Jorge Diab Maluf Filho

A **figura 45** fornece exemplos de pontos fracos (discutidos no Capítulo 3) e exemplos de processos do COBIT 5 que podem ser selecionados para a respectiva orientação sobre estes pontos fracos.

Figura 45 – Mapeamento de Dificuldades em Processos do COBIT 5

Dificuldades	Processos do COBIT 5
Frustração da organização com as iniciativas fracassadas, elevando os custos de TI e a percepção de baixo valor do negócio	EDM02, APO01, APO02, APO05, APO07, BAI01, BAI02
Incidentes significativos relacionados ao risco de TI da organização tais como perda de dados ou falha de projeto	EDM03, APO09, APO12, Domínio DSS
Problemas com a prestação de serviços terceirizados tais como níveis de serviço acordados que não estão sendo atingidos de forma consistente	EDM04, APO09, APO10
Não cumprimento dos requisitos regulatórios ou contratuais	EDM03, MEA03
TI limitando as capacidades de inovação da organização e a agilidade dos negócios	EDM04, APO02, APO04
Resultados regulares de auditoria reportando baixo desempenho de TI ou problemas reportados com a qualidade do serviço de TI	MEA02
Despesas com TI Ocultas ou Não Autorizadas	EDM02, APO05, APO06
Duplicação ou sobreposição entre iniciativas, ou desperdício de recursos	EDM02, EDM04, APO05, BAI01
Recursos de TI insuficientes, pessoal com habilidades inadequadas ou esgotamento/insatisfação do pessoal	EDM04, APO07
Mudanças habilitadas por TI que geralmente não cumprem as necessidades do negócio e entregues com atraso ou acima do orçamento.	APO02, APO05, BAI01
Esforços múltiplos e complexos de garantia de TI	MEA02
Membros da diretoria ou alta administração relutantes em envolver-se com TI, ou falta de patrocinadores de TI da área de negócios comprometidos e satisfeitos	EDM01, EDM02, APO01, APO02
Modelos complexos de operação de TI	EDM01, APO01, APO02, MEA01

Personal Copy of: Mr. Jorge Diab Maluf Filho

APÊNDICE B
EXEMPLO DE MATRIZ DE DECISÃO

A **figura 46** é um exemplo de como identificar as principais áreas que exigem papéis e responsabilidades de tomada de decisão bem definidas. Ele é disponibilizado como um guia e, se considerado útil, pode ser modificado e adaptado para se adequar à organização e aos requisitos específicos da organização.

Figura 46 - Exemplo de Matriz de Decisão

		Responsável, PrestA Contas, Consultado, Informado (RACI)							
Tópico de Decisão	Escopo	Comitê Executivo	Comitê de Estratégia de TI	Comitê de Segurança	Comitê Diretor do Programa	Comitê Diretor do Projeto	Gestão de TI	Gestão do Negócio	Funcionários
Governança	▪ Alinhamento com a governança corporativa ▪ Definição dos princípios, estruturas e objetivos	A/R	R	C			C	R	I
Estratégia do negócio	▪ Definição das metas e objetivos corporativos ▪ Decisão de onde e como TI pode facilitar e apoiar os objetivos corporativos	A/R	R	C			C	R	I
Políticas de TI	▪ Fornecimento de políticas exatas, compreensíveis e aprovadas, procedimentos, diretrizes e outros documentos às partes interessadas. ▪ Desenvolvimento e implementação das políticas de TI ▪ Execução das políticas de TI	I	A	C			R	C	C
Estratégia de TI	▪ Incorporação da gestão de TI e do negócio na conversão dos requisitos do negócio em ofertas de serviço e desenvolvimento de estratégias para a realização destes serviços de forma transparente e eficiente ▪ Envolvimento com a área de negócios e a alta administração no alinhamento do planejamento estratégico de TI com as atuais e futuras necessidades do negócio ▪ Entendimento das atuais capacidades de TI ▪ Criação de um esquema de priorização dos objetivos corporativos que quantifique os requisitos do negócio	I	A	C	I		R	C	C
Orientação da tecnologia de TI	▪ Disponibilização de plataformas adequadas aos aplicativos do negócio em consonância com a arquitetura de TI e os padrões tecnológicos definidos ▪ Criação de um plano de aquisição de tecnologia alinhado ao plano de infraestrutura tecnológica ▪ Planejamento da manutenção da infraestrutura	I	C	C			A/R	C	C
Métodos e modelos de TI	▪ Criação de estruturas organizacionais de TI transparentes, flexíveis e responsivas e definição e implementação de processos de TI que integrem os responsáveis, papéis e responsabilidades nos processos de negócios e de decisão ▪ Definição de uma estrutura de processo de TI ▪ Definição de órgãos e estruturas organizacionais apropriadas ▪ Definição de papéis e responsabilidade	I	C	C			A/R	I	I
Arquitetura corporativa	▪ Definição e implementação da arquitetura e padrões que reconheçam e potencializem as oportunidades tecnológicas ▪ Criação de um fórum para orientar a arquitetura e verificar a conformidade ▪ Definição de um plano de arquitetura equilibrado em relação ao custo, risco e requisitos	A	C	C	I	I	R	R	C

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 46 - Exemplo de Matriz de Decisão

Tópico de Decisão	Escopo	Responsável, PrestA Contas, Consultado, Informado (RACI)							
		Comitê Executivo	Comitê de Estratégia de TI	Comitê de Segurança	Comitê Diretor do Programa	Comitê Diretor do Projeto	Gestão de TI	Gestão do Negócio	Funcionários
	▪ Definição da arquitetura de informação, inclusive a definição de uma modelagem de dados corporativos que incorpore um esquema de classificação de dados ▪ Garantia da exatidão da arquitetura da informação e da modelagem de dados ▪ Atribuição da responsabilidade pelos dados ▪ Classificação da informação com o uso do esquema de classificação definido								
Investimento habilitado por TI e priorização do portfólio	▪ Tomada de decisões eficazes e eficientes sobre o portfólio e sobre os investimentos habilitados por TI ▪ Previsão e alocação de orçamentos ▪ Definição de critérios formais de investimento ▪ Medição e avaliação do valor do negócio em comparação com a previsão	I	A		C	C	R		
Investimento habilitado por TI e priorização do programa	▪ Definição e acompanhamento dos orçamentos de TI em consonância com a estratégia de TI e as decisões de investimento ▪ Definição da abordagem de gestão do programa e do projeto aplicada aos projetos de TI e permitindo a participação das partes interessadas no monitoramento do risco do projeto e andamento ▪ Definição e aplicação das estruturas e abordagens do programa e do projeto ▪ Emissão das diretrizes de gestão do projeto ▪ Realização do planejamento de cada projeto detalhado no portfólio do projeto	I	A		R	C	C/I	C/I	C/I
Gestão, monitoramento e avaliação de SLAs	▪ Identificação dos requisitos do serviço, definição dos níveis de serviço e monitoramento do cumprimento dos níveis de serviço ▪ Formalização dos acordos internos e externos alinhados com os requisitos e a capacidade de entrega ▪ Relatório sobre o cumprimento dos níveis de serviço (relatórios e reuniões) ▪ Identificação e comunicação ao planejamento estratégico dos requisitos de serviço novos e atualizados ▪ Cumprimento dos níveis de serviço operacionais relativos ao processamento de dados programado, proteção dos dados (saída) confidenciais e monitoramento e manutenção da infraestrutura	I	A	R			R	R	I
Gerenciamento de aplicativos de TI	▪ Identificação de soluções com viabilidade técnica e boa relação custo-benefício ▪ Definição dos requisitos técnicos e do negócio ▪ Realização de estudos de viabilidade conforme definição nos padrões de desenvolvimento ▪ Aprovação (ou rejeição) de requisitos e viabilidade dos resultados do estudo ▪ Garantia de haver um processo de desenvolvimento oportuno e com boa relação custo-benefício	I	I	C			A/R	C	C

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 46 - Exemplo de Matriz de Decisão									
		Responsável, PrestA Contas, Consultado, Informado (RACI)							
Tópico de Decisão	Escopo	Comitê Executivo	Comitê de Estratégia de TI	Comitê de Segurança	Comitê Diretor do Programa	Comitê Diretor do Projeto	Gestão de TI	Gestão do Negócio	Funcionários
	▪ Conversão dos requisitos do negócio em especificações do projeto ▪ Aderência de todas as modificações aos padrões de desenvolvimento ▪ Separação das atividades de desenvolvimento, teste e operação								
Gestão da infraestrutura de TI	▪ Operação do ambiente de TI alinhada com os níveis de serviço acordados e instruções definidas ▪ Manutenção da infraestrutura de TI	I	I	C			A/R	C	C
Segurança de TI	▪ Definição das políticas, planos e procedimentos de segurança de TI e monitoramento, detecção, relatório e solução de vulnerabilidades e incidentes de segurança ▪ Entendimento dos requisitos, vulnerabilidades e ameaças relativas à segurança em alinhados com os requisitos do negócio e o impacto sobre ele ▪ Gestão das identificações e autorizações do usuário de forma padronizada ▪ Testar a segurança regularmente	I	A	R			R	R	C/I
Aquisição e contratos	▪ Aquisição e manutenção dos recursos de TI que respondem à estratégia de entrega, definindo uma infraestrutura de TI integrada e padronizada e reduzindo o risco de aquisição de TI ▪ Obtenção de assessoria jurídica e contratual profissional ▪ Definição de procedimentos e padrões de aquisição ▪ Aquisição de hardware, software e serviços solicitados em alinhados com os procedimentos definidos	I	I	C			A/R	C	C
Conformidade de TI	▪ Identificação de todas as leis aplicáveis, regulamentos e contratos e o respectivo nível de conformidade de TI e otimização dos processos de TI para redução do risco de não conformidade ▪ Identificação dos requisitos legais, regulatórios e contratuais relacionados a TI ▪ Avaliação do impacto dos requisitos de conformidade ▪ Monitoramento e relatório sobre a conformidade com estes requisitos	C/I	A	C			A/R	C	C/I

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página deixada intencionalmente em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

APÊNDICE C
MAPEAMENTO DE EXEMPLOS DE CENÁRIOS DE RISCO EM PROCESSOS DO COBIT 5

Figura 47 - Cenários de Risco e Capacidades de Processo do COBIT 5		
Cenário de Risco		Capacidades de Processo do COBIT 5
Se o cenário for significativo e inerentemente provável...	*...considerando estes exemplos negativos...*	*...então considerar se estes processos do COBIT 5 necessitam de melhoria. NOTA: Nesta coluna, ao lado do número de cada processo, apresentamos um exemplo de processo a ser considerado. Estes não são os nomes dos processos.*
Risco de capacitação do benefício/valor		
Seleção do programa de TI	▪ Programas incorretos selecionados para implementação e não alinhados à estratégia corporativa e suas prioridades ▪ Duplicação entre iniciativas diferentes ▪ Um programa novo e importante gera incompatibilidade no longo prazo com a arquitetura corporativa	▪ APO02 Alinhamento das estratégias de TI e de negócios ▪ APO03 Compatibilidades com a arquitetura corporativa ▪ APO04 Identificação de oportunidades de inovação ▪ APO05 Decisões da gestão do portfólio ▪ BAI01 Planejamento e coordenação da gestão do programa
Novas tecnologias	▪ Falha na adoção e exploração de novas tecnologias (por exemplo: funcionalidade, otimização) em tempo hábil ▪ Tendências tecnológicas novas e importantes não identificadas ▪ Incapacidade de usar a tecnologia para obter os resultados desejados (ex: falha na aplicação das mudanças necessárias na organização ou no modelo de negócios)	▪ EDM04 Orientação e/ou previsão da gestão dos recursos ▪ APO02 Estratégia de identificação de oportunidades tecnológicas ▪ APO03 Arquitetura corporativa alinhada às atuais tendências tecnológicas ▪ APO04 Identificação de novas e importantes tendências tecnológicas ▪ BAI02 Capacidade de usar a nova tecnologia para definir novos modelos de negócios ▪ BAI03 Adoção e exploração de novas tecnologias
Seleção de tecnologia	▪ Seleção de tecnologias incorretas (ou seja, custo, desempenho, características, compatibilidade) na implementação	▪ APO02 Seleção de tecnologia estratégica eficiente ▪ APO03 Consistência com a tecnologia da arquitetura corporativa ▪ BAI03 Identificação e criação de soluções ▪ APO13 Impactos sobre a segurança da seleção da tecnologia
Tomada de decisão de investimento em TI	▪ Gerentes de negócios ou representantes não envolvidos nas tomadas de decisão de investimento em TI importantes em relação às oportunidades de novos aplicativos, priorização ou novas tecnologias	▪ EDM02 Orientação e/ou supervisão da gestão de valor ▪ APO02 Envolvimento da área de negócios no planejamento estratégico de TI ▪ APO03 Investimento adequado à meta da arquitetura corporativa ▪ APO05 Decisões da gestão do portfólio ▪ APO06 Monitoramento do investimento ▪ APO08 Entendimento das expectativas do negócio e das oportunidades de alavancagem de TI ▪ BAI01 Sequenciamento das fases de gestão do programa
Responsabilidade sobre TI	▪ A área de negócios não assume responsabilidade sobre as áreas de TI que deveria, tais como requisitos funcionais, prioridades de desenvolvimento e oportunidades de avaliação através de novas tecnologias	▪ EDM01-05 Responsabilidade da gestão executiva pelas decisões de TI ▪ APO01 Papéis e responsabilidades das áreas de negócios e de TI ▪ APO09 Contratos de prestação de serviço bem definidos e aprovados ▪ APO10 Contratos e relacionamentos bem definidos e gerenciados com os fornecedores ▪ BAI05 Capacitação das mudanças organizacionais em relação à responsabilidade de TI e GEIT
Conclusão do projeto de TI	▪ Projetos fracassados devido ao custo, atrasos, indefinição do escopo ou alterações nas prioridades do negócio não concluídos em tempo hábil	▪ EDM01 Políticas, estruturas organizacionais e funções GEIT ▪ EDM02 Monitoramento da governança do valor ▪ EDM04 Monitoramento da governança dos recursos

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 47 - Cenários de Risco e Capacidades de Processo do COBIT 5		
Cenário de Risco		Capacidades de Processo do COBIT 5
Se o cenário for significativo e inerentemente provável...	*...considerando estes exemplos negativos...*	*...então considerar se estes processos do COBIT 5 necessitam de melhoria. NOTA: Nesta coluna, ao lado do número de cada processo, apresentamos um exemplo de processo a ser considerado. Estes não são os nomes dos processos.*
		▪ BAI01 Sequenciamento das fases de gestão do programa/projeto ▪ APO05 Tomada de decisão eficiente relativa à gestão do portfólio ▪ APO06 Monitoramento do investimento ▪ BAI01 Monitoramento do desempenho
Economia do projeto de TI	▪ Estouro do orçamento de um projeto de TI isolado ▪ Estouros de orçamento consistentes e importantes de projetos de TI ▪ Falta de visão sobre o projeto e a economia do portfólio	▪ EDM01 Políticas, estruturas organizacionais e funções GEIT ▪ EDM02 Monitoramento da governança dos valores ▪ EDM04 Monitoramento da governança dos recursos ▪ APO06 Monitoramento do investimento ▪ BAI01 Planejamento e monitoramento da gestão do projeto/ programa
Risco de realização do programa/projeto		
Agilidade e flexibilidade da arquitetura	▪ Arquitetura de TI complexa e inflexível obstruindo novas evoluções e ampliações	▪ APO01 Processos de TI e de negócios definidos e eficientes ▪ EDM04 Governança sobre a otimização dos recursos ▪ APO02 Planejamento estratégico de resposta ▪ APO03 Manutenção da arquitetura corporativa ▪ APO04 Inovação e início da mudança ▪ APO05 Tomada de decisão sobre a gestão do portfólio ▪ BAI02,03 Métodos do ciclo de vida de desenvolvimento rápido ▪ APO13 Segurança da manutenção em um ambiente ágil e flexível
Integração de TI aos processos de negócios	▪ Grande dependência e uso da computação do usuário final e soluções específicas para importantes necessidades de informação ▪ Soluções de TI isoladas e não integradas em apoio aos processos de negócios	▪ EDM01 Políticas, estruturas organizacionais e funções GEIT ▪ APO01 Papéis e responsabilidades das áreas de negócios e de TI ▪ APO02 Alinhamento das estratégias de TI e de negócios ▪ APO03 Projetos e decisões relativos à arquitetura ▪ APO08 Relações entre negócios e TI ▪ BAI02 Definição e entendimento dos requisitos do negócio ▪ BAI03 Adaptação dos processos de negócios às novas soluções de TI ▪ BAI05 Gerenciamento das mudanças organizacionais em relação a TI
Implementação de software	▪ Falhas operacionais após a colocação de um novo software em ambiente de produção ▪ Usuários sem preparação para usar e explorar o novo software	▪ APO11 Atividades consistentes e eficientes de controle da qualidade ▪ BAI01 Gestão do projeto ▪ BAI02 Definições dos requisitos ▪ BAI03 Desenvolvimento de soluções ▪ BAI05 Gestão das mudanças organizacionais referentes à implementação do software ▪ BAI06 Gestão da mudança ▪ BAI07 Testes completos da solução ▪ BAI08 Apoio ao conhecimento
Realização do projeto	▪ Eventual atraso na realização do projeto de TI pelo departamento de desenvolvimento interno ▪ Atrasos constantes e importantes na realização do projeto de TI	▪ EDM01 Políticas, estruturas organizacionais e funções GEIT ▪ EDM02 Monitoramento da governança dos valores ▪ APO06 Monitoramento do investimento

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 47 - Cenários de Risco e Capacidades de Processo do COBIT 5		
Cenário de Risco		Capacidades de Processo do COBIT 5
Se o cenário for significativo e inerentemente provável...	*...considerando estes exemplos negativos...*	*...então considerar se estes processos do COBIT 5 necessitam de melhoria. NOTA: Nesta coluna, ao lado do número de cada processo, apresentamos um exemplo de processo a ser considerado. Estes não são os nomes dos processos.*
	▪ Atrasos excessivos em um projeto de desenvolvimento de TI terceirizado	▪ BAI01 Planejamento e monitoramento da gestão do programa/projeto
Qualidade do projeto	▪ Qualidade insatisfatória dos resultados do projeto devido ao software, documentação ou conformidade com os requisitos funcionais	▪ APO03 Padrões da arquitetura ▪ APO11 Atividades consistentes e eficientes de controle da qualidade ▪ BAI01 Planejamento e monitoramento do controle de qualidade do programa/projeto
Riscos de Entrega de Serviços/Operações de TI		
Condição da tecnologia de infraestrutura	▪ Tecnologia de TI obsoleta, como redes, segurança e armazenamento, não pode satisfazer novos requerimentos do negócio	▪ EDM04 Direção e/ou supervisão da gestão de recursos ▪ APO02 Reconhecer e tratar estrategicamente questões da capacidade atual da TI ▪ APO03 A Manutenção de arquitetura corporativa ▪ APO04 Identificar tendências tecnológicas importantes ▪ BAI03 Manutenção da infraestrutura ▪ BAI04 Planejando e abordando as questões de capacidade e desempenho ▪ BAI09 Manutenção de ativos
Obsolescência do software	▪ Software obsoleto, insuficientemente documentado, com alto custo de manutenção, difícil de ser ampliado ou não integrado à arquitetura atual	▪ EDM04 Orientação e/ou previsão da gestão dos recursos ▪ APO02 Reconhecimento e abordagem estratégica dos atuais problemas de capacidade de TI ▪ APO03 Manutenção da arquitetura corporativa ▪ APO04 Identificação de novas e importantes tendências tecnológicas ▪ BAI03 Manutenção dos aplicativos ▪ BAI09 Manutenção dos ativos ▪ DSS06 Controles dos processos de negócios
Conformidade regulatória	▪ Não conformidade com os regulamentos de contabilidade ou produção	▪ EDM01 Políticas e papéis de conformidade de GEIT ▪ APO01 Políticas e orientação sobre a conformidade regulatória ▪ APO02 Planejamento dos requisitos regulatórios ▪ BAI02 Identificação e definição dos requisitos regulatórios ▪ BAI 03 Monitoramento dos requisitos de conformidade e status atual
Seleção/desempenho de fornecedores terceirizados	▪ Suporte inadequado e prestação dos serviços pelos fornecedores não alinhados aos SLAs ▪ Desempenho inadequado do prestador de serviço terceirizado de acordo com o contrato de terceirização em grande escala e longo prazo	▪ APO10 Escolha, gestão e relacionamentos eficazes com fornecedores ▪ BAI03 Gestão eficaz de aquisições
Roubo de infraestrutura	▪ Roubo de laptop com dados confidenciais ▪ Roubo de um número considerável de servidores de desenvolvimento	▪ APO01 Políticas e orientação sobre a proteção dos ativos ▪ APO07 Verificação das referências e antecedentes dos novos funcionários e organizações contratadas ▪ BAI03 Proteção de ativos críticos durante as atividades de manutenção ▪ DSS05 Medidas de segurança física
Destruição da infraestrutura	▪ Destruição do banco de dados devido à sabotagem ou outras causas ▪ Destruição acidental de laptops pessoais	▪ DSS01 Gestão da proteção do ambiente e das instalações ▪ DSS05 Medidas de segurança física
Pessoal de TI	▪ Saída ou indisponibilidade prolongada dos principais funcionários de TI	▪ APO07 Desenvolvimento e retenção de recursos humanos de TI ▪ BAI08 Gestão do conhecimento tácito

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 47 - Cenários de Risco e Capacidades de Processo do COBIT 5		
Cenário de Risco		Capacidades de Processo do COBIT 5
Se o cenário for significativo e inerentemente provável...	*...considerando estes exemplos negativos...*	*...então considerar se estes processos do COBIT 5 necessitam de melhoria. NOTA: Nesta coluna, ao lado do número de cada processo, apresentamos um exemplo de processo a ser considerado. Estes não são os nomes dos processos.*
	▪ Principal equipe de desenvolvimento deixando a organização ▪ Incapacidade de recrutar pessoal de TI	
Competência e habilidades de TI	▪ Falta ou incompatibilidade das habilidades em TI necessárias devido às novas tecnologias ou outras situações ▪ Falta de conhecimento do negócio pelo pessoal de TI	▪ APO07 Definição e desenvolvimento dos requisitos de competência do pessoal das áreas de TI e de negócios ▪ BAI08 Apoio ao conhecimento
Integridade do software	▪ Modificação intencional do software acarretando dados incorretos ou ações fraudulentas ▪ Modificação não intencional do software acarretando resultados inesperados ▪ Erros não intencionais de configuração e gerenciamento da mudança	▪ BAI02 Definição dos requisitos de controle do aplicativo ▪ BAI06 Gestão da mudança ▪ BAI07 Práticas de testes e aceitação ▪ BAI10 Dados de configuração ▪ DSS05 Controles de acesso ▪ DSS06 Controles de processos do negócio
Infraestrutura (hardware)	▪ Configuração incorreta de componentes de hardware ▪ Dano de servidores críticos no centro de processamento de dados devido a acidentes ou outras causas ▪ Adulteração intencional de hardware tais como dispositivos de segurança	▪ BAI03 Proteção de ativos críticos durante as atividades de manutenção ▪ BAI10 Dados de configuração ▪ DSS05 Medidas de segurança física
Desempenho do software	▪ Constante mau funcionamento de aplicativos críticos ▪ Problemas de desempenho intermitentes com sistema de software importante	▪ BAI03 Garantia da qualidade do desenvolvimento do software ▪ BAI04 Planejamento e abordagem dos problemas de capacidade e desempenho ▪ DSS03 Análise de causa raiz e solução do problema
Capacidade do sistema	▪ Incapacidade dos sistemas de processar o número de operações quando o número de usuários aumenta ▪ Incapacidade dos sistemas de gerenciar as cargas do sistema quando novos aplicativos ou iniciativas são implementados	▪ APO03 Princípios da arquitetura para escalabilidade e agilidade ▪ BAI03 Manutenção da infraestrutura ▪ BAI04 Planejamento e tratamento dos problemas de capacidade e desempenho
Obsolescência do software de infraestrutura	▪ Uso de versões sem suporte de sistemas de software em operação ▪ Uso de sistema de banco de dados obsoleto	▪ EDM04 Orientação e/ou supervisão da gestão dos recursos ▪ APO02 Reconhecimento e abordagem estratégica dos atuais problemas de capacidade de TI ▪ APO03 Manutenção da arquitetura corporativa ▪ APO04 Identificação de novas e importantes tendências tecnológicas ▪ BAI03 Manutenção da infraestrutura ▪ DSS03 Problemas relacionados a Malware nos controles dos processos de negócios
Malware	▪ Intrusão de Malware em servidores operacionais críticos ▪ Infecção constante de laptops com Malware	▪ APO01 Políticas e orientação sobre o uso de software ▪ DSS05 Detecção de software mal intencionado
Ataques lógicos	▪ Ataque por vírus ▪ Usuários não autorizados tentando invadir os sistemas ▪ Ataque de negação de serviço ▪ Desfiguração do Website ▪ Espionagem industrial	▪ APO01 Políticas e orientação sobre a proteção e uso dos ativos de TI ▪ BAI03 Requisitos de segurança das soluções ▪ DSS05 Controles de acesso e monitoramento da segurança

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 47 - Cenários de Risco e Capacidades de Processo do COBIT 5		
Cenário de Risco		Capacidades de Processo do COBIT 5
Se o cenário for significativo e inerentemente provável...	*...considerando estes exemplos negativos...*	*...então considerar se estes processos do COBIT 5 necessitam de melhoria. NOTA: Nesta coluna, ao lado do número de cada processo, apresentamos um exemplo de processo a ser considerado. Estes não são os nomes dos processos.*
Mídia da informação	▪ Perda/divulgação de mídias portáteis (ex: CD, dispositivos USB, discos portáteis) contendo dados confidenciais ▪ Perda da mídia de backup ▪ Divulgação acidental de informações confidenciais devido ao não cumprimento das diretrizes de tratamento da informação	▪ APO01 Políticas e orientação sobre a proteção e uso dos ativos de TI ▪ DSS05, 06 Proteção dos dispositivos de armazenamento e mídia móveis e/ou removíveis
Desempenho das instalações	▪ Falhas intermitentes nas instalações (ex: telecomunicações, eletricidade) ▪ Falhas constantes ou prolongadas nas instalações	▪ APO08 Relacionamentos/gestão dos principais fornecedores de utilitários ▪ DSS01 Gestão da proteção do ambiente e das instalações ▪ Instalações e construções inacessíveis devido a greve em sindicato de trabalhadores ▪ Principais funcionários indisponíveis devido a greve Pessoal chave indisponível devido a greve ▪ APO07 Relacionamentos do pessoal e indivíduos chave ▪ BAI08 Gestão do conhecimento da equipe
Integridade dos (bancos de) dados	▪ Alteração intencional nos dados (ex: contabilidade, dados sobre segurança, resultados das vendas) ▪ Corrupção do banco de dados (ex: banco de dados de clientes ou operações)	▪ APO03 Arquitetura da informação e classificação de dados ▪ BAI03 Padrões de desenvolvimento ▪ BAI06 Gestão da mudança ▪ DSS01 Gerenciamento do armazenamento dos dados ▪ DSS05 Controles de acesso
Invasão lógica	▪ Usuários que contornam os direitos de acesso lógico ▪ Usuários que obtêm acesso a informações não autorizadas ▪ Usuários que roubam dados confidenciais	▪ APO01 Políticas e orientação sobre proteção e uso dos ativos de TI ▪ DSS05 Controles de acesso e monitoramento da segurança ▪ APO07 Políticas de funcionários contratados
Erros operacionais de TI	▪ Erros do operador durante o backup, atualizações ou manutenção dos sistemas ▪ Entrada de informações incorretas	▪ APO07 Treinamento de funcionários ▪ DSS01 Procedimentos operacionais ▪ DSS06 Controles de processos do negócio
Conformidade contratual	▪ Não conformidade com os contratos de licença de software (ex: uso e/ou distribuição de software não licenciado) ▪ Obrigações contratuais não cumpridas pelo prestador do serviço perante os clientes	▪ APO09 Monitoramento de contratos de prestação de serviço ▪ APO10 Monitoramento dos contratos e relações com o fornecedor ▪ DSS02 Gestão de licenças de software ▪ BAI 03 Monitoramento dos requisitos de conformidade contratual e do status atual
Ambiental	▪ Não conformidade com os contratos de licença de software (ex: uso e/ou distribuição de software não licenciado) ▪ Obrigações contratuais não cumpridas pelo prestador do serviço perante os clientes	▪ APO09 Monitoramento de contratos de prestação de serviço ▪ APO10 Monitoramento dos contratos e relações com o fornecedor ▪ DSS02 Gestão de licenças de software ▪ BAI 03 Monitoramento dos requisitos de conformidade contratual e do status atual
Ações da natureza	▪ Terremoto ▪ Tsunami ▪ Fortes tempestades/furacões ▪ Incêndios de grandes proporções	▪ DSS01 Gestão do ambiente e das instalações ▪ DSS05 Segurança física ▪ DSS04 Gerenciar Continuidade

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página deixada intencionalmente em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

APÊNDICE D
EXEMPLO DE CASO DE NEGÓCIO

Obs.: Este exemplo é fornecido como um guia genérico e não prescritivo para incentivar a elaboração de um caso de negócio que justifique o investimento em um programa de implementação da GEIT. Cada organização tem seus próprios motivos para melhorar a GEIT e sua própria abordagem para preparação dos estudos de caso, que pode variar desde uma abordagem detalhada com ênfase nos benefícios quantificados até uma abordagem de nível e qualidade mais elevados. As organizações devem seguir o atual caso de negócio interno e as abordagens de justificativa do investimento, se houver, e usar este exemplo e a orientação contida nesta publicação para ajudar a se concentrar em todos os problemas que devem ser abordados. Mais orientações sobre a elaboração dos estudos de caso podem ser encontradas no processo APO05 do COBIT 5 e no The Business Case Guide: Using Val IT™ 2.0.

O exemplo de cenário é de uma grande organização multinacional com uma combinação de unidades de negócios tradicionais bem estabelecidas e com novos negócios com base na Internet que adotam as tecnologias mais recentes. Muitas das unidades de negócios foram adquiridas e estão presentes em diversos países com diferentes ambientes políticos, culturais e econômicos locais. A gerência executiva do grupo central tem sido influenciada pela orientação de governança corporativa mais recente, inclusive o COBIT, que tem sido usada de forma centralizada por algum tempo. Eles querem garantir que a rápida expansão e adoção de TI avançada em muitos de seus negócios crie o valor esperado e ainda gerencie os novos riscos significativos. Eles instruíram, entretanto, a adoção pela organização de uma abordagem GEIT uniforme que também inclui o envolvimento das funções de auditoria e de risco bem como o relatório anual interno da administração da unidade de negócios sobre a adequação dos controles em todas as entidades.

Embora o exemplo seja derivado de situações reais, ele não reflete o caso de uma organização real específica.

Sumário Executivo

Este caso de negócio documenta as linhas gerais do escopo do programa GEIT proposto pela Acme Corporation com base no COBIT.

É necessário um caso de negócio adequado para garantir que a diretoria da Acme Corporation e que cada unidade de negócios adote a iniciativa, identifique os potenciais benefícios e então monitore o caso de negócio para garantir que os benefícios esperados sejam obtidos.

O escopo inclui todas as entidades de negócios que constituem a Acme Corporation. Deve-se reconhecer que alguma forma de priorização será aplicada sobre todas as entidades para cobertura inicial pelo programa GEIT, devido aos recursos limitados do programa.

Há uma série de participantes interessados nos resultados do programa GEIT, que vão desde o conselho de administração da Acme Corporation até a administração local de cada entidade, bem como participantes externos tais como acionistas e órgãos governamentais.

Alguns desafios significativos devem ser considerados, além do risco, na implementação do programa GEIT na escala global necessária. Um dos aspectos mais desafiadores é a natureza empreendedora de muitos dos negócios de Internet, bem como o modelo de negócios descentralizado ou federativa existente na Acme Corporation.

O objetivo do programa GEIT será atingido concentrando-se na capacidade dos processos da Acme Corporation e outros facilitadores em relação aos definidos no COBIT, relevantes a cada unidade de negócios. Os processos relevantes e priorizados que receberão atenção em cada entidade serão identificados através de uma abordagem de seminários (workshop) facilitada pelos membros do programa GEIT, começando com os objetivos corporativos de cada unidade, bem como os cenários de risco de TI do negócio aplicados à unidade de negócios específica.

O objetivo do programa GEIT é garantir que as estruturas de governança adequadas sejam adotadas e aumentar o nível de capacidade e adequação dos processos de TI relevantes, com a expectativa de que conforme a capacidade de um processo de TI aumente, o risco associado diminua proporcionalmente e sua eficiência e qualidade aumentem. Desta forma, os reais benefícios do negócio podem ser obtidos em cada unidade de negócios.

Uma vez que o processo de avaliação do nível de capacidade dentro de cada unidade de negócios houver sido estabelecido, espera-se que as auto avaliações continuem em cada unidade de negócios como uma prática de negócios normal.

O programa GEIT será realizado em duas fases distintas. A primeira é a fase de desenvolvimento, onde a equipe desenvolverá e testará a abordagem e o conjunto de ferramentas que será usado na Acme Corporation. No final da 1ª fase, os resultados serão apresentados à administração do grupo para aprovação final. Uma vez que a aprovação final tiver sido obtida na forma de um caso de negócio aprovado, o programa GEIT será implementado na entidade de acordo com a sua definição.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Deve-se observar que não é responsabilidade do programa GEIT implementar as ações corretivas identificadas em cada unidade de negócios. O programa GEIT meramente reportará o progresso informado por cada unidade de negócios, de forma consolidada.

O desafio final que deverá ser atingido pelo programa GEIT é o de reportar os resultados de forma sustentável de agora em diante. Este aspecto tomará tempo e bastante discussão e o desenvolvimento terá de ser dedicado a isso, o que resultará em um aperfeiçoamento dos atuais mecanismos de reporte e painéis de resultados corporativos.

Um orçamento inicial para a fase de desenvolvimento do programa GEIT terá sido elaborado. O orçamento será detalhado em uma tabela separada. Um orçamento detalhado também será concluído para a 2ª fase do projeto e enviado para aprovação pela administração do grupo.

Referência (Ver Capítulo 2. Posicionamento GEIT)

GEIT é uma parte integral da governança corporativa geral e concentra-se no desempenho de TI e na gestão do risco atribuível às dependências de TI que a organização tem.

TI está integrada às operações dos negócios da Acme Corporation e para muitos, especialmente os negócios de Internet, está no centro de suas operações. Portanto, GEIT segue a estrutura de gestão do grupo, um formato descentralizado. A gestão de cada subsidiária/unidade de negócios é responsável por garantir que os processos adequados sejam implementados visando a GEIT.

Anualmente, a gestão de cada subsidiária importante é obrigada a enviar um relatório formal por escrito ao comitê de risco apropriado, que é um subconjunto da diretoria, sobre em que medida a política GEIT foi implementada durante o exercício financeiro. Exceções significativas devem ser reportadas em cada reunião do comitê de risco em questão.

O conselho de administração, com o auxílio dos comitês de risco e do conselho fiscal, garantirá que o desempenho da GEIT do grupo seja avaliado, monitorado, reportado e divulgado em uma declaração sobre a GEIT como parte do relatório integrado. Essa declaração terá como base os relatórios obtidos junto às equipes de auditoria interna, risco e conformidade e à administração de cada subsidiária importante a fim de fornecer aos participantes internos e externos informações relevantes e confiáveis sobre a qualidade do desempenho GEIT do grupo.

Os serviços de auditoria interna garantirão à administração e ao conselho fiscal a adequação e eficiência da GEIT.

O risco de TI do negócio será reportado e discutido como parte de um processo de gestão de risco nos registros de riscos apresentados ao comitê de risco pertinente.

Desafios de Negócio (Ver Capítulo 3. Primeiros Passos - Identificar a Necessidade de Agir: Reconhecer Pontos Fracos e Eventos Desencadeadores)

Devido à natureza penetrante de TI e ao ritmo das mudanças tecnológicas, uma estrutura confiável é necessária para controlar adequadamente todo o ambiente de TI e evitar falhas no controle que possam expor a organização a um risco inaceitável.

A intenção é não impedir o funcionamento das operações de TI das diversas entidades operacionais. Em vez disso, pretende-se melhorar o perfil de risco das entidades de modo a fazer sentido para os negócios e ainda aumentar a qualidade e eficiência do serviço, e ao mesmo tempo alcançar explicitamente a conformidade não apenas com a diretriz de GEIT do grupo Acme Corporation, mas também com quaisquer outros requisitos legislativos, regulatórios e/ou contratuais.

Alguns exemplos de pontos de atenção enfrentados são:

- Esforços de garantia de TI complicados devido à natureza empreendedora de muitas das unidades de negócios
- Modelos de operação de TI complexos devido aos modelos de negócios com base nos serviços de internet em uso
- Entidades geograficamente dispersas, compostas por diversas culturas e idiomas
- O modelo de controle de negócios descentralizado/federado e altamente autônomo empregado no grupo
- Níveis razoáveis de implementação de gestão de TI, considerando-se uma força de trabalho de TI altamente técnica e, às vezes, volátil
- Equilíbrio por TI da orientação da organização relativa às capacidades de inovação e agilidade do negócio com a necessidade de administrar o risco e ter o controle adequado
- A definição dos níveis de risco e de tolerância de cada unidade de negócios
- O aumento da necessidade de se concentrar no cumprimento dos requisitos de conformidade regulatória (privacidade) e contratuais (indústria de cartões de pagamento - payment card industry [PCI])
- Resultados de auditoria regular sobre os fracos controles de TI e problemas reportados sobre a qualidade do serviço de TI
- Prestação de serviços novos e inovadores em um mercado altamente competitivo com sucesso e dentro do prazo

Personal Copy of: Mr. Jorge Diab Maluf Filho

Análise de Lacunas (Gap) e Objetivos

Não há atualmente no âmbito do grupo uma abordagem ou um modelo de GEIT nem o uso de boas práticas e padrões de TI. No âmbito de unidade de negócios local há diversos níveis de adoção de boas práticas em relação à GEIT. Consequentemente, muito pouca atenção é dada tradicionalmente ao nível de capacidade do processo de TI. Com base na experiência, os níveis geralmente são baixos.

O objetivo do programa GEIT é, portanto, aumentar o nível de capacidade e adequação dos processos e controles de TI adequados para cada unidade de negócios, de forma priorizada.

O resultado deve ser a identificação e articulação do risco significativo e a administração deve estar em condições de tratar o risco e informar sobre seu status. Conforme o nível de capacidade de cada unidade de negócios aumenta, o perfil de risco de TI do negócio de cada entidade deve diminuir e a qualidade e eficiência devem aumentar na mesma proporção.

Em última análise, o valor do negócio deverá aumentar em função da eficiência da GEIT.

Alternativas Consideradas

Há muitas estruturas de TI, cada uma tentando manter aspectos específicos de TI sob controle. O modelo do COBIT é considerado por muitos a líder mundial em modelos de controle e de GEIT. O modelo do COBIT foi implementado por algumas subsidiárias do grupo. Também foi especificamente mencionada no relatório do King III[8] como um possível modelo a ser implementada para GEIT.

O COBIT foi escolhido pela Acme Corporation como a estrutura preferida para implementação GEIT e deverá, portanto, ser adotado por todas as subsidiárias.

O COBIT não precisa ser necessariamente adotado em sua totalidade; somente as áreas pertinentes à subsidiária ou unidade de negócios específica deverão ser implementadas; considerando o seguinte:

1. A fase de desenvolvimento de cada entidade no ciclo de vida do negócio
2. Os objetivos corporativos de cada entidade
3. A importância de TI para a unidade de negócios
4. O risco de TI do negócio enfrentado por cada entidade
5. Requisitos legais e contratuais
6. Quaisquer outros motivos pertinentes

Quando outras estruturas já tiverem sido implementadas em uma subsidiária ou unidade de negócios específica, ou sua implementação estiver programada para o futuro, tal implementação deverá ser mapeada no COBIT para fins de relatório, auditoria e clareza do controle interno.

Solução Proposta

O programa GEIT está sendo planejado em duas fases distintas.

1ª Fase. Pré-planejamento (Ver Capítulo 3. Primeiros Passos em Direção a GEIT)

A 1ª Fase do programa GEIT é a fase de desenvolvimento. Durante esta fase do programa os seguintes passos deverão ser concluídos:

1. Finalização da estrutura da equipe principal entre o suporte da gestão de riscos e a TI do grupo
2. Conclusão do treinamento básico do COBIT pela equipe principal
3. Seminário (workshop) com a equipe principal conduzido para definir uma abordagem para o grupo
4. Criação de uma comunidade online dentro da Acme Corporation para atuar como um repositório para compartilhamento do conhecimento
5. Identificação de todos os participantes e suas necessidades
6. Clarificação e realinhamento, se necessário, das atuais estruturas do comitê, papéis e responsabilidades, regras de decisão e sistemas de relatórios
7. Desenvolvimento e manutenção de um caso de negócio do programa GEIT como uma base para a implementação do programa com sucesso
8. Plano de comunicação dos princípios de orientação, políticas e benefícios esperados ao longo do programa
9. Desenvolvimento das ferramentas de relatório e avaliação a serem usadas durante a vigência do programa e além
10. Teste da abordagem em uma entidade local. Esta atividade foi escolhida para facilitar a logística e o refinamento da abordagem e das ferramentas.
11. Piloto da abordagem refinada em uma das entidades externas. Isto se destina a entender e quantificar as dificuldades de execução da fase de avaliação do programa GEIT sob condições de negócios mais desafiadoras.

[8] King III é o Código de Governança Corporativa da África do Sul.

Personal Copy of: Mr. Jorge Diab Maluf Filho

12. Apresentação do caso de negócio e da abordagem definitivos, inclusive um plano de implementação para aprovação pela gerência executiva da Acme Corporation

2ª Fase. Implementação do Programa (Ver Capítulo 3. Aplicação da Abordagem do Ciclo de Vida de Melhoria Contínua)

O programa GEIT foi projetado para iniciar um programa permanente de melhoria contínua, com base em um ciclo de vida iterativo facilitado, seguindo estas etapas:

1. Determinar os orientadores de melhoria GEIT, a partir de uma perspectiva da Acme Corporation Group e outra da unidade de negócios.
2. Determinar o atual status GEIT.
3. Determinar a condição de GEIT desejada (para curto e longo prazos).
4. Determinar o que deve ser implementado no âmbito da unidade de negócios para facilitar os objetivos corporativos locais, alinhando-se assim às expectativas do grupo.
5. Implementar os projetos de melhoria identificados e definidos no âmbito da unidade de negócios local.
6. Realizar e monitorar os benefícios.
7. Sustentar a nova forma de trabalho mantendo o impulso.

Escopo do Programa

O programa GEIT cobrirá o seguinte:

1. Todas as entidades do grupo; contudo, as entidades deverão ser priorizadas para interação, devido aos recursos limitados do programa.
2. O método de priorização. Será necessário defini-lo junto à gestão da corporação, mas isso poderá ser feito com base no (a):
   a. Tamanho do investimento
   b. Ganhos/contribuição ao grupo
   c. Perfil de risco a partir de uma perspectiva de grupo
   d. Uma combinação dos itens 'a' até 'c'.
3. A lista de entidades a serem contempladas durante o atual exercício financeiro. Isto ainda deve ser finalizado e definido junto à gestão da corporação.

Metodologia e Alinhamento do Programa (Ver Capítulo 6. Tarefas, papéis e Responsabilidades do Ciclo de Vida da Implementação)

O programa GEIT será regido usando uma abordagem de seminários (workshop) facilitada e interativa com todas as entidades.

A abordagem começa com os objetivos de negócio e os responsáveis pelos objetivos, geralmente o Diretor-Presidente (CEO) e o Diretor Financeiro (CFO). Esta abordagem deverá garantir que os resultados do programa estejam estritamente alinhados aos resultados e prioridades previstos para o negócio.

Uma vez que os objetivos de negócio tenham sido cobertos, o foco volta-se então para as operações de TI, geralmente sob o controle do Diretor de Tecnologia (CTO) ou do Diretor de Informática (CIO), onde mais detalhes sobre o risco de TI do negócio e os objetivos de TI são considerados.

Os objetivos de negócio e de TI, assim como o risco de TI do negócio, são então combinados em uma ferramenta (com base na orientação do COBIT) que fornecerá um conjunto de áreas de enfoque dentro dos processos do COBIT para consideração pela unidade de negócios. Desta forma, a unidade de negócios estará apta a priorizar seus esforços de correção no tratamento das áreas de risco de TI.

Entregáveis do Programa (Ver Capítulo 6. Tarefas, Papéis e Responsabilidades do Ciclo de Vida da Implementação)

Conforme mencionado anteriormente, um objetivo geral do programa de GEIT é incluir as boas práticas GEIT nas operações contínuas das diversas entidades do grupo.

Resultados específicos serão produzidos pelo programa GEIT de modo que a corporação possa medir a realização dos resultados pretendidos pelo programa GEIT. Isto incluirá o seguinte:

1. O programa GEIT facilitará o compartilhamento do conhecimento interno através da plataforma intranet e potencializará os atuais relacionamentos com os fornecedores para o benefício das unidades de negócios individuais.
2. Relatórios detalhados sobre cada interação de facilitação com as unidades de negócios serão elaborados. Os relatórios incluirão:
   a. Os atuais objetivos de negócio priorizados e os respectivos objetivos de TI baseados no COBIT
   b. O risco de TI identificado pela unidade de negócios em um formato padronizado, e as áreas de enfoque definidas para receber a atenção da unidade de negócios, com base nos processos e práticas do COBIT e outros

Personal Copy of: Mr. Jorge Diab Maluf Filho

habilitadores recomendados
   c. O exposto acima será derivado da ferramenta de avaliação do programa GEIT
3. Relatórios gerais do progresso da cobertura pretendida das unidades de negócios da corporação pelo programa GEIT serão produzidos.
4. Relatórios consolidados do grupo cobrirão:
   a. O progresso das unidades de negócios envolvidas com seus projetos de implementação definidos com base no monitoramento das métricas de desempenho aprovadas
   b. Visão consolidada do risco de TI sobre as entidades da Acme Corporation
   c. Requisitos específicos do(s) comitê(s) de risco
5. Serão produzidos relatórios financeiros sobre o orçamento do programa em comparação com o valor real gasto.
6. Serão feitos monitoramento e relatórios do benefício em comparação com metas e métricas de valor definidas pelas unidades de negócios.

Riscos do Programa (Ver Capítulo 5. Capacitação da Mudança)

Em seguida serão considerados possíveis tipos de risco para um início bem-sucedido e êxito permanente do programa GEIT da Acme Corporation. Esses riscos serão mitigados focando na capacitação da mudança e serão monitorados e abordados continuamente através das análises do programa e do registro de riscos. Estes tipos de risco são:

1. Compromisso e apoio ao programa pela administração, em nível de grupo e também em nível de unidade de negócios local
2. Demonstração da real criação de valor e dos benefícios para cada entidade local por meio da adoção do programa. As entidades locais podem desejar adotar o processo para o valor que criarão, em vez de fazê-lo por causa da política vigente.
3. Participação ativa da administração local na implementação do programa
4. Identificação dos principais participantes de cada entidade para participação no programa
5. Compreensão (Insight) do negócio nas classificações de gestão de TI
6. Integração bem-sucedida com quaisquer iniciativas de governança e conformidade existentes dentro do grupo
7. As estruturas de comitê adequadas para supervisionar o programa. Por exemplo, o progresso geral do programa GEIT pode se tornar um item da agenda do comitê executivo de TI. Equivalentes locais também teriam de ser constituídos. Isto poderia ser replicado geograficamente e ainda em nível de sociedade holding local, conforme o caso.

Participantes (Ver Capítulo 3. Reconhecimento das Papéis e Responsabilidades dos Participantes)

Os seguintes especialistas foram identificados como participantes no resultado do programa GEIT:

1. Comitê de Risco
2. Comitê executivo de TI
3. Equipe de governança
4. Equipe de conformidade
5. Gerência regional
6. Gerência executiva em nível de entidade local (inclusive gerência de TI)
7. Serviços de auditoria interna

Uma estrutura definitiva com os nomes dos especialistas será compilada e publicada após consulta à gestão do grupo.

O programa GEIT necessita que os participantes identificados forneçam o seguinte:

1. Orientação geral sobre o programa GEIT. Isto inclui decisões sobre temas importantes relacionados à governança definidos em uma tabela RACI do grupo de acordo com a orientação do COBIT, bem como a definição das prioridades, aprovação dos financiamentos e dos objetivos de valor.
2. Aceitação dos resultados, bem como o monitoramento dos benefícios esperados, do programa GEIT

Análise de Custo-Benefício

O programa deverá identificar os benefícios esperados e monitorar se o real valor do negócio está sendo gerado pelo investimento realizado. A gerência local deverá motivar e sustentar o programa. Uma sólida GEIT deverá produzir os seguintes benefícios que serão definidos como metas específicas para cada unidade de negócios, monitorados e depois medidos durante a implementação para garantir que sejam realizados:

1. Maximização da realização das oportunidades de negócios através de TI e mitigação do risco de TI do negócio em níveis aceitáveis, garantindo assim que o risco seja responsavelmente ponderado em relação às oportunidades contidas em todas as iniciativas do negócio
2. Apoio aos objetivos corporativos por meio dos investimentos principais e dos retornos ideais sobre os investimentos, alinhando assim as iniciativas e objetivos de TI diretamente com a estratégia de negócios
3. Conformidade legislativa, regulatória e contratual e conformidade com a política interna e os regulamentos
4. Uma abordagem consistente para medição e monitoramento do progresso, eficiência e eficácia
5. Maior qualidade do serviço prestado

Personal Copy of: Mr. Jorge Diab Maluf Filho

6. Redução do custo das operações de TI e/ou maior produtividade de TI realizando um trabalho mais consistente em menos tempo e com menos recursos

Os custos centrais incluirão o tempo necessário para a gestão do programa pelo grupo, recursos para consultoria externa e cursos de formação inicial. Estes custos centrais foram estimados na 1ª Fase. O custo dos seminários (workshops) de avaliação da gerência e dos responsáveis pelos processos de cada unidade de negócios será financiado localmente e um orçamento será fornecido. Iniciativas específicas para melhoria de projetos de cada unidade de negócios serão estimadas na 2ª Fase e consideradas caso a caso e também como um todo. Isto permitirá que o grupo maximize a eficiência e padronização.

Desafios e Fatores de Sucesso (Ver Capítulo 4. Identificação dos Desafios e Fatores de Sucesso da Implementação)

A **figura 48** resume os desafios que poderiam afetar o programa GEIT durante o período de implementação do programa e os fatores de sucesso críticos que devem ser abordados para garantir que o resultado seja bem-sucedido.

Figura 48 – Desafios e Ações Planejadas da Acme Corporation

Desafio	Fatores de Sucesso Críticos - Ações Planejadas
Incapacidade de obter e manter apoio para os objetivos de melhoria	Mitigar através das estruturas de comitê do grupo (a ser definido e constituído).
Falha de comunicação entre as áreas de TI e de negócios	Envolver todos os participantes.
O custo das melhorias supera os benefícios observados	Foco na identificação do benefício.
Falta de confiança e bons relacionamentos entre TI e a organização	▪ Fomentar uma comunicação aberta e transparente sobre o desempenho, associada ao controle de desempenho corporativo. ▪ Focar nas interfaces do negócio e mentalidade do serviço. ▪ Publicar os resultados positivos e as lições aprendidas para ajudar a criar e manter a credibilidade. ▪ Garantir a credibilidade e liderança do Diretor de Informática na criação de confiança e dos relacionamentos. ▪ Formalizar as papéis e responsabilidades da governança da organização de modo que a responsabilidade pelas decisões seja clara. ▪ Identificar e comunicar indícios de problemas reais, riscos que devam ser evitados e benefícios a serem realizados (em termos de negócios) em relação aos investimentos propostos. ▪ Focar no planejamento da capacitação de mudança.
Falta de conhecimento do ambiente da Acme pelos responsáveis pelo programa GEIT	Aplicar uma metodologia de avaliação consistente.
Diversos níveis de complexidade (técnico, organizacional, modelo operacional)	Tratar as entidades conforme o caso. Benefícios das lições aprendidas e compartilhamento do conhecimento.
Conhecimento dos modelos, procedimentos e práticas GEIT	Treinamento e orientação.
Resistência à mudança	Garantir que a implementação do ciclo de vida também inclua atividades de capacitação da mudança.
Adoção de melhorias	Capacitar o fortalecimento local em nível de entidade.
Dificuldade de integrar GEIT aos modelos de governança dos parceiros terceirizados	▪ Envolver fornecedores/terceiros na atividades GEIT. ▪ Incorporar condições e direito de auditoria nos contratos.
Falha em entender os compromissos de implementação GEIT	▪ Gerenciar as expectativas. ▪ Mantê-las simples, realistas e práticas. ▪ Dividir o projeto geral em pequenos projetos atingíveis, gerando experiência e benefícios.
Tentativa de fazer muito de uma só vez; abordagem muito complexa e/ou problemas graves de TI	▪ Aplicar princípios de gestão de projetos e de programas. ▪ Usar marcos.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Figura 48 – Desafios e Ações Planejadas da Acme Corporation	
Desafio	Fatores de Sucesso Críticos - Ações Planejadas
	▪ Priorizar tarefas 80/20 (80% de benefício com 20% de esforço) e tomar cuidado com a ordem correta de sequenciamento; capitalizar os resultados rápidos. ▪ Criar confiança; possuir as habilidades e a experiência para manter isso de forma simples e prática. ▪ Reutilizar o que já existe como base.
TI no modo "apagar incêndio" e/ou não priorizando corretamente e incapaz de focar na GEIT	▪ Aplicar as habilidades de boa liderança. ▪ Obter o compromisso e orientação da alta gestão de modo que as pessoas possam se concentrar na GEIT. ▪ endereçar as causas raiz no ambiente operacional (intervenção externa, priorização da gestão de TI). ▪ Aplicar uma disciplina mais rigorosa sobre/gestão dos requisitos do negócio. ▪ Obter assessoria externa.
Habilidades e competências de TI necessárias não adotadas, ex: entendimento do negócio, processos, habilidades sociais	Focar no planejamento da capacitação da mudança: ▪ Desenvolvimento ▪ Treinamento ▪ Acompanhamento ▪ Orientação ▪ Feedback sobre os processos de recrutamento ▪ Habilidades cruzadas
Melhorias não adotadas ou aplicadas	Usar uma abordagem caso a caso com princípios definidos para a entidade local. Sua implementação deve ser prática.
Benefícios difíceis de demonstrar ou comprovar	Identificar as métricas de desempenho.
Perda de interesse e impulso	Criar o compromisso em nível de grupo, inclusive comunicação.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página deixada intencionalmente em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho

APÊNDICE E
TABELA DE ATRIBUTOS DE MATURIDADE DO COBIT 4.1

Figura 49 - Tabela de Maturidade do COBIT 4.1

Conscientização e Comunicação	Políticas, Planos e Procedimentos	Ferramentas e Automação	Habilidades e Expertise	Responsabilidade e	Definição e Medição dos Objetivos
1. Está surgindo O reconhecimento da necessidade do processo. Há uma comunicação esporádica das questões.	Há abordagens isoladas dos processos e práticas. O processo e as políticas não foram definidos.	Algumas ferramentas podem existir; seu uso baseia-se em ferramentas básicas na área de trabalho. Não há uma abordagem planejada quanto ao uso da ferramenta.	As habilidades exigidas pelo processo não estão identificadas. Não existe um plano de treinamento e não há treinamento formal.	Não há definição de prestação de contas e responsabilidades. As pessoas se encarregam dos problemas e reagem a eles por conta própria.	Os objetivos não são claros e medições não são feitas.
2. Há a consciência da necessidade de agir. A gestão comunica as questões gerais.	Surgem processos semelhantes e comuns, mas são altamente intuitivos devido à expertise individual. Alguns aspectos do processo são repetitivos devido à expertise individual e pode haver alguma documentação e entendimento informal das políticas e procedimentos.	Há abordagens comuns em relação ao uso das ferramentas, mas elas se baseiam nas soluções desenvolvidas por pessoas chave. As ferramentas dos fornecedores podem ter sido adquiridas; mas provavelmente não são aplicadas corretamente, e podem até mesmo ser softwares inúteis, sem utilidade (shelfware).	Requisitos mínimos de habilidades são identificados para áreas críticas. O treinamento é disponibilizado em resposta às necessidades e não com base em um plano definido e o treinamento informal é feito no local de trabalho.	Uma pessoa assume sua responsabilidade e é geralmente considerada prestadora de contas, mesmo se isto não estiver definido formalmente. Há uma confusão sobre a responsabilidade pelos problemas e uma cultura de culpa tende a existir.	Há definição de alguns objetivos; algumas medidas financeiras são estabelecidas, mas são conhecidas somente pela alta gestão. Há monitoramento inconsistente em áreas isoladas.
3. Há entendimento da necessidade de agir. A gestão é mais formal e estruturada em sua comunicação.	O uso de boas práticas é observado. O processo, políticas e procedimentos são definidos e documentados em todas as atividades chave.	Um plano foi definido para o uso e padronização das ferramentas para a automatização do processo. Ferramentas estão sendo usadas para suas finalidades básicas, mas nem todas podem estar de acordo com o plano definido, e podem não ser integradas entre si.	As qualificações necessárias são definidas e documentadas para todas as áreas. Um plano de treinamento formal foi desenvolvido, mas o treinamento formal ainda se baseia nas iniciativas individuais.	As responsabilidades e a prestação de contas do processo são definidas e os donos do processo foram identificados. O dono do processo provavelmente não tem plena autoridade para exercer suas responsabilidades.	Algumas metas de eficácia e medições foram definidas, mas não são comunicadas, e há uma clara associação com os objetivos de negócio. Processos de medição são adotados, mas não são consistentemente aplicados. Ideias Balanced Scorecard de TI estão sendo adotadas, assim como uma eventual aplicação intuitiva da análise de causa raiz.
4. Há um entendimento de todos os requisitos. Técnicas maduras de comunicação são aplicadas e ferramentas padronizadas de comunicação estão em uso.	O processo é sólido e completo; boas práticas internas são aplicadas. Todos os aspectos do processo são documentados e repetíveis. As políticas foram aprovadas e assinadas pela gestão. Padrões para o desenvolvimento e manutenção de processos e procedimentos são adotados e seguidos.	Ferramentas são implementadas de acordo com um plano padronizado e algumas foram integradas a outras ferramentas relacionadas. As ferramentas estão sendo usadas nas principais áreas para automatizar a gestão do processo e monitorar as atividades e controles críticos.	As capacidades necessárias são atualizadas de forma rotineira em todas as áreas, a proficiência é garantida em todas as áreas críticas e a certificação é incentivada. Técnicas maduras de treinamento são aplicadas de acordo com o plano de treinamento, e o compartilhamento de conhecimento é incentivado. Todos os especialistas no domínio interno são envolvidos, e a eficácia do plano de treinamento é avaliada.	As responsabilidades e a prestação de contas do processo são aceitas e trabalham para permitir que um dono de processo cumpra plenamente suas responsabilidades. Uma cultura de gratificação está estabelecida e motiva uma ação positiva.	Eficiência e eficácia são medidas e comunicadas e associadas aos objetivos s de negócio e ao plano estratégico de TI. O Balanced Scorecard de TI é implementado em algumas áreas com as exceções observadas pela gestão e a análise de causa raiz está sendo padronizada. A melhoria contínua está surgindo.
5. Há um entendimento avançado e prospectivo dos requisitos. Há uma comunicação proativa das questões com base nas tendências, técnicas maduras de comunicação são aplicadas e ferramentas de comunicação integradas estão em uso.	Boas práticas e padrões externos são aplicados. A documentação do processo é aprimorada para fluxos de trabalho automatizados. Processos, políticas e procedimentos são padronizados e integrados visando facilitar a gestão e melhoria ponta a ponta.	Conjuntos de ferramentas padronizadas são usados na organização. As ferramentas foram plenamente integradas a outras ferramentas correlatas para permitir o apoio aos processos de ponta a ponta. Ferramentas estão sendo usadas para apoiar a melhoria do processo e detectar automaticamente exceções do controle.	A organização incentiva formalmente a melhoria contínua das habilidades, com base nos objetivos pessoais e organizacionais claramente definidos. O treinamento e a formação apoiam as boas práticas externas e o uso de conceitos e técnicas de ponta. O compartilhamento do conhecimento é uma cultura da organização, e sistemas com base no conhecimento estão sendo implantados. Especialistas externos e líderes do setor são usados para orientação.	Os donos do processo tem autonomia para tomar decisões e tomar medidas. A aceitação da responsabilidade foi cascateada para todos os níveis inferiores da organização de forma consistente.	Há um sistema integrado de medição de desempenho associando o desempenho de TI aos objetivos de negócio através da aplicação global do Balanced Scorecard de TI. Exceções são globalmente e consistentemente observadas pela gestão e análises de causa raiz são aplicadas. A melhoria contínua é um modo de vida.

Personal Copy of: Mr. Jorge Diab Maluf Filho

Página intencionalmente deixada em branco

Personal Copy of: Mr. Jorge Diab Maluf Filho